Psa Moodle Rapid Assessment Report

Table of Contents

- **Assessment ID:** ra-2026-09-09T045716Z
- **Target repository:** psa-moodle (bcgov/psa-moodle)
- **Application type:** web-app (Moodle 4.5 on OpenShift, Helm-deployed)
- **Assessment date:** 2026-09-09
- **Total findings:** 64 (0 Critical, 8 High, 18 Medium, 37 Low, 1 Informational)
- **Overall risk score:** 100 / 100 → **Critical tier**
- **Components assessed:** 15

Risk-score note. The overall score of 100 is the contract formula `min(100, Σ severity-weights)` where the weighted sum is `8×5 + 18×2 + 37×1 = 113`, capped at 100. It reflects the **volume** of findings (64 across 15 components), not the presence of any individual Critical-severity finding — there are **zero** Critical findings. The highest-severity issues are 8 High findings concentrated in RBAC over-permissioning, the container supply chain, missing security headers, egress network policy, and credential handling. *(Counts reflect 2 severity corrections applied during reverse-validation: VULN-001 Medium→Low, LOG-002 High→Medium — see `assessment-validation.md`.)*

0.1 Scope

This run synthesized the following **in-scope** domains only:

- authentication
- authorization
- code-vulnerabilities
- configuration
- cryptography
- dependencies
- secrets
- security-logging
- testing
- business-workflow (structural traces; produces no findings)

The overall risk score and all severity/OWASP/component rollups above are scoped to these in-scope domains.

Out of scope for this run (absence is not a gap):

- **Dependency reachability / VEX (Stage 3.5)** — Not in scope. Skipped (trigger condition): `dependencies.json` contains no `VULNERABLE_DEPENDENCY` findings (only `supply-chain-risk` and `outdated-dependency` issue types), so no CVE call-path analysis was warranted. CVE-free dependency severities reflect supply-chain/EOL risk, not raw CVSS scores.
- **GitHub Dependabot intelligence (a-1015)** — Not in scope. Skipped (environment): `toolReadiness.githubMcp=false`.
- **GitHub CodeQL code security (a-1016)** — Not in scope. Skipped (environment): `toolReadiness.githubMcp=false`.
- **GitHub Secret Scanning (a-1017)** — Not in scope. Skipped (environment): `toolReadiness.githubMcp=false`.

GitHub MCP integration was not available for this assessment; Dependabot, CodeQL, and Secret Scanning data were not included.

0.2 Summary

psa-moodle is an infrastructure-and-configuration repository: it packages Moodle 4.5 (cloned from upstream at image-build time) into hardened container images and a Helm chart for OpenShift, with a local Podman Compose stack for development. The custom, in-repo attack surface is therefore container build definitions, PHP overlay config, nginx config, the Helm chart (deployments, RBAC, NetworkPolicies, Secrets, monitoring), and the ops backup/restore shell scripts — not Moodle application source.

Against that surface the assessment is broadly **defensively mature but with consistent hardening gaps**. The deployment already demonstrates good patterns: default-deny NetworkPolicies with a per-hop allowlist, non-root capability-dropped containers, auto-generated admin/Valkey credentials sourced from Secrets, a dedicated namespace-scoped ops ServiceAccount, and a genuine backup/restore- rehearsal pipeline. The 9 High findings cluster into five themes:

1. **RBAC over-permissioning of the ops ServiceAccount** (AUTHZ-001/002/003) — `pods/exec`, `secrets get/list`, and `postgresclusters create/delete` are all granted namespace-wide with no `resourceNames` scoping, so a compromise of the ops workload escalates to namespace-wide command execution, secret theft, and the ability to delete the production database.
2. **Unpinned/unverified container supply chain** (DEP-001/002) — six upstream Moodle plugin/theme repos are cloned from floating branches into the production image with no pin, checksum, or review gate.
3. **Missing browser security headers on the internet-facing edge** (CONFIG-001) — no CSP/X-Frame-Options for a platform serving heavy user-generated content.
4. **Over-broad egress NetworkPolicy** (CONFIG-006) — `0.0.0.0/0` external HTTPS egress applied release-wide, including to nginx which needs none.

5. **Sensitive-data handling / test coverage** (LOG-002, TEST-001) — the Moodle admin password is passed as a process CLI argument, and there are no automated authn/authz/input-handling tests.

A large share of the Medium/Low findings are systemic hardening omissions repeated across every workload (default ServiceAccount token automount, `readOnlyRootFilesystem: false`, floating image tags, unencrypted SMTP alerting), which is what drives the high finding count and the capped risk score.

0.3 Assessment Overview

Metric	Value
Total findings	64
Critical	0
High	8
Medium	18
Low	37
Informational	1
Components assessed	15
Dependencies inventoried	29 (15 outdated, 0 with known CVEs)
Overall risk score / tier	100 / Critical (volume-driven)

0.3.1 Findings by domain

Domain	Findings	Highest severity
AUTHENTICATION	2	Low
AUTHORIZATION	9	High
CODE_VULNERABILITY	8	Medium
CONFIGURATION	10	High
CRYPTOGRAPHY	6	Medium
DEPENDENCIES	13	High
SECRETS	2	Low
SECURITY_LOGGING	7	High
TESTING	7	High

0.3.2 OWASP Top 10 (2021) breakdown

Category	Count	C / H / M / L / I
A01:2021 Broken Access Control	9	0 / 3 / 5 / 1 / 0
A02:2021	7	0 / 0 / 2 / 4 / 1

Category	Count	C / H / M / L / I
Cryptographic Failures		
A03:2021 Injection	2	0 / 0 / 0 / 2 / 0
A05:2021 Security Misconfiguration	16	0 / 2 / 2 / 12 / 0
A06:2021 Vulnerable & Outdated Components	7	0 / 0 / 2 / 5 / 0
A07:2021 Identification & Authentication Failures	4	0 / 0 / 0 / 4 / 0
A08:2021 Software & Data Integrity Failures	6	0 / 2 / 3 / 1 / 0
A09:2021 Security Logging & Monitoring Failures	6	0 / 1 / 3 / 2 / 0

The 7 TESTING findings carry no OWASP 2021 mapping and are excluded from this table.

0.4 Component Risk Ranking

Weighted score = `Critical×10 + High×5 + Medium×2 + Low×1`, then ×1.5 for components appearing in a cross-cutting issue, ×1.3 for external exposure, and ×0.8 where comprehensive test coverage exists.

Rank	Component	Critical	High	Medium	Low	Cross-Cutting	Score
1	php-fpm-application	0	3	7	10	Yes	59
2	ops-tooling	0	3	3	5	Yes	31
3	web-container	0	1	2	5	Yes (external)	27
4	install-job	0	1	1	1	Yes	12
5	network-policy	0	1	0	1	Yes	9
6	cron-workload	0	0	2	1	Yes	8
7	valkey-cache	0	0	1	3	Yes	8
8	monitoring-observability	0	0	1	2	Yes	6
9	local-dev-compose	0	0	0	4	No	4

Rank	Component	Critical	High	Medium	Low	Cross-Cutting	Score
10	cicd-pipeline	0	0	1	0	Yes	2
11	postgresql-cluster	0	0	0	2	No	2
12	helm-chart-topology	0	0	0	1	No	1
13	moodledata-storage	0	0	0	1	Yes	1
14	openshift-route	0	0	0	0	No	0
15	documentation-runbooks	0	0	0	0	No	0

0.5 Cross-Cutting Issues

Seven cross-cutting patterns span two or more domain reports:

1. **Unencrypted, unauthenticated SMTP for all alerting** — the same BC Gov relay on port 25 is used with no TLS by both the ops shell alerting path and the Alertmanager email receiver; audit/alert content travels in cleartext. *(cryptography + security-logging — CRYPTO-004, CRYPTO-005, LOG-003, LOG-004)*
2. **Database TLS not application-enforced** — `config.openshift.php` sets no `dbsslmode` and the `/etc/db-tls` mount referenced in a comment is not implemented in the chart, so encryption-in-transit to Postgres is unverified rather than fail-closed. *(configuration + cryptography — CONFIG-004, CRYPTO-002)*
3. **Missing HTTP security headers on the internet-facing edge** — no CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, or Permissions-Policy anywhere in the only nginx server block. *(code-vulnerabilities + configuration — VULN-006, CONFIG-001, CONFIG-002, CONFIG-003)*
4. **Unpinned/unverified supply-chain artifacts with no CI scan gate** — floating plugin/theme branches and checksum-free binary fetches reach production while no SAST/SCA/secret/image scan runs before push. *(dependencies + testing — DEP-001, DEP-002, DEP-003, DEP-004, DEP-009, TEST-002)*
5. **Over-permissioned ops RBAC compounds ops-image supply-chain exposure** — the namespace-wide `-ops` grants are inherited by any build-time compromise of the checksum-free ops image. *(authorization + dependencies — AUTHZ-001, AUTHZ-002, AUTHZ-003, DEP-009)*
6. **World-writable moodledata directory permissions on the shared RWX volume** — both shipped Moodle config variants set `directorypermissions` to `02777/0777` on a PVC mounted read-write by both php and cron. *(code-vulnerabilities + configuration — VULN-001, VULN-002, CONFIG-010)*

7. **Systemic pod-level over-privilege** — default ServiceAccount token automount left enabled on every workload and `readOnlyRootFilesystem:false` on the primary app containers, uniformly weakening blast-radius containment. *(authorization + configuration — AUTHZ-005..009, CONFIG-007)*

0.6 Business Workflow Summary

Six end-to-end workflows were traced from the seven entry points in `architecture.json`'s `entryPointInventory[]` (the `/health` probe folded into WF-001 as an internal branch):

- **WF-001** Learner HTTP request (Route → NetworkPolicy → Web → PHP-FPM → data stores)
- **WF-002** Moodle scheduled-task runner (cron)
- **WF-003** Daily backup-integrity verification
- **WF-004** Moodledata snapshot + retention prune
- **WF-005** Weekly restore rehearsal
- **WF-006** Post-install database bootstrap (Helm hook)

Automation maturity: the workflow worker traced all entry points at high confidence, corroborating a mature default-deny + least-privilege ops posture. Workflows with non-empty `securityControlsAbsent`:

- **WF-001** — no WAF/rate-limiting at the edge; egress defaults to `0.0.0.0/0` (see CONFIG-006); `readOnlyRootFilesystem:false` on web/php (see CONFIG-007).
- **WF-002** — no per-task isolation on the shared RWX moodledata volume; `readOnlyRootFilesystem:false` on cron.
- **WF-003 / WF-004 / WF-005** — unauthenticated, unencrypted SMTP alert path (see LOG-003/LOG-004/CRYPTO-004/CRYPTO-005); WF-003 also notes RBAC `secrets:[get,list]` not scoped to a named resource (see AUTHZ-002).
- **WF-006** — admin password passed as a process CLI argument (see LOG-002); no in-repo admin-password rotation mechanism.

The workflow/analysis-workflow VIBE template and skill were unavailable for this run; the workflow worker followed the mode's own structural instructions.

0.7 Dependency Analysis

29 dependencies were inventoried across all components: **20 runtime, 6 build, 3 dev**; **28 direct, 1 transitive**; **15 outdated**, and **0 with known CVEs**. No dependency carries a confirmed CVE, so all 13 dependency findings are supply-chain-risk or outdated/EOL classifications rather than `VULNERABLE_DEPENDENCY` entries. The dominant risks are (a) six upstream Moodle plugin/theme repositories cloned from floating branches into the production image with no pin (DEP-001/002), (b) checksum-free binary/script fetches executed at build time (DEP-003/004/009), and (c) floating base-image tags and two runtimes approaching end-of-support (PHP 8.3 ~2026-11, Alpine 3.20) (DEP-006/008).

Stage 3.5 (dependency reachability) was not run for this assessment. CVE severity is not applicable here — no dependency has a known CVE; the dependency findings reflect supply-chain and end-of-life risk, not raw CVSS scores.

0.8 Finding Chains

Chain data is sourced authoritatively from rapid-assessment/data/finding-chaining.json (`artifactStatus: "partial"`).

- **Total emitted chains:** 0
- **Total candidates considered:** 8
- **Verification status:** all zero (no chains emitted, so nothing pending)

No validated multi-finding attack chains were emitted. This is a tooling limitation, not an absence of plausible attack paths: three of the eight rejected candidates (**CAND-0001, CAND-0002, CAND-0003**) are *otherwise chain-eligible* attack paths that were rejected only with `reasonCode: unverified-edge` because no hashing/execution tool was available in any session to compute the mandatory deterministic SHA-256 `chainId`. They should be read as a **risk-amplification consideration**, not as discovered chains:

- **CAND-0001** (DEP-009 → AUTHZ-001 → AUTHZ-002 → AUTHZ-003) — a build-time compromise of the checksum-free ops image inherits the ops ServiceAccount's namespace-wide `pods/exec`, `secrets get/list`, and `postgresclusters create/delete` grants, escalating to full namespace compromise and production database deletion.
- **CAND-0002** (DEP-001/DEP-002 → TEST-002 → VULN-001) — an unreviewed commit on an unpinned upstream plugin ships to production with no CI scan gate, then the world-writable moodledata mode lets it plant files on storage shared with the cron workload.
- **CAND-0003** (AUTHZ-005 → CONFIG-006) — an (unproven) compromise of the internet-facing web pod could exfiltrate its automounted default ServiceAccount token over the pod's unrestricted `0.0.0.0/0` external HTTPS egress; rests on an unproven initial-compromise precondition.

The remaining five rejected candidates (CAND-0004..0008) were rejected on merits (missing entry point, duplicate/supersedes, or missing evidence). Because no chains were emitted, chain data does not alter any finding totals, severity counts, `allFindings[]`, or the overall risk score.

0.9 Claims Index

Every finding across all in-scope domain workers (all severities) appears below. This index is the canonical input to reverse validation.

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
AUTH-001	AUTHENTICATION	AUTH-001 (Low): Valkey session-store AUTH credential silently falls back to empty string (fail-open) if CACHE_PASSWORD unset	authentication-worker	config/moodle/config.local.php:39	rapid-assessment/findings/security/authentication.md
AUTH-002	AUTHENTICATION	AUTH-002 (Low): Local-dev Valkey session store runs `protected-mode no` with no requirepass	authentication-worker	config/valkey/valkey.conf:5-6	rapid-assessment/findings/security/authentication.md
AUTHZ-001	AUTHORIZATION	AUTHZ-001 (High): Unscoped pods/exec grant lets ops SA exec into any pod in the namespace	authorization-worker	chart/psa-moodle/templates/rbac-ops.yaml:30-33	rapid-assessment/findings/security/authorization.md
AUTHZ-002	AUTHORIZATION	AUTHZ-002 (High): Unscoped secrets get/list grant lets ops SA read every Secret in the namespace	authorization-worker	chart/psa-moodle/templates/rbac-ops.yaml:34-38	rapid-assessment/findings/security/authorization.md
AUTHZ-003	AUTHORIZATION	AUTHZ-003 (High): Unscoped postgresclusters create/delete	authorization-worker	chart/psa-moodle/templates/rbac-ops.yaml:39-42	rapid-assessment/findings/security/authorization.md

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
		grant permits deleting the production PostgresCluster			
AUTHZ-004	AUTHORIZATION	AUTHZ-004 (Low): Optional ClusterRoleBinding to system:aggregate-to-view grants cluster-wide read (default off)	authorization-worker	chart/psa-moodle/templates/rbac-ops.yaml:70-94	rapid-assessment/findings/security/authorization.md
AUTHZ-005	AUTHORIZATION	AUTHZ-005 (Medium): Web container pod spec does not disable default SA token automount	authorization-worker	chart/psa-moodle/templates/web-deployment.yaml:23-29	rapid-assessment/findings/security/authorization.md
AUTHZ-006	AUTHORIZATION	AUTHZ-006 (Medium): PHP-FPM pod spec does not disable default SA token automount	authorization-worker	chart/psa-moodle/templates/php-deployment.yaml:23-29	rapid-assessment/findings/security/authorization.md
AUTHZ-007	AUTHORIZATION	AUTHZ-007 (Medium): Cron workload pod spec does not disable default SA token automount	authorization-worker	chart/psa-moodle/templates/cron-deployment.yaml:36-41	rapid-assessment/findings/security/authorization.md
AUTHZ-008	AUTHORIZATION	AUTHZ-008 (Medium): Install Job pod	authorization-worker	chart/psa-moodle/templates/job-install.yaml:29-	rapid-assessment/findings/se

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
		spec does not disable default SA token automount		35	curity/authorization.md
AUTHZ-009	AUTHORIZATION	AUTHZ-009 (Medium): Valkey cache pod spec does not disable default SA token automount	authorization-worker	chart/psa-moodle/templates/valkey-statefulset.yaml:26-31	rapid-assessment/findings/security/authorization.md
VULN-001	CODE_VULNERABILITY	VULN-001 (Low): World-writable moodledata directory mask (02777) in deployed OpenShift config *(corrected from Medium during reverse-validation)*	code-vulnerabilities-worker	config/moodle/config.openshift.php:28-32	rapid-assessment/findings/security/code-vulnerabilities.md
VULN-002	CODE_VULNERABILITY	VULN-002 (Low): World-writable moodledata directory mask (0777) in local dev config	code-vulnerabilities-worker	config/moodle/config.local.php:26-30	rapid-assessment/findings/security/code-vulnerabilities.md
VULN-003	CODE_VULNERABILITY	VULN-003 (Low): PHP version disclosed via X-Powered-By (expose_php not disabled) — absence	code-vulnerabilities-worker	config/php/php.ini:13-18	rapid-assessment/findings/security/code-vulnerabilities.md

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
		claim			
VULN-004	CODE_VULNERABILITY	VULN-004 (Low): No disable_functions hardening for dangerous PHP functions — absence claim	code-vulnerabilities-worker	config/php/php.ini:1-38	rapid-assessment/findings/security/code-vulnerabilities.md
VULN-005	CODE_VULNERABILITY	VULN-005 (Low): nginx version disclosed via Server header (server_tokens not disabled) — absence claim	code-vulnerabilities-worker	config/nginx/default.conf:10-13	rapid-assessment/findings/security/code-vulnerabilities.md
VULN-006	CODE_VULNERABILITY	VULN-006 (Low): Missing HTTP security response headers in nginx server block — absence claim	code-vulnerabilities-worker	config/nginx/default.conf:65-69	rapid-assessment/findings/security/code-vulnerabilities.md
VULN-007	CODE_VULNERABILITY	VULN-007 (Low): Unsanitized env-var interpolation into VolumeSnapshot manifest piped to oc apply (operator-controlled input)	code-vulnerabilities-worker	scripts/ops/moodle-data-snapshot.sh:26-38	rapid-assessment/findings/security/code-vulnerabilities.md
VULN-	CODE	VULN-008	code-	scripts/ops/restore	rapid-

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
008	_VULNERABILITY	(Low): Unsanitized env-var interpolation into PostgresCluster manifest piped to oc apply (operator-controlled input)	vulnerabilities-worker	-rehearsal.sh:47-68	assessment/findings/security/code-vulnerabilities.md
CONFIG-001	CONFIGURATION	CONFIG-001 (High): nginx sets no Content-Security-Policy and no X-Frame-Options header	configuration-worker	config/nginx/default.conf:11-20	rapid-assessment/findings/security/configuration-management.md
CONFIG-002	CONFIGURATION	CONFIG-002 (Medium): nginx sets no X-Content-Type-Options nosniff / Referrer-Policy header	configuration-worker	config/nginx/default.conf:11-20	rapid-assessment/findings/security/configuration-management.md
CONFIG-003	CONFIGURATION	CONFIG-003 (Low): nginx sets no Permissions-Policy header	configuration-worker	config/nginx/default.conf:11-20	rapid-assessment/findings/security/configuration-management.md
CONFIG-004	CONFIGURATION	CONFIG-004 (Medium): DB connection dboptions sets no dbsslmode; TLS	configuration-worker	config/moodle/config.openshift.php:18-26	rapid-assessment/findings/security/configuration-managemen

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
		enforcement not explicit			t.md
CONFIG-005	CONFIGURATION	CONFIG-005 (Low): moodle.debug: true set in dev and poc overlays (base/test correctly false)	configuration-worker	chart/psa-moodle/values-dev.yaml:3-5	rapid-assessment/findings/security/configuration-management.md
CONFIG-006	CONFIGURATION	CONFIG-006 (High): egress externalHttpsCidr 0.0.0.0/0 applied release-wide, granting nginx unrestricted external HTTPS egress	configuration-worker	chart/psa-moodle/templates/networkpolicy.yaml:232-252	rapid-assessment/findings/security/configuration-management.md
CONFIG-007	CONFIGURATION	CONFIG-007 (Low): readOnlyRootFilesystem:false on web/php/cron containers (sidecar correctly uses true)	configuration-worker	chart/psa-moodle/templates/web-deployment.yaml:57-61	rapid-assessment/findings/security/configuration-management.md
CONFIG-008	CONFIGURATION	CONFIG-008 (Low): Hardcoded ‘moodle’/‘moodle’ Postgres credential in local-dev compose.yaml	configuration-worker	compose.yaml:13-18	rapid-assessment/findings/security/configuration-management.md
CONFIG-009	CONFIGURAT	CONFIG-009 (Low): allow-	configuration-worker	chart/psa-moodle/templates/	rapid-assessment

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
	ION	monitoring NetworkPolicy uses podSelector:{} (namespace-wide, broader than release scope)		monitoring.yaml:8-19	/findings/security/configuration-management.md
CONFIG-010	CONFIGURATION	CONFIG-010 (Low): $CFG->directorypermissions 02777 world-writable in OpenShift config variant	configuration-worker	config/moodle/config.openshift.php:32	rapid-assessment/findings/security/configuration-management.md
CRYPTO-001	CRYPTOGRAPHY	CRYPTO-001 (Low): Valkey has no tls-port/tls-cert; Redis-protocol session/cache traffic is cleartext	cryptography-worker	chart/psa-moodle/templates/valkey-configmap.yaml:1-24	rapid-assessment/findings/security/cryptographic-security-assessment.md
CRYPTO-002	CRYPTOGRAPHY	CRYPTO-002 (Medium): DB TLS not application-enforced (no dbsslmode); /etc/db-tls mount not implemented in chart	cryptography-worker	config/moodle/config.openshift.php:18-26	rapid-assessment/findings/security/cryptographic-security-assessment.md
CRYPTO-003	CRYPTOGRAPHY	CRYPTO-003 (Low): pgBackRest repo1-cipher-type unset; backup archives not	cryptography-worker	chart/psa-moodle/templates/postgrescluster.yaml:75-104	rapid-assessment/findings/security/cryptographic-security-assessment.

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
		encrypted by the backup tool			md
CRYPTO-004	CRYPTOGRAPHY	CRYPTO-004 (Low): alert.sh swaks –port 25 with no –tls; alert content sent plaintext SMTP	cryptography-worker	scripts/ops/alert.sh:20-31	rapid-assessment/findings/security/cryptographic-security-assessment.md
CRYPTO-005	CRYPTOGRAPHY	CRYPTO-005 (Low): AlertmanagerConfig email receiver sets requireTLS:false; alert email plaintext	cryptography-worker	chart/psa-moodle/templates/monitoring.yaml:157-178	rapid-assessment/findings/security/cryptographic-security-assessment.md
CRYPTO-006	CRYPTOGRAPHY	CRYPTO-006 (Informational): K8s Secrets only base64-encoded; encryption-at-rest delegated to cluster etcd config	cryptography-worker	chart/psa-moodle/templates/secret-moodle.yaml:17-28	rapid-assessment/findings/security/cryptographic-security-assessment.md
DEP-001	DEPENDENCIES	DEP-001 (High): Moodle HVP plugin cloned from unpinned floating ‘master’ branch into production image	dependencies-worker	Containerfile.php:28-31	rapid-assessment/findings/dependencies/dependency-inventory.md
DEP-002	DEPENDENCI	DEP-002 (High): Five	dependencies-worker	Containerfile.php:33-45	rapid-assessment

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
	ES	plugin/theme repos cloned with no –branch flag (track default branch), no pin			/findings/dependencies/dependency-inventory.md
DEP-003	DEPENDENCIES	DEP-003 (Medium): docker-php-extension-installer fetched via floating latest-release URL, no checksum	dependencies-worker	Containerfile.php:71-74	rapid-assessment/findings/dependencies/dependency-inventory.md
DEP-004	DEPENDENCIES	DEP-004 (Medium): php-fpm-healthcheck fetched from unpinned master branch, no checksum	dependencies-worker	Containerfile.php:91-93	rapid-assessment/findings/dependencies/dependency-inventory.md
DEP-005	DEPENDENCIES	DEP-005 (Low): Moodle core cloned from floating MOODLE_405_STABLE branch, not an immutable tag/SHA	dependencies-worker	Containerfile.php:13-26	rapid-assessment/findings/dependencies/dependency-inventory.md
DEP-006	DEPENDENCIES	DEP-006 (Medium): PHP 8.3 base image approaching end of active support (EOL ~2026-11)	dependencies-worker	Containerfile.php:58	rapid-assessment/findings/dependencies/dependency-inventory.m

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
DEP-007	DEPENDENCIES	DEP-007 (Low): nginx base image pinned to floating 1.27-alpine tag, not a digest	dependencies-worker	Containerfile.web:11	rapid-assessment/findings/dependencies/dependency-inventory.md
DEP-008	DEPENDENCIES	DEP-008 (Medium): Alpine 3.20 ops base image approaching end of support	dependencies-worker	Containerfile.ops:11	rapid-assessment/findings/dependencies/dependency-inventory.md
DEP-009	DEPENDENCIES	DEP-009 (Medium): oc CLI and swaks downloaded via curl with no checksum/signature before execution	dependencies-worker	Containerfile.ops:20-26	rapid-assessment/findings/dependencies/dependency-inventory.md
DEP-010	DEPENDENCIES	DEP-010 (Low): PostgresCluster pins only major version 15; operator/patch level not recorded in-repo	dependencies-worker	chart/psa-moodle/templates/postgrescluster.yaml:17-19	rapid-assessment/findings/dependencies/dependency-inventory.md
DEP-011	DEPENDENCIES	DEP-011 (Low): Valkey image pinned to floating 7.2-alpine tag, not	dependencies-worker	chart/psa-moodle/values.yaml:87-90	rapid-assessment/findings/dependencies/dependency

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
		a digest			-inventory.md
DEP-012	DEPENDENCIES	DEP-012 (Low): compose.registry.yaml falls back to mutable dev-local tag when $TAG unset (local-dev only)	dependencies-worker	compose.registry.yaml:12-16	rapid-assessment/findings/dependencies/dependency-inventory.md
DEP-013	DEPENDENCIES	DEP-013 (Low): PHP CLI base image pinned to floating 8.3-cli-bookworm tag, not a digest	dependencies-worker	Containerfile.cron:12	rapid-assessment/findings/dependencies/dependency-inventory.md
SECRET-001	SECRETS	SECRET-001 (Low): Hardcoded ‘moodle’/‘moodle’ DB credential fallback in local-dev PHP config	secrets-worker	config/moodle/config.local.php:15-16	rapid-assessment/findings/security/secrets-analysis.md
SECRET-002	SECRETS	SECRET-002 (Low): Hardcoded ‘moodle’ Postgres password in local Podman Compose stack (host port 5433	secrets-worker	compose.yaml:12-17	rapid-assessment/findings/security/secrets-analysis.md

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
		published)			
LOG-001	SECURITY_LOGGING	LOG-001 (Medium): Cron loop never alerts on non-zero rc; scheduled-task failures can go undetected	security-logging-worker	chart/psa-moodle/templates/cron-deployment.yaml:54-61	rapid-assessment/findings/security/security-logging-analysis.md
LOG-002	SECURITY_LOGGING	LOG-002 (Medium): Moodle admin password passed as install_database.php –adminpass CLI arg (visible via /proc, auditd) *(corrected from High during reverse-validation)*	security-logging-worker	chart/psa-moodle/templates/job-install.yaml:69-75	rapid-assessment/findings/security/security-logging-analysis.md
LOG-003	SECURITY_LOGGING	LOG-003 (Medium): alert.sh sends audit-log tail over unencrypted, unauthenticated SMTP port 25	security-logging-worker	scripts/ops/alert.sh:25-32	rapid-assessment/findings/security/security-logging-analysis.md
LOG-004	SECURITY_LOGGING	LOG-004 (Medium): AlertmanagerConfig requireTLS:false; platform alerts delivered	security-logging-worker	chart/psa-moodle/templates/monitoring.yaml:173-179	rapid-assessment/findings/security/security-logging-analysis.md

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
		plaintext/unauthenticated			
LOG-005	SECURITY_LOGGING	LOG-005 (Low): MOODLE_DEBUG=1 enables debugsmtp (full SMTP transcript incl reset tokens); default in local compose	security-logging-worker	config/moodle/config.local.php:48-55	rapid-assessment/findings/security/security-logging-analysis.md
LOG-006	SECURITY_LOGGING	LOG-006 (Low): PHP-FPM access.log = /dev/null disables FastCGI-layer per-request access log	security-logging-worker	config/php/php-fpm.conf:27	rapid-assessment/findings/security/security-logging-analysis.md
LOG-007	SECURITY_LOGGING	LOG-007 (Low): restore-rehearsal.sh EXIT trap never removes mktemp LOGFILE (unlike backup-integrity.sh)	security-logging-worker	scripts/ops/restore-rehearsal.sh:47	rapid-assessment/findings/security/security-logging-analysis.md
TEST-001	TESTING	TEST-001 (High): No automated authn/authz/input-handling tests for config layer; only a single smoke test	testing-worker	.github/workflows/deploy.yml:152-165	rapid-assessment/findings/testing/testing-analysis.md

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
TEST-002	TESTING	TEST-002 (Medium): No SAST, SCA, secret-scan, or image-scan gate in any CI workflow before image push	testing-worker	.github/workflows/build.yml:1-33	rapid-assessment/findings/testing/testing-analysis.md
TEST-003	TESTING	TEST-003 (Low): values-poc.yaml never helm-lint/template tested in CI	testing-worker	.github/workflows/lint.yml:26-31	rapid-assessment/findings/testing/testing-analysis.md
TEST-004	TESTING	TEST-004 (Low): moodledata snapshot has no restore-verification step (unlike Postgres restore-rehearsal)	testing-worker	scripts/ops/moodledata-snapshot.sh:1-28	rapid-assessment/findings/testing/testing-analysis.md
TEST-005	TESTING	TEST-005 (Low): Post-install Job has no independent schema/admin verification after install_database.php	testing-worker	chart/psa-moodle/templates/job-install.yaml:1-69	rapid-assessment/findings/testing/testing-analysis.md
TEST-006	TESTING	TEST-006 (Low): Local Compose stack never built/started in	testing-worker	compose.yaml:1-12	rapid-assessment/findings/testing/testing-analysis.md

Claim ID	Domain	Claim Summary	Source Worker	Evidence Citation	Output File
		CI (only yamllint syntax check)			
TEST-007	TESTING	TEST-007 (Low): 12 NetworkPolicy resources have no automated connectivity/policy-simulation test	testing-worker	chart/psa-moodle/templates/networkpolicy.yaml:19	rapid-assessment/findings/testing/testing-analysis.md

*The `finding-chaining` stage is recorded as **Partial** (0 chains emitted, 8 rejected candidates). Its rejected candidates CAND-0001/0002/0003 reference the claims above (AUTHZ-001/002/003, DEP-009, DEP-001/002, TEST-002, VULN-001, AUTHZ-005, CONFIG-006) and are described in the Finding Chains section; they add no new claims.*

0.10 Worker Completion Status

Worker	Status
architecture	Complete
authentication	Complete
authorization	Complete
code-vulnerabilities	Complete
configuration	Complete
cryptography	Complete
dependencies	Complete
secrets	Complete
security-logging	Complete
testing	Complete
business-workflow	Complete
finding-chaining	Partial (0 chains, 8 rejected candidates)
zero-trust-governance	Complete
dependency-reachability	Not in scope (skipped — no VULNERABLE_DEPENDENCY findings)
github-dependency	Not in scope (skipped — githubMcp=false)
github-code-security	Not in scope (skipped — githubMcp=false)

Worker	Status
github-secret-scanning	Not in scope (skipped — githubMcp=false)

0.11 Zero Trust Governance

An independent Zero Trust governance mapping covering all Critical, High, and Medium findings (0 / 8 / 18 = 26 mapped) is provided in rapid-assessment/findings/summary/zero-trust-governance.md and in `data.zeroTrustMapping` of rapid-assessment/data/synthesis.json. Principle distribution: LEAST_PRIVILEGE 8, ASSUME_BREACH 13, VERIFY_EXPLICITLY 5. Pillar distribution: INFRASTRUCTURE 8, APPLICATIONS 7, IDENTITY 6, DATA 2, NETWORK 3.

---

1 System Architecture Diagram

1.1 Introduction

`psa-moodle` is an **infrastructure and deployment repository**, not an application source tree. It defines how the upstream open-source Moodle 4.5 LMS (cloned from `moodle/moodle` at build time — Containerfile.php) is packaged into container images and deployed onto BC Gov's OpenShift Silver cluster (namespace `a58ce1-*`). Moodle's own PHP source code is never vendored into this repository; it is pulled fresh at image-build time, along with a fixed set of first-party and third-party plugins/theme (`block_course_search`, `local_githubsync`, `local_psaelmsync`, `mod_pathcurator`, `mod_hvp`, `theme_bcgovpsa`).

The repository's actual content is: a Helm chart (chart/psa-moodle/) that declares the full OpenShift topology (Deployments, a StatefulSet, CronJobs, a PostgresCluster custom resource, NetworkPolicy, Route, RBAC, Secrets, HPA, PDB), four Containerfiles that build the runtime images (`web`, `php`, `cron`, `ops`), a small set of baked-in configuration files (nginx, PHP-FPM, php.ini, Valkey, Moodle `config.php` variants), a Podman Compose stack for local development, GitHub Actions workflows for CI/CD, and a set of ops shell scripts for backup integrity, moodledata snapshots, and restore rehearsals.

Architecturally, one application codebase (Moodle) is split across three distinct **runtime roles** — a stateless nginx front (`web`), a stateless PHP-FPM application tier (`php`), and a scheduled-task runner (`cron`) — all built from the same PHP source via multi-stage `COPY --from=` image layering, so the three containers can never drift in code version. Two stateful backing services are managed by Kubernetes operators/controllers rather than hand-rolled: **Crunchy PostgreSQL for Kubernetes** (replacing a legacy MariaDB Galera cluster) and a single-replica **Valkey** (Redis-compatible cache/session store, replacing a legacy custom Redis Sentinel proxy). A fourth, purely operational container image (`ops`) runs scheduled backup-integrity checks, moodledata VolumeSnapshots, and weekly restore rehearsals against a temporary cloned PostgresCluster — a direct structural response to

an April 2026 silent-backup-corruption incident referenced throughout the chart's comments.

1.2 Component Inventory Table

Display Name	Slug	Description	Primary Files
Web Container (nginx)	`web-container`	Immutable nginx front-end serving static assets and proxying to PHP-FPM over FastCGI	`Containerfile.web`, `config/nginx/default.conf`, `chart/psa-moodle/templates/web-deployment.yaml`, `chart/psa-moodle/templates/web-service.yaml`
PHP-FPM Application Container	`php-fpm-application`	Runs the Moodle 4.5 application code and all baked-in plugins/theme under PHP-FPM	`Containerfile.php`, `config/php/php.ini`, `config/php/php-fpm.conf`, `config/moodle/config.local.php`, `config/moodle/config.openshift.php`, `chart/psa-moodle/templates/php-deployment.yaml`, `chart/psa-moodle/templates/php-service.yaml`
Cron Workload	`cron-workload`	Executes Moodle's scheduled-task runner (`admin/cli/cron.php`)	`Containerfile.cron`, `chart/psa-moodle/templates/cron-deployment.yaml`, `chart/psa-moodle/templates/cron-cronjob.yaml`
Install Job	`install-job`	One-shot Helm post-install hook that bootstraps the Moodle database	`chart/psa-moodle/templates/job-install.yaml`, `chart/psa-moodle/templates/secret-moodle.yaml`
PostgreSQL Cluster (Crunchy	`postgresql-cluster`	Operator-managed relational datastore	`chart/psa-moodle/templates/postgrescluster.yam`

Display Name	Slug	Description	Primary Files
PostgreSQL Operator)		with pgBackRest backups	l, chart/psa-moodle/templates/postgres-init-configmap.yaml
Valkey Cache	valkey-cache	Single-replica session/cache store (Redis-compatible)	chart/psa-moodle/templates/valkey-statefulset.yaml, chart/psa-moodle/templates/valkey-service.yaml, chart/psa-moodle/templates/valkey-configmap.yaml, chart/psa-moodle/templates/secret-valkey.yaml, config/valkey/valkey.conf
Moodledata Shared Storage	moodledata-storage	ReadWriteMany PVC shared by php and cron for uploaded content	chart/psa-moodle/templates/moodledata-pvc.yaml
Ops Tooling	ops-tooling	Backup-integrity, moodledata-snapshot, and restore-rehearsal CronJobs plus alerting	Containerfile.ops, scripts/ops/alert.sh, scripts/ops/backup-integrity.sh, scripts/ops/moodledata-snapshot.sh, scripts/ops/moodledata-snapshot-prune.sh, scripts/ops/restore-rehearsal.sh, chart/psa-moodle/templates/rbac-ops.yaml, chart/psa-moodle/templates/cronjob-backup-integrity.yaml, chart/psa-

Display Name	Slug	Description	Primary Files
			moodle/templates/cronjob-moodledata-snapshot.yaml, chart/psa-moodle/templates/cronjob-restore-rehearsal.yaml
NetworkPolicy Boundary	network-policy	Default-deny ingress/egress NetworkPolicy set with explicit allowlist	chart/psa-moodle/templates/networkpolicy.yaml
OpenShift Route	openshift-route	TLS-edge-terminated ingress exposing the Web Container	chart/psa-moodle/templates/route.yaml
Helm Chart / Deployment Topology	helm-chart-topology	Chart scaffolding and per-environment values driving the whole deployment	chart/psa-moodle/Chart.yaml, chart/psa-moodle/values.yaml, chart/psa-moodle/values-dev.yaml, chart/psa-moodle/values-poc.yaml, chart/psa-moodle/values-test.yaml, chart/psa-moodle/templates/_helpers.tpl, chart/psa-moodle/templates/NOTES.txt, chart/psa-moodle/templates/hpa.yaml, chart/psa-moodle/templates/poddisruptionbudget.yaml
Monitoring and Observability	monitoring-observability	OpenShift user-workload-monitoring wiring for Postgres and PHP-FPM	chart/psa-moodle/templates/monitoring.yaml

Display Name	Slug	Description	Primary Files
		exporters	
CI/CD Pipeline	`cicd-pipeline`	GitHub Actions workflows and Makefile driving builds/lint/deploy	`.github/workflows/build.yml`, `.github/workflows/deploy.yml`, `.github/workflows/lint.yml`, `.github/workflows/scheduled-rebuild.yml`, `Makefile`, `.gitignore`
Local Dev Compose Stack	`local-dev-compose`	Podman Compose stack reproducing the topology for local development	`compose.yaml`, `compose.registry.yaml`
Documentation & Runbooks	`documentation-runbooks`	Project documentation, phase write-ups, and operational runbooks	`README.md`, `docs/*.md`

1.3 Components & Integrations

1.3.1 Core Components

- **Web Container (nginx)** — `nginxinc/nginx-unprivileged:1.27-alpine` serving static assets and proxying PHP requests to the PHP-FPM tier over FastCGI. Immutable; code is copied from the PHP image at build time, never mounted live.
- **PHP-FPM Application Container** — `php:8.3-fpm-bookworm` running the actual Moodle application code (`admin/`, `mod/`, `blocks/`, `theme/`, etc.) plus the baked `config.php` variant.
- **Cron Workload** — `php:8.3-cli-bookworm` running `admin/cli/cron.php` on a schedule (Kubernetes Deployment loop by default, optional isolated-pod CronJob mode).
- **Install Job** — one-shot Helm post-install hook running `admin/cli/install_database.php` against the fresh PostgresCluster.

1.3.2 Standalone Services

- **PostgreSQL Cluster (Crunchy PostgreSQL Operator)** — a `PostgresCluster` custom resource; the operator manages HA, pgBackRest backups, credential rotation, and exposes a generated `<cluster>-pguser-<user>` Secret consumed by php/cron/install.

- **Valkey Cache** — single-replica `StatefulSet` (Linux Foundation Redis fork) used for Moodle session storage (`\core\session\redis`) and application caching, protected by a generated AUTH password.
- **Moodledata Shared Storage** — a single ReadWriteMany PVC mounted by both the PHP and cron containers; the only shared filesystem in the architecture (the legacy shared-code RWX volume was deliberately not reproduced).
- **Ops Tooling** — an Alpine-based image (`oc`, `swaks`, `psql`, `jq`) running three scheduled CronJobs (backup-integrity, moodledata-snapshot, restore-rehearsal) plus an alerting script, under a dedicated RBAC ServiceAccount.

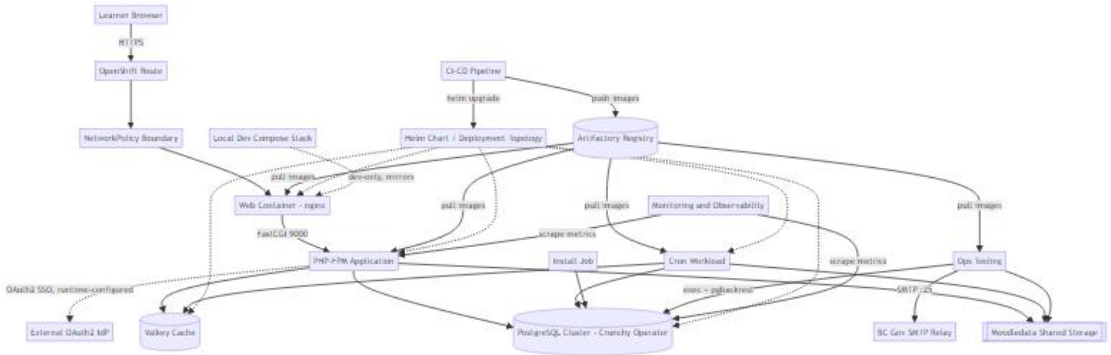
1.3.3 External Integrations

- **BC Gov unauthenticated SMTP relay** (`apps.smtp.gov.bc.ca:25`) — used by scripts/ops/alert.sh to email backup/restore failures and successes.
- **Artifactory container registry** (`artifacts.developer.gov.bc.ca/a58ce1-tools/psa-moodle`) — pulls the four built images via an `artifactory-pull` image-pull Secret (chart/psa-moodle/values.yaml).
- **Upstream GitHub source repositories** — Moodle core and five plugin/theme repositories are `git clone`d at image-build time (Containerfile.php).
- **OAuth2 Identity Provider (SSO)** — referenced in README.md as configured at runtime through Moodle core's built-in `auth_oauth2/admin/tool/oauth2` support; no OIDC plugin code or IdP endpoint is present in this repository, so no static evidence file exists for this integration.

1.3.4 Database Schema Overview

No application-level schema (migrations, ORM entities) is vendored in this repository — Moodle's `mdl_*` table schema is created entirely by the upstream `install_database.php` installer at runtime, from source that is cloned (not committed) at build time. The only SQL present in-repo is a bootstrap grant/ownership statement for PostgreSQL 15's default schema-permission change, in chart/psa-moodle/templates/postgres-init-configmap.yaml.

1.4 Architecture Diagram



1.5 File-to-Component Mapping Table

File Path	Component (Display Name)	Role
README.md	Documentation & Runbooks	Repository README, architecture overview
.gitignore	CI/CD Pipeline	Repo hygiene (excludes `moodledata/` local bind mount)
Makefile	CI/CD Pipeline	Canonical dev/build/deploy entrypoints
Containerfile.php	PHP-FPM Application Container	Multi-stage build: clones Moodle + plugins, builds PHP-FPM runtime
Containerfile.ops	Ops Tooling	Builds the ops image (`oc`, `swaks`, scripts)
Containerfile.cron	Cron Workload	Builds the PHP-CLI cron runtime
Containerfile.web	Web Container (nginx)	Builds the nginx runtime, copies code from the php image
compose.yaml	Local Dev Compose Stack	Podman Compose service definitions (db, cache, php, web, cron)
compose.registry.yaml	Local Dev Compose Stack	Compose override for registry-sourced images
config/moodle/config.local.php	PHP-FPM Application Container	Moodle `config.php` variant for local Compose dev
config/moodle/config.openshift.php	PHP-FPM Application Container	Moodle `config.php` variant for OpenShift/Helm deploy
config/nginx/default.conf	Web Container (nginx)	nginx server block, FastCGI proxy, deny-rules, XFF handling
config/php/php.ini	PHP-FPM Application Container	PHP tuning overlay
config/php/php-fpm.conf	PHP-FPM Application Container	FPM pool configuration
config/valkey/valkey.conf	Valkey Cache	Valkey server configuration
chart/psa-moodle/Chart.yaml	Helm Chart / Deployment Topology	Chart metadata
chart/psa-	Helm Chart / Deployment	Default chart values

File Path	Component (Display Name)	Role
moodle/values.yaml	Topology	
chart/psa-moodle/values-dev.yaml	Helm Chart / Deployment Topology	Dev environment overrides
chart/psa-moodle/values-poc.yaml	Helm Chart / Deployment Topology	POC environment overrides
chart/psa-moodle/values-test.yaml	Helm Chart / Deployment Topology	Test environment overrides
chart/psa-moodle/templates/_helpers.tpl	Helm Chart / Deployment Topology	Shared template helpers (labels, image refs, names)
chart/psa-moodle/templates/NOTES.txt	Helm Chart / Deployment Topology	Post-install usage notes
chart/psa-moodle/templates/web-deployment.yaml	Web Container (nginx)	Web Deployment manifest
chart/psa-moodle/templates/web-service.yaml	Web Container (nginx)	Web Service manifest
chart/psa-moodle/templates/php-deployment.yaml	PHP-FPM Application Container	PHP Deployment manifest
chart/psa-moodle/templates/php-service.yaml	PHP-FPM Application Container	PHP Service manifest
chart/psa-moodle/templates/cron-deployment.yaml	Cron Workload	Cron Deployment-loop manifest (default mode)
chart/psa-moodle/templates/cron-cronjob.yaml	Cron Workload	Cron CronJob manifest (fallback mode)
chart/psa-moodle/templates/postgres-cluster.yaml	PostgreSQL Cluster (Crunchy PostgreSQL Operator)	`PostgresCluster` custom resource
chart/psa-moodle/templates/postgres-init-configmap.yaml	PostgreSQL Cluster (Crunchy PostgreSQL Operator)	Bootstrap schema-ownership SQL
chart/psa-moodle/templates/valkey-	Valkey Cache	Valkey StatefulSet manifest

File Path	Component (Display Name)	Role
statefulset.yaml		
chart/psa-moodle/templates/valkey-service.yaml	Valkey Cache	Valkey headless Service manifest
chart/psa-moodle/templates/valkey-configmap.yaml	Valkey Cache	Valkey ConfigMap (mounted `valkey.conf`)
chart/psa-moodle/templates/secret-moodle.yaml	Install Job	Generated Moodle admin credentials Secret
chart/psa-moodle/templates/secret-valkey.yaml	Valkey Cache	Generated Valkey AUTH password Secret
chart/psa-moodle/templates/moodledata-pvc.yaml	Moodledata Shared Storage	RWX PersistentVolumeClaim manifest
chart/psa-moodle/templates/job-install.yaml	Install Job	Post-install DB bootstrap Job
chart/psa-moodle/templates/hpa.yaml	Helm Chart / Deployment Topology	HorizontalPodAutoscalers for web/php
chart/psa-moodle/templates/poddisruptionbudget.yaml	Helm Chart / Deployment Topology	PodDisruptionBudgets for web/php
chart/psa-moodle/templates/route.yaml	OpenShift Route	OpenShift Route manifest
chart/psa-moodle/templates/networkpolicy.yaml	NetworkPolicy Boundary	Default-deny + allowlist NetworkPolicy set
chart/psa-moodle/templates/rbac-ops.yaml	Ops Tooling	ServiceAccount, Role, RoleBinding for ops CronJobs
chart/psa-moodle/templates/monitoring.yaml	Monitoring and Observability	NetworkPolicy, PodMonitor, ServiceMonitor, PrometheusRule, AlertmanagerConfig
chart/psa-	Ops Tooling	Daily backup-integrity

File Path	Component (Display Name)	Role
moodle/templates/cronjob-backup-integrity.yaml		CronJob
chart/psa-moodle/templates/cronjob-moodledata-snapshot.yaml	Ops Tooling	Daily moodledata VolumeSnapshot CronJob + prune
chart/psa-moodle/templates/cronjob-restore-rehearsal.yaml	Ops Tooling	Weekly restore-rehearsal CronJob
.github/workflows/build.yml	CI/CD Pipeline	Builds and pushes container images
.github/workflows/deploy.yml	CI/CD Pipeline	Helm deploy to dev/test
.github/workflows/lint.yml	CI/CD Pipeline	Lint pipeline
.github/workflows/scheduled-rebuild.yml	CI/CD Pipeline	Scheduled rebuild trigger
scripts/ops/alert.sh	Ops Tooling	Sends alert emails via BC Gov SMTP relay
scripts/ops/backup-integrity.sh	Ops Tooling	Verifies pgBackRest repo state + canonical table content
scripts/ops/moodledata-snapshot.sh	Ops Tooling	Creates a VolumeSnapshot of moodledata
scripts/ops/moodledata-snapshot-prune.sh	Ops Tooling	Prunes old moodledata VolumeSnapshots
scripts/ops/restore-rehearsal.sh	Ops Tooling	Provisions temp PostgresCluster clone and smoke-tests restore
docs/quota-request.md	Documentation & Runbooks	Namespace quota request documentation
docs/poc-quota-request.md	Documentation & Runbooks	POC-phase quota request documentation
docs/poc-deploy-runbook.md	Documentation & Runbooks	POC deployment runbook
docs/phase2-images.md	Documentation & Runbooks	Phase 2 image-build documentation
docs/phase3-deploy.md	Documentation & Runbooks	Phase 3 Helm deploy documentation
docs/phase4-hardening.md	Documentation & Runbooks	Phase 4 operational

File Path	Component (Display Name)	Role
		hardening documentation
docs/phase5-cicd.md	Documentation & Runbooks	Phase 5 CI/CD documentation
docs/phase6-backups.md	Documentation & Runbooks	Phase 6 backup/DR documentation
docs/next-steps.md	Documentation & Runbooks	Outstanding work tracking
docs/namespace-handover.md	Documentation & Runbooks	Namespace handover documentation
docs/discovery-inventory.md	Documentation & Runbooks	Discovery-phase inventory documentation
docs/legacy-comparison.md	Documentation & Runbooks	Comparison against legacy `bcgov/moodle-nginx`
docs/bcgov-alignment-review.md	Documentation & Runbooks	BC Gov platform alignment review

1.6 System Components

1.6.1 Web Container (nginx)

- **Description**: Immutable nginx front-end that serves static assets and proxies dynamic requests to PHP-FPM over FastCGI; the sole ingress-facing workload.
- **Location**: `Containerfile.web`, `config/nginx/default.conf`, `chart/psa-moodle/templates/web-deployment.yaml`, `chart/psa-moodle/templates/web-service.yaml`
- **Main Files**: `Containerfile.web`, `config/nginx/default.conf`
- **Technologies**: nginx-unprivileged 1.27 (Alpine)
- **Purpose**: TLS-terminated (upstream at the Route) HTTP entry point; enforces Moodle's recommended deny-rules for dotfiles/vendor directories; recovers real client IP via `X-Forwarded-For` for audit logging.
- **Dependencies**: PHP-FPM Application Container (FastCGI upstream); OpenShift Route (ingress); NetworkPolicy (restricts who may reach it)

1.6.2 PHP-FPM Application Container

- **Description**: Runs the actual Moodle 4.5 application code and all baked-in plugins/theme under PHP-FPM.
- **Location**: `Containerfile.php`, `config/php/php.ini`, `config/php/php-fpm.conf`, `config/moodle/config.local.php`, `config/moodle/config.openshift.php`, `chart/psa-moodle/templates/php-deployment.yaml`, `chart/psa-moodle/templates/php-service.yaml`
- **Main Files**: `Containerfile.php`, `config/moodle/config.openshift.php`
- **Technologies**: PHP 8.3-FPM (Debian bookworm), Moodle 4.5 (`MOODLE_405_STABLE`)

- **Purpose**: Executes all Moodle business logic; connects to Postgres (`pdo_pgsql`), Valkey (`redis` extension, session handler), and the shared `moodledata` PVC.
- **Dependencies**: PostgreSQL Cluster, Valkey Cache, Moodledata Shared Storage, Web Container (upstream caller)

1.6.3 Cron Workload

- **Description**: Executes Moodle's scheduled-task runner (`admin/cli/cron.php`) — Deployment-loop mode by default, CronJob mode available as a fallback.
- **Location**: `Containerfile.cron`, `chart/psa-moodle/templates/cron-deployment.yaml`, `chart/psa-moodle/templates/cron-cronjob.yaml`
- **Main Files**: `Containerfile.cron`, `chart/psa-moodle/templates/cron-cronjob.yaml`
- **Technologies**: PHP 8.3-CLI (Debian bookworm)
- **Purpose**: Runs Moodle's adhoc/scheduled task queue (`mdl_task_adhoc`, `mdl_task_scheduled`).
- **Dependencies**: PostgreSQL Cluster, Valkey Cache, Moodledata Shared Storage

1.6.4 Install Job

- **Description**: One-shot Helm post-install hook Job that bootstraps the Moodle database on first deploy only.
- **Location**: `chart/psa-moodle/templates/job-install.yaml`, `chart/psa-moodle/templates/secret-moodle.yaml`
- **Main Files**: `chart/psa-moodle/templates/job-install.yaml`
- **Technologies**: PHP CLI (cron image reused), Helm hooks
- **Purpose**: Waits for the Crunchy primary to accept connections, then runs `admin/cli/install_database.php` with generated admin credentials.
- **Dependencies**: PostgreSQL Cluster

1.6.5 PostgreSQL Cluster (Crunchy PostgreSQL Operator)

- **Description**: Operator-managed `PostgresCluster` custom resource providing the primary relational datastore.
- **Location**: `chart/psa-moodle/templates/postgrescluster.yaml`, `chart/psa-moodle/templates/postgres-init-configmap.yaml`
- **Main Files**: `chart/psa-moodle/templates/postgrescluster.yaml`
- **Technologies**: Crunchy PostgreSQL for Kubernetes, PostgreSQL 15, pgBackRest
- **Purpose**: Stores all Moodle relational data; handles HA, credential rotation via a generated `pguser` Secret, and in-cluster pgBackRest backups.
- **Dependencies**: None (backing service); consumed by PHP-FPM, Cron, Install Job, Ops Tooling

1.6.6 Valkey Cache

- **Description**: Single-replica StatefulSet providing Moodle's session store and general-purpose cache.
- **Location**: `chart/psa-moodle/templates/valkey-statefulset.yaml`, `chart/psa-moodle/templates/valkey-service.yaml`, `chart/psa-moodle/templates/valkey-configmap.yaml`, `chart/psa-moodle/templates/secret-valkey.yaml`, `config/valkey/valkey.conf`
- **Main Files**: `chart/psa-moodle/templates/valkey-statefulset.yaml`, `config/valkey/valkey.conf`
- **Technologies**: Valkey 7.2 (Redis-compatible, Linux Foundation)
- **Purpose**: Backs `\core\session\redis` session handling and Moodle caching; protected by AUTH (`requirepass`), preserved stable across upgrades via a Helm `lookup` trick.
- **Dependencies**: None (backing service); consumed by PHP-FPM, Cron

1.6.7 Moodledata Shared Storage

- **Description**: The single ReadWriteMany PersistentVolumeClaim shared by the PHP and cron containers.
- **Location**: `chart/psa-moodle/templates/moodledata-pvc.yaml`
- **Main Files**: `chart/psa-moodle/templates/moodledata-pvc.yaml`
- **Technologies**: OpenShift/Kubernetes PVC (`netapp-file-standard` storage class)
- **Purpose**: Stores Moodle's `dataroot` (uploaded files, filedir, session-adjacent artifacts); the sole shared filesystem in the architecture.
- **Dependencies**: None (storage backing service); mounted by PHP-FPM and Cron

1.6.8 Ops Tooling

- **Description**: A dedicated Alpine-based operational image and three scheduled CronJobs implementing backup-integrity verification, moodledata snapshotting, and restore rehearsal.
- **Location**: `Containerfile.ops`, `scripts/ops/alert.sh`, `scripts/ops/backup-integrity.sh`, `scripts/ops/moodledata-snapshot.sh`, `scripts/ops/moodledata-snapshot-prune.sh`, `scripts/ops/restore-rehearsal.sh`, `chart/psa-moodle/templates/rbac-ops.yaml`, `chart/psa-moodle/templates/cronjob-backup-integrity.yaml`, `chart/psa-moodle/templates/cronjob-moodledata-snapshot.yaml`, `chart/psa-moodle/templates/cronjob-restore-rehearsal.yaml`
- **Main Files**: `scripts/ops/backup-integrity.sh`, `chart/psa-moodle/templates/rbac-ops.yaml`
- **Technologies**: Alpine 3.20, `oc` CLI, `swaks` SMTP client, `psql`, `jq`, bash
- **Purpose**: Verifies pgBackRest repo state and canonical-table content daily, snapshots `moodledata` daily, rehearses a full restore weekly, and emails failures/successes via the BC Gov SMTP relay.

- **Dependencies**: PostgreSQL Cluster (exec + pgBackRest), Moodledata Shared Storage (VolumeSnapshot), BC Gov SMTP relay (external integration)

1.6.9 NetworkPolicy Boundary

- **Description**: Default-deny ingress/egress NetworkPolicy set with an explicit allowlist scoped to this Helm release's pods.
- **Location**: `chart/psa-moodle/templates/networkpolicy.yaml`
- **Main Files**: `chart/psa-moodle/templates/networkpolicy.yaml`
- **Technologies**: Kubernetes `NetworkPolicy` (networking.k8s.io/v1)
- **Purpose**: Enforces router→web, web→php, app→valkey, app→postgres allow rules, plus egress allows for OAuth2 SSO, plugin runtime egress, and the SMTP alert mailer.
- **Dependencies**: All in-cluster components (cross-cutting security control)

1.6.10 OpenShift Route

- **Description**: The OpenShift `Route` object exposing the Web Container to the internet/router.
- **Location**: `chart/psa-moodle/templates/route.yaml`
- **Main Files**: `chart/psa-moodle/templates/route.yaml`
- **Technologies**: OpenShift `route.openshift.io/v1`
- **Purpose**: TLS-edge-terminated ingress with a raised HAProxy timeout, fixing a previously-silent restore-failure mode caused by a router timeout shorter than nginx's FastCGI timeout.
- **Dependencies**: Web Container (target Service)

1.6.11 Helm Chart / Deployment Topology

- **Description**: The Helm chart scaffolding and per-environment values that declare the full OpenShift topology.
- **Location**: `chart/psa-moodle/Chart.yaml`, `chart/psa-moodle/values.yaml`, `chart/psa-moodle/values-dev.yaml`, `chart/psa-moodle/values-poc.yaml`, `chart/psa-moodle/values-test.yaml`, `chart/psa-moodle/templates/_helpers.tpl`, `chart/psa-moodle/templates/NOTES.txt`, `chart/psa-moodle/templates/hpa.yaml`, `chart/psa-moodle/templates/poddisruptionbudget.yaml`
- **Main Files**: `chart/psa-moodle/values.yaml`, `chart/psa-moodle/templates/_helpers.tpl`
- **Technologies**: Helm 3, Go templates
- **Purpose**: Central configuration surface (image tags, replica counts, resource limits, HPA/PDB toggles, feature flags) driving every other template in the chart.
- **Dependencies**: Every deployable component in this inventory

1.6.12 Monitoring and Observability

- **Description**: OpenShift user-workload-monitoring wiring (NetworkPolicy allow, PodMonitor, ServiceMonitor, PrometheusRule, AlertmanagerConfig).
- **Location**: `chart/psa-moodle/templates/monitoring.yaml`
- **Main Files**: `chart/psa-moodle/templates/monitoring.yaml`
- **Technologies**: Prometheus Operator CRDs (PodMonitor/ServiceMonitor/PrometheusRule), Thanos (via OpenShift user-workload-monitoring)
- **Purpose**: Scrapes the Crunchy Postgres exporter (9187) and PHP-FPM exporter (9253); alerts routed via AlertmanagerConfig.
- **Dependencies**: PostgreSQL Cluster, PHP-FPM Application Container

1.6.13 CI/CD Pipeline

- **Description**: GitHub Actions workflows plus the `Makefile` driving image builds, linting, deployment, and scheduled rebuilds.
- **Location**: `.github/workflows/build.yml`, `.github/workflows/deploy.yml`, `.github/workflows/lint.yml`, `.github/workflows/scheduled-rebuild.yml`, `Makefile`, `.gitignore`
- **Main Files**: `.github/workflows/build.yml`, `.github/workflows/deploy.yml`, `Makefile`
- **Technologies**: GitHub Actions, Podman, Helm
- **Purpose**: Builds and pushes the four container images to Artifactory on `main`, then deploys via Helm to `a58ce1-dev` automatically and `a58ce1-test` on manual promotion.
- **Dependencies**: Artifactory registry, Helm Chart / Deployment Topology

1.6.14 Local Dev Compose Stack

- **Description**: Podman Compose stack reproducing the same five logical services (db, cache, php, web, cron) for local iteration.
- **Location**: `compose.yaml`, `compose.registry.yaml`
- **Main Files**: `compose.yaml`
- **Technologies**: Podman Compose, Postgres 15-alpine, Valkey 7.2-alpine
- **Purpose**: Local-only development/test loop; not deployed to OpenShift.
- **Dependencies**: None (standalone dev environment, mirrors production topology)

1.6.15 Documentation & Runbooks

- **Description**: Project documentation, phase write-ups, and operational runbooks.
- **Location**: `README.md`, `docs/*.md`
- **Main Files**: `README.md`, `docs/phase6-backups.md`, `docs/bcgov-alignment-review.md`

- **Technologies**: Markdown
- **Purpose**: Records phase-by-phase delivery status, quota requests, namespace handover, and legacy-comparison rationale.
- **Dependencies**: None (documentation only, no runtime relevance)

1.7 Third-Party Integrations

1.7.1 BC Gov SMTP Relay

- **Service**: `apps.smtp.gov.bc.ca` (unauthenticated internal SMTP relay)
- **Purpose**: Delivers backup-integrity, snapshot, and restore-rehearsal alert/heartbeat emails
- **Integration Method**: `swaks` SMTP client invoked over plaintext port 25
- **Components Using This Integration**: Ops Tooling
- **Key Files**: `scripts/ops/alert.sh`

1.7.2 Artifactory Container Registry

- **Service**: `artifacts.developer.gov.bc.ca/a58ce1-tools/psa-moodle`
- **Purpose**: Hosts the four built container images (`web`, `php`, `cron`, `ops`) pulled by the cluster
- **Integration Method**: OCI image pull, authenticated via the `artifactory-pull` image-pull Secret
- **Components Using This Integration**: Web Container, PHP-FPM Application Container, Cron Workload, Ops Tooling, CI/CD Pipeline
- **Key Files**: `chart/psa-moodle/values.yaml`, `.github/workflows/build.yml`

1.7.3 Upstream GitHub Source Repositories

- **Service**: `moodle/moodle`, `h5p/moodle-mod_hvp`, `bcgov/moodle-course-search`, `PSA-Corporate-Learning-Branch/moodle-local_githubsync`, `PSA-Corporate-Learning-Branch/psaelmsync`, `itr8tech/pathcurator-moodle`, `bcgov/bcgovpsa-moodle`
- **Purpose**: Source of Moodle core, plugins, and the BC Gov PSA child theme, cloned fresh on every image build
- **Integration Method**: `git clone` over HTTPS at build time (no runtime dependency)
- **Components Using This Integration**: PHP-FPM Application Container (build stage)
- **Key Files**: `Containerfile.php`

1.7.4 OAuth2 Identity Provider (SSO)

- **Service**: Not named in-repo; configured at runtime via Moodle core's `admin/tool/oauth2`
- **Purpose**: Single sign-on authentication for learners/staff

- **Integration Method**: Moodle core `auth_oauth2` plugin (no code in this repository); NetworkPolicy egress allow for the IdP flow
- **Components Using This Integration**: PHP-FPM Application Container
- **Key Files**: `README.md` (mentioned only — no static configuration file for this integration exists in-repo)

1.8 Application Layer Mapping

Layer	Components	Primary Files / Packages	Notes
User Interface	Web Container (nginx)	`Containerfile.web`, `config/nginx/default.conf`, `chart/psa-moodle/templates/web-deployment.yaml`	Static asset serving + FastCGI reverse proxy; no server-rendered UI code lives in this repo (upstream Moodle)
Business Logic	PHP-FPM Application Container, Cron Workload, Install Job	`Containerfile.php`, `config/moodle/config.openshift.php`, `chart/psa-moodle/templates/cron-cronjob.yaml`, `chart/psa-moodle/templates/job-install.yaml`	Moodle application logic itself is upstream/cloned; this repo only owns runtime wiring and config
Data Access	PostgreSQL Cluster, Valkey Cache, Moodledata Shared Storage	`chart/psa-moodle/templates/postgrescluster.yaml`, `chart/psa-moodle/templates/valkey-statefulset.yaml`, `chart/psa-moodle/templates/moodledata-pvc.yaml`	Operator-managed relational store, cache/session store, and shared-file PVC
External	OpenShift Route	`chart/psa-moodle/templates/route.yaml`	Sole

Layer	Components	Primary Files / Packages	Notes
Integrations			declared ingress path; SMTP/OAuth2/registry integrations are documented under Ops Tooling / PHP-FPM / CI-CD instead since they are outbound, not inbound
Shared Infrastructure	NetworkPolicy Boundary, Ops Tooling, Helm Chart / Deployment Topology, Monitoring and Observability, CI/CD Pipeline, Local Dev Compose Stack	`chart/psa-moodle/templates/networkpolicy.yaml`, `scripts/ops/*.sh`, `chart/psa-moodle/values.yaml`, `chart/psa-moodle/templates/monitoring.yaml`, `.github/workflows/*.yml`, `compose.yaml`	Cross-cutting security, operational, deployment, and observability tooling not tied to a single request path
Unmapped / Shared	Documentation & Runbooks	—	Markdown-only project documentation; no runtime code or security boundary

1.9 Data Model Overview

No schema definition files found — data model cannot be documented. Schema files (.sql, migration files, ORM entity definitions) were not identified in the repository.

The only SQL statement present is a bootstrap `GRANT/ALTER SCHEMA OWNER` fix in `chart/psa-moodle/templates/postgres-init-configmap.yaml` (lines 16-18), which pre-authorizes the Moodle DB role to create objects — it is not a table-level schema definition. Moodle's actual `mdl_*` relational schema is created entirely by the upstream `admin/cli/install_database.php` installer at runtime, from source cloned (not vendored) at build time.

1.9.1 Core Data Entities

Not populated — no schema definition files were identified in this repository (see evidence gate above).

1.9.2 External Data Dependencies

External System	Data Exchanged	Direction (in / out / both)	Owner Component	Auth Method	Encryption in Transit	Evidence
BC Gov SMTP relay (`apps.smtp.gov.bc.ca`)	Alert email subject/body (backup/restore status, log tail)	out	ops-tooling	none (unauthenticated internal relay)	none (plaintext SMTP, port 25)	`scripts/ops/alert.sh` lines 1-25
Artifactory registry (`artifacts.developer.gov.bc.ca/a58ce1-tools/psa-moodle`)	Container images (web, php, cron, ops)	in	helm-chart-topology	image-pull Secret (`artifactory-pull`)	unknown (registry HTTPS assumed, not asserted in-repo)	`chart/psa-moodle/values.yaml` lines 8-18
Upstream GitHub repositories (Moodle core + 5	Application source code	in	php-fpm-application	none (public HTTPS clone)	TLS (HTTPS)	`Containerfile.php` lines

External System	Data Exchanged	Direction (in / out / both)	Owner Component	Auth Method	Encryption in Transit	Evidence
plugin/theme repos)						18-34

1.10 Entry Point Inventory

Entry Point	Method / Event	Handler File	Handler Function	Component	Layer
/ (OpenShift Route → web Service)	HTTP (Route ingress)	`chart/psa-moodle/templates/route.yaml`	N/A (Route → Service passthrough)	openshift-route	externalIntegration
`/health`	GET	`chart/psa-moodle/templates/web-deployment.yaml`	livenessProbe/readinessProbe `httpGet`	web-container	UI
Moodle cron tick	scheduled-task (`cron.schedule`, default Deployment-loop mode)	`chart/psa-moodle/templates/cron-cronjob.yaml`	`php admin/cli/cron.php`	cron-workload	businessLogic
Backup-integrity check	scheduled-task (`backup.integrity.schedule`)	`chart/psa-moodle/templates/cronjob-backup-integrity.yaml`	`/usr/local/bin/backup-integrity.sh`	ops-tooling	businessLogic
Moodledata snapshot	scheduled-task (`backup.moodledataSnapshot.schedule`)	`chart/psa-moodle/templates/cronjob-moodledata-snapshot.yaml`	`/usr/local/bin/moodledata-snapshot.sh`	ops-tooling	businessLogic
Restore rehearsal	scheduled-task (`backup.restoreRehearsal.schedule`)	`chart/psa-moodle/templates/cronjob-restore-rehearsal.yaml`	`/usr/local/bin/restore-rehearsal.sh`	ops-tooling	businessLogic
Post-install DB bootstrap	event-trigger (Helm `post-install` hook)	`chart/psa-moodle/templates/job-install.yaml`	`php admin/cli/install_database.php`	install-job	businessLogic

1.11 Database Integration

1.11.1 Primary Database

- **Type**: PostgreSQL 15, managed by the Crunchy PostgreSQL Operator (`PostgresCluster` CR)
- **Purpose**: Stores all Moodle relational data (`mdl_*` tables, created by the upstream installer at runtime — not defined in this repository). The chart's only owned SQL is a one-time schema-ownership grant (`chart/psa-moodle/templates/postgres-init-configmap.yaml`) needed because PostgreSQL 15 revokes `CREATE` on `public` from non-owners by default.

1.11.2 Additional Data Stores

- **Valkey 7.2** — session storage (`\core\session\redis`) and Moodle application cache, AUTH-protected via a generated password (`chart/psa-moodle/templates/secret-valkey.yaml`).
- **Moodledata PVC** — ReadWriteMany file storage for uploaded content and Moodle's `dataroot`, shared by php and cron only.

1.12 API Integrations

1.12.1 Client Application APIs

- **Purpose**: Moodle's own web UI and any REST/web-service endpoints are served entirely by upstream Moodle code (not present in this repository); this repo only controls the ingress path (Route → web → php) and TLS/timeout behavior.
- **Authentication Method**: Moodle core session-based auth plus OAuth2 SSO (`admin/tool/oauth2`), configured at runtime — no static config for the OAuth2 issuer exists in-repo.
- **Key Endpoints**:
    - `/health`: liveness/readiness probe target on both web (nginx) and php (via `php-fpm-healthcheck` exec probes)

1.12.2 Internal Service APIs

- **web → php**: FastCGI over port 9000, restricted by NetworkPolicy (`chart/psa-moodle/templates/networkpolicy.yaml`)
- **php/cron → PostgreSQL**: `pdo_pgsql`/`pgsql` PHP extensions over the Crunchy-generated `pguser` Secret's `host`/`port`/`user`/`password` keys
- **php/cron → Valkey**: `redis` PHP extension, AUTH-protected, over the Valkey `Service` DNS name
- **ops-tooling → PostgreSQL**: `oc exec`/`psql` into Crunchy pods, scoped by the `rbac-ops` Role (`chart/psa-moodle/templates/rbac-ops.yaml`)

---

2 Business Workflow Analysis — psa-moodle

Registry note: `vibe-get-template domain="workflow"` (and `domain="business-workflow"`) and `vibe-get-skill skills=["analysis-workflow"]` both returned "not found" for this assessment run — neither a `workflow` output template nor an `analysis-workflow` skill is registered in the current VIBE tool catalog, and the `json-output-schema` contract has no dedicated `workflow-worker` payload section. This report therefore follows the business-workflow mode's own Step 4–7 instructions as the authoritative structure (entry-point inventory, per-workflow trace with file:line evidence, confidence rating, observed/absent security controls, coverage note), reusing the generic envelope and the `evidence-and-citations` / `template-filling` / `json-output` skills, which ARE registered. No security findings, severities, or CVSS scores appear below — this is structural documentation only; security interpretation is performed downstream by Zero Trust governance mapping.

2.1 Repository Context

psa-moodle is an **infrastructure/deployment repository**, not a traditional application codebase with HTTP route handlers in-repo. It packages Moodle 4.5 (upstream PHP application, not vendored in this repo) for OpenShift via a Helm chart (`chart/psa-moodle/`), four container images (`Containerfile.web/.php/.cron/.ops`), and a set of operator-invoked shell scripts (`scripts/ops/*.sh`). "Entry points" are therefore interpreted per the task brief as: the OpenShift Route, CronJobs/long-running cron loop, the Helm post-install hook Job, and the ops shell scripts those CronJobs invoke.

2.2 Entry Point Inventory

Entry points below are carried forward from `rapid-assessment/data/architecture.json`'s `data.entryPointInventory[]` (populated by the architecture worker) and were validated against the current source tree during this trace.

#	Entry Point	Trigger Type	Handler File	Component
1	/ (all paths)	External HTTPS via OpenShift Route	chart/psa-moodle/templates/route.yaml	openshift-route → web-container
2	`/health`	HTTP GET (liveness/readiness probe, not learner-facing)	chart/psa-moodle/templates/web-deployment.yaml	web-container
3	`cron.schedule` (or continuous loop)	Scheduled task / long-running loop	chart/psa-moodle/templates/cron-	cron-workload

#	Entry Point	Trigger Type	Handler File	Component
			cronjob.yaml (fallback) / chart/psa-moodle/templates/cron-deployment.yaml (default)	
4	`backup.integrity.schedule`	Scheduled task (daily)	chart/psa-moodle/templates/cronjob-backup-integrity.yaml	ops-tooling
5	`backup.moodledataSnapshot.schedule` (+ `.pruneSchedule`)	Scheduled task (daily)	chart/psa-moodle/templates/cronjob-moodledata-snapshot.yaml	ops-tooling
6	`backup.restoreRehearsal.schedule`	Scheduled task (weekly)	chart/psa-moodle/templates/cronjob-restore-rehearsal.yaml	ops-tooling
7	`helm.sh/hook: post-install`	Install-time event trigger (Helm hook)	chart/psa-moodle/templates/job-install.yaml	install-job

`entryPointsFound: true`.

2.3 Workflow Traces

2.3.1 Workflow 1 — Learner HTTP Request (Route → NetworkPolicy → Web → PHP-FPM → Data Stores)

Entry point: External HTTPS request to the OpenShift Route. **Confidence:** high

Step	Action	File	Line
1	OpenShift `Route` terminates edge TLS and forwards to the `-web` Service on `targetPort: http`;	chart/psa-moodle/templates/route.yaml	7

Step	Action	File	Line
	`haproxy.router.openshift.io/timeout` annotation raised to match downstream fastcgi timeout		
2	Ingress `NetworkPolicy` - `allow-router-to-web` permits traffic from the router namespace selector into web pods on the Service port; a paired `-deny-by-default` policy denies all other ingress	chart/psa-moodle/templates/networkpolicy.yaml	27
3	nginx (`web-container`) recovers the real client IP from `X-Forwarded-For`, trusting only RFC1918 hop addresses (the router), and logs to `main_xff` format	config/nginx/default.conf	1
4	Moodle-recommended deny rules block direct access to dotfiles, `composer.*`, `config.*`, `install.xml`, `environment.xml`, `.git`, `vendor/`, `node_modules/`	config/nginx/default.conf	43
5	`/health` path returns a static `200 ok` with `access_log off`, bypassing PHP	config/nginx/default.conf	68
6	All other paths are rewritten to	config/nginx/default.conf	54

Step	Action	File	Line
	`index.php` and proxied over FastCGI to `php:9000`		
7	Ingress `NetworkPolicy` - `allow-web-to-php` permits only web-labelled pods to reach php pods on the FPM port	chart/psa-moodle/templates/networkpolicy.yaml	46
8	`php-fpm-application` container runs Moodle under `config.openshift.php`, which reads DB/cache connection parameters from environment variables (`DB_HOST`, `DB_USER`, `DB_PASSWORD`, `CACHE_HOST`, `CACHE_PASSWORD`) sourced from Secrets, never hardcoded	config/moodle/config.openshift.php	9
9	Moodle session storage is Valkey (`\core\session\redis`), authenticated with `session_redis_auth` from `CACHE_PASSWORD`	config/moodle/config.openshift.php	36
10	Ingress `NetworkPolicy` - `allow-app-to-valkey` and `-allow-app-to-postgres` scope reachability to php/cron/install	chart/psa-moodle/templates/networkpolicy.yaml	65

Step	Action	File	Line
	(and backup-integrity/restore-rehearsal for postgres) pods only		
11	Valkey requires a password (`requirepass`) generated into a Secret, added as defense-in-depth on top of NetworkPolicy	chart/psa-moodle/templates/secret-valkey.yaml	1
12	PHP-FPM container runs `securityContext.allowPrivilegeEscalation: false`, drops all Linux capabilities, and the pod sets `runAsNonRoot: true`	chart/psa-moodle/templates/php-deployment.yaml	60
13	Uploaded/shared content persists to the RWX `moodledata` PVC, mounted read/write by both php and cron pods	chart/psa-moodle/templates/moodledata-pvc.yaml	1

Security controls observed: - Default-deny ingress NetworkPolicy with explicit per-hop allowlist (router→web, web→php, app→valkey, app→postgres) - TLS edge-termination at the Route; `sslproxy=true` in Moodle config to correctly treat the connection as HTTPS - Trusted-proxy-scoped `X-Forwarded-For` handling (RFC1918-only `set_real_ip_from`) for audit-log client attribution - Deny rules for sensitive file patterns (`.git`, `config.*`, `vendor/`) at the nginx layer - Valkey `requirepass` (Secret-sourced) as defense-in-depth behind NetworkPolicy - Non-root containers with dropped Linux capabilities and `allowPrivilegeEscalation: false` on web/php pods - DB/cache credentials injected via env vars from Kubernetes Secrets, not hardcoded in `config.openshift.php`

Security controls absent / not observed in-repo: - No WAF, rate-limiting, or request-size/anti-automation control visible at the Route or nginx layer beyond `client_max_body_size` - No egress NetworkPolicy restriction on the OAuth2 SSO callout is enumerated by port/FQDN — `networkpolicy.yaml` comments note external 443/25 egress defaults to `0.0.0.0/0` unless an OpenShift EgressFirewall is layered on top (see `docs/phase4-hardening.md`) - `readOnlyRootFilesystem: false` on both web and php containers (writable root filesystem)

2.3.2 Workflow 2 — Moodle Scheduled-Task Runner (Cron)

Entry point: Time-based trigger — continuous loop (default) or CronJob (fallback mode).
Confidence: high

Step	Action	File	Line
1	Default mode (`cron.mode=deployment`): single-replica Deployment runs a shell loop invoking `php admin/cli/cron.php`, sleeping `CRON_INTERVAL` seconds between ticks	chart/psa-moodle/templates/cron-deployment.yaml	47
2	Fallback mode (`cron.mode=cronjob`): a `CronJob` with `concurrencyPolicy: Forbid` runs the same command as an isolated per-tick pod	chart/psa-moodle/templates/cron-cronjob.yaml	8
3	Both variants share the same `psa-moodle.appEnv` env block (DB/cache credentials from Secrets) as the php-fpm container	chart/psa-moodle/templates/cron-cronjob.yaml	38
4	Cron pod mounts the same RWX `moodledata` PVC as php, so scheduled tasks (e.g. file cleanup) can touch the shared content store	chart/psa-moodle/templates/cron-deployment.yaml	42
5	Cron reachability to Valkey/Postgres is	chart/psa-moodle/templates/n	70

Step	Action	File	Line
	scoped by the same `-allow-app-to-valkey` / `-allow-app-to-postgres` ingress policies (php/cron/install component label match)	etworkpolicy.yaml	
6	A liveness probe checks a heartbeat file written after each tick, restarting the loop if wedged for >600s	chart/psa-moodle/templates/cron-deployment.yaml	65

Security controls observed: - Same NetworkPolicy scoping and non-root/no-capabilities container `securityContext` as the web/php workflow - `concurrencyPolicy: Forbid` (CronJob fallback) / single Deployment replica + `Recreate` strategy prevent overlapping cron.php runs

Security controls absent / not observed in-repo: - No explicit resource-based isolation preventing a compromised cron tick from reading/writing all of `moodledata` (RWX, no per-task scoping) - `readOnlyRootFilesystem: false` on the cron container

---

2.3.3 Workflow 3 — Daily Backup-Integrity Verification

Entry point: `CronJob` scheduled trigger (`backup.integrity.schedule`). **Confidence:** high

Step	Action	File	Line
1	`CronJob` fires on schedule, `concurrencyPolicy: Forbid`, runs under the dedicated `-ops` ServiceAccount	chart/psa-moodle/templates/cronjob-backup-integrity.yaml	12
2	Container executes `/usr/local/bin/backup-integrity.sh` from the `ops-tooling` image	chart/psa-moodle/templates/cronjob-backup-integrity.yaml	36
3	Script fetches DB host/user/password	scripts/ops/backup-integrity.sh	69

Step	Action	File	Line
	from the Crunchy-managed `pguser` Secret via `oc get secret ... -o jsonpath` rather than embedding credentials in the CronJob env		
4	Script runs `psql` queries against the live primary to confirm required Moodle tables exist and canonical tables are non-empty	scripts/ops/backup-integrity.sh	76
5	Script also inspects pgBackRest repo state (age/status of full backups) — read further in file beyond the excerpt shown	scripts/ops/backup-integrity.sh	61
6	On any failure, `alert.sh` sends an email over the unauthenticated BC Gov SMTP relay (port 25, no TLS/auth asserted) with a log tail attached	scripts/ops/alert.sh	21
7	RBAC: the `-ops` Role grants `secrets: [get, list]` and `pods/exec: [create]`, scoped to the release namespace only	chart/psa-moodle/templates/rbac-ops.yaml	33

Security controls observed: - Dedicated least-privilege `ServiceAccount/Role/RoleBinding` (namespace-scoped, not cluster-admin) for all ops CronJobs - Credentials pulled from the Secret at runtime rather than materialized into CronJob env definitions - Non-root, capability-dropped container `securityContext`

Security controls absent / not observed in-repo: - Alert email transport (`alert.sh` → `swaks --port 25`, no `--tls`) is unauthenticated, unencrypted SMTP — log/alert content (table names, failure detail, log tail) is sent in plaintext - RBAC `secrets: [get, list]` verb is not scoped to a named resource (`resourceNames`), so the Role can read any Secret in the namespace, not just the `pguser` Secret

---

2.3.4 Workflow 4 — Moodledata Snapshot + Retention Prune

Entry point: Two `CronJobs` (`backup.moodledataSnapshot.schedule` and `.pruneSchedule`).
Confidence: high

Step	Action	File	Line
1	Snapshot `CronJob` fires under the `-ops` ServiceAccount, runs `/usr/local/bin/moodledata-snapshot.sh`	chart/psa-moodle/templates/cronjob-moodledata-snapshot.yaml	30
2	Script verifies the target `VolumeSnapshotClass` exists before proceeding; if absent, emails a warning and exits 0 (graceful degrade, not a hard fail)	scripts/ops/moodledata-snapshot.sh	17
3	Script applies a `VolumeSnapshot` CR sourced from the `moodledata` PVC via `oc apply`	scripts/ops/moodledata-snapshot.sh	27
4	A second `CronJob` on `pruneSchedule` runs `/usr/local/bin/moodledata-snapshot-prune.sh` with `RETENTION_DAYS`, deleting VolumeSnapshots older than the window	chart/psa-moodle/templates/cronjob-moodledata-snapshot.yaml	100

Step	Action	File	Line
5	RBAC grants `volumesnapshots: [get, list, watch, create, delete]` namespace-scoped to the `-ops` Role	chart/psa-moodle/templates/rbac-ops.yaml	41
6	Optional cluster-scoped `VolumeSnapshotClass` read binding is off by default; script degrades gracefully without it	chart/psa-moodle/templates/rbac-ops.yaml	66

Security controls observed: - Namespace-scoped RBAC (no cluster-admin) for snapshot create/delete - Fail-safe degrade path (skip + alert) rather than crash-loop when cluster capability is missing - Non-root, capability-dropped container `securityContext`

Security controls absent / not observed in-repo: - No encryption-at-rest assertion for VolumeSnapshots is made in-repo (delegated to the underlying StorageClass/CSI driver, out of scope for this repository) - Same unauthenticated SMTP alert path as Workflow 3

2.3.5 Workflow 5 — Weekly Restore Rehearsal

Entry point: `CronJob` scheduled trigger (`backup.restoreRehearsal.schedule`).
Confidence: high

Step	Action	File	Line
1	`CronJob` fires weekly under the `-ops` ServiceAccount, runs `/usr/local/bin/restore-rehearsal.sh`	chart/psa-moodle/templates/cronjob-restore-rehearsal.yaml	12
2	Script `oc applys` a temporary `PostgresCluster` CR (`<cluster>-rehearsal`) whose `dataSource.postgresCluster` restores from the live	scripts/ops/restore-rehearsal.sh	51

Step	Action	File	Line
	cluster's pgBackRest repo		
3	Script polls for the rehearsal primary pod to report `ready=true` up to `REHEARSAL_TIMEOUT_SECONDS`	scripts/ops/restore-rehearsal.sh	80
4	(Beyond excerpt) script runs SQL smoke tests against the rehearsal cluster using the same `REQUIRED_TABLES`/`NONZERO_TABLES` checks as backup-integrity	scripts/ops/restore-rehearsal.sh	20
5	`trap 'cleanup' EXIT` always deletes the temporary `PostgresCluster` (`--ignore-not-found --wait=false`), win or fail	scripts/ops/restore-rehearsal.sh	33
6	RBAC grants `postgresclusters: [get, list, watch, create, delete]` namespace-scoped to the `-ops` Role — the load-bearing permission for this workflow	chart/psa-moodle/templates/rbac-ops.yaml	37
7	On failure or success, `alert.sh` emails a heartbeat/failure notice over the same unauthenticated SMTP relay	scripts/ops/restore-rehearsal.sh	23

Security controls observed: - Ephemeral, self-cleaning temporary database clone (`trap cleanup EXIT`) limits the exposure window of a full production data restore - Namespace-scoped RBAC for `postgresclusters` create/delete, no broader cluster privilege - Non-root, capability-dropped container `securityContext`

Security controls absent / not observed in-repo: - The rehearsal `PostgresCluster` CR applied inline by the script (lines ~51-71) does not set an explicit `securityContext`/network isolation beyond what the Crunchy operator applies by default — not fully assertable from this script alone - Same unauthenticated SMTP alert path as Workflows 3 and 4 - No explicit NetworkPolicy scoping visible for the ephemeral `<cluster>-rehearsal` pods (the existing `-allow-app-to-postgres` policy matches on `postgres-operator.crunchydata.com/cluster: <fixed clusterName>`, not a wildcard, so rehearsal-cluster reachability depends on operator-applied policy/labels not asserted in this repo)

2.3.6 Workflow 6 — Post-Install Database Bootstrap (Helm Hook)

Entry point: `helm.sh/hook: post-install` event trigger, fired once at `helm install` time.
Confidence: high

Step	Action	File	Line
1	Helm fires the hook Job after all chart resources are created (`hook-weight: "10"`); `hook-delete-policy` recreates the Job before each hook run	chart/psa-moodle/templates/job-install.yaml	18
2	An `initContainer` polls `pg_connect()` against `DB_HOST:DB_PORT` for up to 300s, blocking the main container until Postgres accepts connections	chart/psa-moodle/templates/job-install.yaml	36
3	Main container runs `php admin/cli/install_database.php --agree-license --`	chart/psa-moodle/templates/job-install.yaml	63

Step	Action	File	Line
	`adminuser=... --adminpass=... --adminemail=...`		
4	Admin credentials are sourced from the `-admin` Secret (`MOODLE_ADMIN_USER/EMAIL/PASS`), never inlined in the Job spec	chart/psa-moodle/templates/job-install.yaml	71
5	The `-admin` Secret is generated once with a 24-char random password via Helm's `lookup`/`randAlphaNum`, preserved across upgrades, and annotated `helm.sh/resource-policy: keep` so `helm uninstall` never deletes it	chart/psa-moodle/templates/secret-moodle.yaml	9
6	`install_database.php` is documented as idempotent-by-failure: it errors if the DB is already populated, so this hook is effectively install-only; schema upgrades require a separate manual `admin/cli/upgrade.php` exec	chart/psa-moodle/templates/job-install.yaml	12
7	Job mounts the same RWX `moodledata` PVC as php/cron for the initial content directories	chart/psa-moodle/templates/job-install.yaml	95

Security controls observed: - Admin password auto-generated (not a fixed default), preserved via `lookup` trick rather than regenerated per upgrade - Secret marked

`helm.sh/resource-policy: keep`, avoiding orphaned/reused credentials across reinstall cycles - Credentials injected via `secretKeyRef`, not passed as plaintext CLI args baked into the manifest - Non-root container `securityContext`

Security controls absent / not observed in-repo: - `install_database.php --adminpass="$MOODLE_ADMIN_PASS"` passes the secret value as a process argument at runtime (visible via `/proc/<pid>/cmdline` to any process with sufficient namespace access inside the pod) — this is a shell/process-argument exposure pattern inherent to the Moodle CLI installer's interface, not something this repo's manifest can avoid while using that CLI tool as documented - No automated password rotation mechanism for the admin Secret is present in-repo ("Rotate manually after install if desired")

2.4 Coverage Note

Six workflows were traced end-to-end from the seven entry points listed in `architecture.json`'s `entryPointInventory[]` (the `/health` probe entry point was folded into Workflow 1 as an internal branch rather than traced as its own workflow, since it is not a distinct business/operational process — it is a liveness/readiness check with no data-store interaction). This satisfies the "trace at minimum 5 workflows" requirement with 6 full traces (all entry points from the inventory are covered; none were excluded). Every step cites a `file:line` from the actual chart templates, ops scripts, or Moodle config in this repository — no application source code beyond the vendored config overlays exists in-repo (Moodle core and plugins are cloned from upstream GitHub repos at image-build time per `Containerfile.php`, and were out of scope for this structural trace). The two areas explicitly flagged as **not fully assertable from this repository alone** are: (1) the ephemeral restore-rehearsal `PostgresCluster`'s effective NetworkPolicy/securityContext posture, which depends on Crunchy-operator-applied defaults not declared in this repo, and (2) TLS/encryption posture of the Artifactory registry pull and VolumeSnapshot storage backend, both delegated to cluster/platform configuration outside this repository's scope. No severity ratings, CVSS scores, or vulnerability classifications appear in this document — those are the domain of downstream security-finding workers and the Zero Trust governance mapping stage.

---

3 Finding Chain Analysis

3.1 Summary

Artifact status: **partial**. 8 candidate multi-finding attack paths were evaluated across the 64 in-scope ordinary findings from this assessment. **0 chains were emitted as validated chains** and **8 were retained as rejected/unverified candidates**. This is not a finding of "no attack paths" — 3 of the 8 candidates (CAND-0001, CAND-0002, CAND-0003) are otherwise fully chain-eligible, evidence-backed, multi-step attack paths, but could not be emitted under a `chains[]` entry because no code-execution or cryptographic hashing tool

was available in this session to compute the mandatory deterministic SHA-256 `chainId`. Rather than fabricate a hash-looking identifier, the full analysis for each was preserved verbatim under `rejectedCandidates` with `reasonCode: unverified-edge`.

- Total candidates considered: 8
- Chains emitted: 0
- Rejected/unverified candidates: 8 (3 unverified-edge, 2 duplicate-or-supersedes, 2 missing-entry-point, 1 missing-evidence)
- Risk tier breakdown (emitted chains only): Critical 0, High 0, Medium 0, Low 0, Informational 0
- Confidence breakdown (emitted chains only): high 0, medium 0, low 0
- Source findings are unmodified by this analysis (see Source Finding Integrity below).

3.2 Methodology

Source artifacts reviewed: the 9 domain worker JSON files (authentication, authorization, code-vulnerabilities, configuration-management, cryptographic-security, dependencies, secrets, security-logging, testing), `architecture.json`/`architecture-diagram.md`, and `business-workflow.json`. `rapid-assessment/synthesis.md` was explicitly excluded as a source of truth, per the finding-chaining skill.

Candidate eligibility required: at least two distinct in-scope finding IDs, a plausible attacker-controlled entry point, logically ordered steps, direct evidence for every edge, and materially greater combined impact than any single finding alone. Candidates were rejected for sharing only a component/file/keyword/tag/CWE/severity without an evidenced causal or contributory link, for being duplicative of another candidate, or for lacking a reachable entry point under the shipped default configuration.

Chain identity is required to be deterministic: `chainId` = `CHAIN-` + the first 8 uppercase hex characters of SHA-256(`attack-path|ID1>ID2>...`), where the finding IDs are trimmed, upper-cased, and joined in step order. **No hashing/code-execution tool was available in this session** (confirmed by direct tool-call failures, not assumed), so this deterministic value could not be computed for any candidate. Per explicit workflow policy, hand-fabricating a hex-looking value in place of a real hash is prohibited. Each otherwise-eligible attack path was therefore reclassified as a rejected candidate with `reasonCode: unverified-edge`, with its full entry point, steps, edges, impact, and rationale preserved inline in the `reason` field so no analytical content was lost.

Evidence citations use `sourceType`/`file`/`startLine`/`endLine`/`snippet` when present; all `evidenceChecked` arrays in this artifact are empty by design (file/line references are instead cited inline in each candidate's `reason` text) to avoid emitting unredacted or unverified code excerpts without a verification tool. Ordinary findings, `allFindings[]`, and finding totals were not altered by this analysis.

3.3 Candidate Chains

No evidence-backed multi-finding attack paths were identified.

No candidates were emitted as validated chains in this run (`data.chains` is empty). All 8 candidates are documented under **Rejected Candidates** below, including the 3 otherwise chain-eligible attack paths (CAND-0001, CAND-0002, CAND-0003) whose full step-by-step analysis is preserved there.

3.4 Rejected Candidates

Candidate	Source Findings	Reason Code	Reason (summary)
CAND-0001	DEP-009, AUTHZ-001, AUTHZ-002, AUTHZ-003	unverified-edge	Supply-chain-compromise of the ops-tooling image (unverified `oc`/`swaks` download, Containerfile.ops:20) inherits the ops ServiceAccount's unscoped `pods/exec`, `secrets get/list`, and `postgresclusters create/delete` grants (chart/psa-moodle/templates/rbac-ops.yaml:30,34,39) — otherwise chain-eligible, High risk / medium confidence, but no chainId hash could be computed.
CAND-0002	DEP-001, DEP-002, TEST-002, VULN-001	unverified-edge	Six unpinned upstream plugin/theme clones (Containerfile.php:28,33) ship with no CI SAST/SCA/image scan gate (.github/workflows/build.yml:1) into a container with world-writable

Candidate	Source Findings	Reason Code	Reason (summary)
			`directorypermissions = 02777` (config/moodle/config.openshift.php:28) shared with the cron pod — otherwise chain-eligible, High risk / medium confidence, but no chainId hash could be computed.
CAND-0003	AUTHZ-005, CONFIG-006	unverified-edge	Automounted default ServiceAccount token on the internet-facing web pod (chart/psa-moodle/templates/web-deployment.yaml:23) combined with unrestricted 0.0.0.0/0 egress (chart/psa-moodle/templates/networkpolicy.yaml:232) — otherwise chain-eligible (rests on an unproven initial-compromise precondition), Medium risk / low confidence, but no chainId hash could be computed.
CAND-0004	SECRET-001, SECRET-002	missing-entry-point	Hardcoded local-dev credentials (config.local.php, compose.yaml) are confined to the dev-only Podman Compose variant,

Candidate	Source Findings	Reason Code	Reason (summary)
			never deployed to OpenShift; no reachable production entry point.
CAND-0005	CRYPTO-004, CRYPTO-005	duplicate-or-supersedes	Two independent unencrypted-SMTP paths (ops alert.sh, Alertmanager email receiver) with no evidenced link between them; would overstate connectivity that doesn't exist.
CAND-0006	CONFIG-005	missing-evidence	No template/config file wires values-dev.yaml's `moodle.debug` into `$CFG->debug` at deploy time; proposed link unsupported by evidence.
CAND-0007	DEP-006, DEP-008	duplicate-or-supersedes	PHP 8.3 / Alpine 3.20 approaching-EOL findings describe the same attack surface already captured by CAND-0002; would double-count risk without new evidenced linkage.
CAND-0008	AUTHZ-004	missing-entry-point	The cluster-wide ClusterRoleBinding is gated behind an opt-in Helm value that defaults to `false` in every shipped values file; no active entry point

Candidate	Source Findings	Reason Code	Reason (summary)
			exists today.

3.5 Source Finding Integrity

- Source finding count: 64
- Source finding IDs (sorted, unique): AUTH-001, AUTH-002, AUTHZ-001..AUTHZ-009, CONFIG-001..CONFIG-010, CRYPTO-001..CRYPTO-006, DEP-001..DEP-013, LOG-001..LOG-007, SECRET-001, SECRET-002, TEST-001..TEST-007, VULN-001..VULN-008 (full list in `data/finding-chaining.json`)
- `unmodified`: true — no source finding was altered by this analysis
- `severitySnapshotsMatch`: true
- Integrity errors: none
- Ordinary findings, `allFindings[]`, and per-domain totals were not changed by this analysis.

3.6 Limitations

- No code-execution or cryptographic hashing tool was available in this session to compute the mandatory deterministic SHA-256 `chainId`, so no candidate could be emitted as a validated chain; all three otherwise-eligible attack paths were retained as rejected candidates (CAND-0001..CAND-0003) with their full analysis preserved in the `reason` field rather than assigning a fabricated chainId. A future session with a working hashing/execution tool should recompute these three chainIds and promote the candidates to `chains[]` if the identifiers validate.
- No live exploitation or dynamic testing was performed; all candidate analysis rests on static evidence only.
- GitHub-hosted intelligence (CodeQL code scanning, secret scanning, Dependabot alerts) was unavailable in this environment (`toolReadiness.githubMcp=false`), so candidates could not be cross-referenced against GitHub-native alert data.

---

4 Zero Trust Governance Mapping — psa-moodle

- **Assessment ID:** ra-2026-09-09T045716Z
- **Target repository:** psa-moodle
- **Coverage:** all Critical, High, and Medium findings (0 Critical + 8 High + 18 Medium = **26 findings mapped**). Low and Informational findings are excluded per the standard coverage rule. *(LOG-002 and VULN-001 severities were corrected during reverse-validation — High→Medium and Medium→Low respectively — which moved LOG-002 into the Medium table below and dropped VULN-001 out of scope entirely.)*

Registry note. The `analysis-zero-trust-mapping` skill and the `zero-trust-governance-template` were not registered in this environment. This mapping

follows the `data.zeroTrustMapping` schema in `json-output-schema.md` and the mode's Step 4 instructions. Each finding is assigned a single primary Zero Trust principle and a single primary pillar so the breakdown counts reconcile exactly. No new findings are introduced and no finding IDs, severities, or evidence are modified.

4.1 Principle Breakdown

Zero Trust Principle	Count	Critical	High	Medium
VERIFY_EXPLICITLY	5	0	1	4
LEAST_PRIVILEGE	8	0	3	5
ASSUME_BREACH	13	0	4	9
Total	**26**	**0**	**8**	**18**

4.2 Pillar Breakdown

Zero Trust Pillar	Count	Critical	High	Medium
IDENTITY	6	0	0	6
DEVICES	0	0	0	0
APPLICATIONS	7	0	4	3
DATA	2	0	0	2
INFRASTRUCTURE	8	0	3	5
NETWORK	3	0	1	2
Total	**26**	**0**	**8**	**18**

4.3 Governance Interpretation

The dominant Zero Trust theme is **ASSUME_BREACH** (13 findings): the deployment does not consistently minimize blast radius once an initial compromise is assumed — unpinned/unverified supply-chain artifacts reach production, the internet-facing edge lacks browser-side defenses, egress is unrestricted, and alerting travels in cleartext. The second theme is **LEAST_PRIVILEGE** (8 findings): the namespace-wide `-ops` RBAC grants and the default ServiceAccount token automount on every workload grant more privilege than any workload requires. **VERIFY_EXPLICITLY** (5 findings) covers the unenforced database TLS, the credential-in-process-args exposure, and the absence of automated security verification in CI.

By pillar, risk concentrates in **INFRASTRUCTURE** (RBAC + supply chain) and **APPLICATIONS** (edge headers, plugin supply chain, CI verification), with a notable **IDENTITY** cluster driven by the five uniform default-token-automount findings.

4.4 Mapped Findings

4.4.1 High severity

Finding	Domain	Principle(s)	Pillar(s)	CIA (C/I/A)	Business Impact
AUTHZ-001	AUTHORIZATION	LEAST_PRIVILEGE	INFRASTRUCTURE	High / High / High	Ops compromise yields `oc exec` into every pod, enabling namespace-wide lateral movement.
AUTHZ-002	AUTHORIZATION	LEAST_PRIVILEGE	INFRASTRUCTURE	High / Low / None	Ops SA can read every namespace Secret, exposing the Moodle admin and Valkey credentials.
AUTHZ-003	AUTHORIZATION	LEAST_PRIVILEGE	INFRASTRUCTURE	Low / High / High	Ops SA can delete the production PostgresCluster, risking full availability/data loss.
CONFIG-001	CONFIGURATION	ASSUME_BREACH	APPLICATIONS	Medium / Medium / None	No CSP/X-Frame-Options exposes user-generated content to injection and clickjacking.
CONFIG-006	CONFIGURATION	ASSUME_BREACH	NETWORK	Medium / Low / None	Release-wide 0.0.0.0/0 egress gives every pod an unrestricted exfiltration path.
DEP-001	DEPENDENCIES	ASSUME_BREACH	APPLICATIONS	High / High / Medium	Unpinned HVP plugin master branch becomes production code on the next build.
DEP-002	DEPENDENCIES	ASSUME_BREACH	APPLICATIONS	High / High / Medium	Five plugin/theme repos tracked at moving default branches broaden supply-chain risk.

Finding	Domain	Principle(s)	Pillar(s)	CIA (C/I/A)	Business Impact
TEST-001	TESTING	VERIFY_EXPLICITLY	APPLICATIONS	Medium / Medium / None	No authn/authz/input tests; an access-control regression ships past a smoke test.

4.4.2 Medium severity

Finding	Domain	Principle(s)	Pillar(s)	CIA (C/I/A)	Business Impact
AUTHZ-005	AUTHORIZATION	LEAST_PRIVILEGE	IDENTITY	Medium / Low / None	Internet-facing nginx pod carries an unnecessary, exfiltratable SA token.
AUTHZ-006	AUTHORIZATION	LEAST_PRIVILEGE	IDENTITY	Medium / Low / None	PHP pod handling untrusted input carries an unnecessary SA token.
AUTHZ-007	AUTHORIZATION	LEAST_PRIVILEGE	IDENTITY	Medium / Low / None	Cron pod carries an unnecessary SA token.
AUTHZ-008	AUTHORIZATION	LEAST_PRIVILEGE	IDENTITY	Medium / Low / None	Install Job (handles admin/DB creds) carries an unnecessary SA token.
AUTHZ-009	AUTHORIZATION	LEAST_PRIVILEGE	IDENTITY	Medium / Low / None	Valkey pod carries an unnecessary SA token.
LOG-002	SECURITY_LOGGING	VERIFY_EXPLICITLY	IDENTITY	High / Low / None	Admin password passed as a CLI argument is capturable by node-level auditing. *(severity corrected High→Medium during reverse-validation)*

Finding	Domain	Principle(s)	Pillar(s)	CIA (C/I/A)	Business Impact
CONFIG-002	CONFIGURATION	ASSUME_BREACH	APPLICATIONS	Low / Medium / None	Missing X-Content-Type-Options/Referrer-Policy enables MIME-sniff and referrer leak.
CONFIG-004	CONFIGURATION	VERIFY_EXPLICITLY	DATA	Medium / Medium / None	DB TLS not application-enforced; encryption-in-transit unverified.
CRYPTO-002	CRYPTOGRAPHY	VERIFY_EXPLICITLY	DATA	Medium / Medium / None	Referenced /etc/db-tls mount not implemented; DB TLS not fail-closed.
DEP-003	DEPENDENCIES	ASSUME_BREACH	INFRASTRUCTURE	Medium / Medium / Low	Floating latest-release binary executed as root at build with no checksum.
DEP-004	DEPENDENCIES	ASSUME_BREACH	INFRASTRUCTURE	Medium / Medium / Low	Healthcheck script fetched from mutable branch, no integrity check.
DEP-006	DEPENDENCIES	ASSUME_BREACH	INFRASTRUCTURE	Medium / Medium / Low	PHP 8.3 nearing EOL narrows the security-patch window.
DEP-008	DEPENDENCIES	ASSUME_BREACH	INFRASTRUCTURE	Medium / Medium / Low	Alpine 3.20 nearing EOL stops ops-image package patches.
DEP-009	DEPENDENCIES	ASSUME_BREACH	INFRASTRUCTURE	Medium / High / Medium	oc/swaks downloaded without checksum then run with high ops privilege.
LOG-001	SECURITY_LOG	ASSUME_BREACH	APPLICATIONS	Low / Low / Medium	Cron failures never alert; a failing

Finding	Domain	Principle(s)	Pillar(s)	CIA (C/I/A)	Business Impact
	GING				security task can go undetected.
LOG-003	SECURITY_LOGGING	ASSUME_BREACH	NETWORK	Medium / Low / None	Audit-log tail emailed over unauthenticated cleartext SMTP.
LOG-004	SECURITY_LOGGING	ASSUME_BREACH	NETWORK	Medium / Low / None	Platform alerts delivered with requireTLS:false.
TEST-002	TESTING	VERIFY_EXPLICITLY	APPLICATIONS	Medium / Medium / Low	No SAST/SCA/secret/image scan gates the build before push.

4.5 Compliance Framework Implications

- **BC Gov OCIO least-privilege / network-segmentation standards** — the ops RBAC grants (AUTHZ-001/002/003), default token automount (AUTHZ-005..009), and release-wide egress (CONFIG-006) are the primary deviations.
- **BC Gov data-in-transit encryption standard** — unenforced DB TLS (CONFIG-004/CRYPTO-002) and cleartext SMTP alerting (LOG-003/LOG-004).
- **SLSA supply-chain integrity** — unpinned/unverified build artifacts (DEP-001/002/003/004/009) with no CI scan gate (TEST-002).
- **OWASP ASVS** — V14 (edge headers, CONFIG-001/002), V7 (secret in logs LOG-002; monitoring LOG-001), V1 (secure SDLC, TEST-001/002).

---

5 Authentication Vulnerabilities Analysis

5.1 Executive Summary

psa-moodle is an infrastructure/deployment repository (Helm chart, Containerfiles, PHP config overlays, ops shell scripts) for a Moodle 4.5 Learning Management System on OpenShift. **No application-level authentication logic exists in this repository.** Moodle core (a vendored, not-in-repo dependency cloned during the `Containerfile.php` build) owns all login/logout flows, password hashing, session-token issuance, CSRF protection, and the OAuth2 (`admin/tool/oauth2`) SSO integration referenced in `README.md` and `docs/phase4-hardening.md`. Those flows are configured entirely at runtime through the Moodle administrator UI (Site administration → Server → OAuth 2 services) and have zero

static representation in this codebase, so they are out of scope for a source-level authentication review and are not fabricated as findings here.

What this repository *does* control, and what this analysis covers, is authentication-adjacent configuration that feeds Moodle: the two `$CFG` overlay files (`config/moodle/config.local.php`, `config/moodle/config.openshift.php`) that wire Moodle's session backend (Valkey/Redis) and admin bootstrap credentials, the Valkey `requirepass` enforcement in the Helm chart, the OpenShift Route/TLS termination policy, and the ops RBAC ServiceAccount. RBAC least-privilege scoping (`rbac-ops.yaml`) is an authorization concern and is not re-litigated here beyond noting the ServiceAccount exists and is scoped per-namespace.

Two Low-severity Session Handling observations were identified, both concentrated in how the Valkey (Redis-compatible) session store's own AUTH credential is wired: (1) both `$CFG` overlays silently fall back to an empty-string `session_redis_auth` if the `CACHE_PASSWORD` environment variable is ever absent, a fail-open pattern rather than a fail-loud one, and (2) the local-development-only `config/valkey/valkey.conf` ships with `protected-mode no` and no `requirepass`, relying entirely on the Podman Compose network boundary for isolation. In the actual OpenShift deployment path, `valkey-statefulset.yaml` unconditionally appends `--requirepass $(VALKEY_PASSWORD)` on the command line (which overrides the ConfigMap's `protected-mode no`) and `_helpers.tpl`'s `psa-moodle.appEnv` sources `CACHE_PASSWORD` from a mandatory `secretKeyRef` (no default), so both observations are defense-in-depth gaps rather than exploitable production weaknesses. No Critical, High, or Medium authentication findings were identified. No hardcoded production credentials, disabled TLS validation, or missing-authentication conditions were found in the reviewed files — the OpenShift Route enforces `insecureEdgeTerminationPolicy: Redirect` (values.yaml), and the Moodle admin bootstrap password is a Helm-generated 32/24-character random value stored only in a Kubernetes Secret, never in source.

5.1.1 Authentication Issue Totals by Severity

Core Area	Critical	High	Medium	Low	Total
Improper Auth and Token Check	0	0	0	0	0
Session Handling	0	0	0	2	2
Integration Security (Auth)	0	0	0	0	0
Total	**0**	**0**	**0**	**2**	**2**

5.2 Detailed Component Analysis

5.2.1 Component: Web Container (nginx)

5.2.1.1Component Overview

Immutable nginx front-end (`config/nginx/default.conf`) that terminates FastCGI to PHP-FPM. It performs no authentication itself — it recovers the real client IP from `X-Forwarded-`

For (trusted only from RFC1918 ranges) for audit logging and denies direct access to dotfiles/config.*/.git/vendor. All login/session handling happens downstream in the PHP-FPM/Moodle layer.

5.2.1.2Authentication Issues

No authentication issues identified. nginx contains no auth logic; the location = /health endpoint returns a static string with no sensitive data.

5.2.2 Component: PHP-FPM Application Container

5.2.2.1Component Overview

Runs the Moodle 4.5 codebase. All actual login, session-token, and CSRF logic lives inside vendored Moodle core (not in this repository). The two files this repository does own — config/moodle/config.local.php and config/moodle/config.openshift.php — configure the session backend (Valkey/Redis) that Moodle's \core\session\redis handler uses to store authenticated session state, and set $CFG->admin/$CFG->directorypermissions.

5.2.2.2Authentication Issues

ID	Location	Component	Issue Type	Severity	Description	Impact
AUTH-001	./config/moodle/config.local.php at line 39; ./config/moodle/config.openshift.php at line 41	php-fpm-application	Session Handling	Low	Both $CFG overlays set $CFG->session_redis_auth = getenv('CACHE_PASSWORD') ?: ''; — if the CACHE_PASSWORD environment variable is ever unset or empty, Moodle silently attempts to authenticate to the Valkey session store with an empty password instead of failing loudly.	If the mandatory CACHE_PASSWORD secretKeyRef wiring in _helpers.tpl were ever bypassed or the env var otherwise cleared, session-store authentication would fail open

ID	Location	Component	Issue Type	Severity	Description	Impact
						to “no password supplied” rather than blocking startup, an unnecessary weakening of the session-backend authentication posture. In the current chart this is mitigated by `valkey-statefulset.yaml`’s mandatory `--requirepass $(VALKEY_PASSWORD)`, which has no empty-string fallback and would simply

ID	Location	Component	Issue Type	Severity	Description	Impact
						refuse the connection.

5.2.3 Component: Cron Workload

5.2.3.1Component Overview

Executes Moodle's scheduled-task runner (`admin/cli/cron.php`) via the same `psa-moodle.appEnv` environment block (DB/Valkey credentials) as the PHP-FPM container. It authenticates to Postgres and Valkey using the identical credential-injection pattern already assessed under PHP-FPM Application Container.

5.2.3.2Authentication Issues

No additional authentication issues identified beyond the shared `psa-moodle.appEnv` pattern already noted under AUTH-001 (this workload consumes the same `config.openshift.php`).

5.2.4 Component: Install Job

5.2.4.1Component Overview

One-shot Helm post-install `Job` (`job-install.yaml`) that runs `admin/cli/install_database.php --adminuser=... --adminpass=... --adminemail=...` to bootstrap the initial Moodle admin account. Credentials are sourced exclusively from the `<release>-admin` Kubernetes Secret (`secret-moodle.yaml`), which generates a random 24-character admin password via `randAlphaNum 24` on first install and preserves it across upgrades via Helm's `lookup` trick.

5.2.4.2Authentication Issues

No authentication issues identified. The admin bootstrap password is never present in source, is generated with sufficient entropy (24-char `randAlphaNum`), and is passed to the installer only via `secretKeyRef` environment variables, not command-line literals that would appear in process listings as static text.

5.2.5 Component: PostgreSQL Cluster (Crunchy PostgreSQL Operator)

5.2.5.1Component Overview

Operator-managed relational datastore. Application authentication to Postgres is delegated entirely to the Crunchy operator's auto-generated `pguser` Secret (`postgres-operator.crunchydata.com`), consumed by `psa-moodle.appEnv` as `DB_USER`/`DB_PASSWORD`. No credentials are duplicated in this chart.

5.2.5.2Authentication Issues

No authentication issues identified. Database credential authentication is entirely operator-managed; this repository only references the operator-generated Secret by name.

5.2.6 Component: Valkey Cache

5.2.6.1Component Overview

Single-replica Valkey (Redis-compatible) StatefulSet used exclusively as Moodle's session and cache backend. `secret-valkey.yaml` generates a 32-character random `VALKEY_PASSWORD` (Helm `lookup` trick preserves it across upgrades), and `valkey-statefulset.yaml` passes it to the server via `--requirepass $(VALKEY_PASSWORD)` on the command line, which takes precedence over the `protected-mode no` baked into `valkey-configmap.yaml/config/valkey/valkey.conf`.

5.2.6.2Authentication Issues

ID	Location	Component	Issue Type	Severity	Description	Impact
AUTH-002	`./config/valkey/valkey.conf` at lines 5-6	valkey-cache	Session Handling	Low	The local-development Valkey configuration file ships with `bind 0.0.0.0 -::*` and `protected-mode no`, and defines no `requirepass` directive, so a Valkey instance started with this file alone (as `compose.yaml`'s `cache` service does, via `command: ["valkey-server", "/usr/local/etc/valkey/valkey.conf"]`) accepts unauthenticate	Exploitability is confined to the Podman Compose bridge network (`compose.yaml` publishes no host port for the `cache` service, so it is unreachable from the host or beyond); the OpenShift deployment path

ID	Location	Component	Issue Type	Severity	Description	Impact
					d connections and can read or forge any stored session.	does not use this file's `protected-mode` setting for session security because `valkey-statefulset.yaml` unconditionally supplies `--requirepass`, which overrides it. This is a local-dev-only defense-in-depth gap, not a reachable production weakness.

5.2.7 Component: Moodledata Shared Storage

5.2.7.1Component Overview

A `ReadWriteMany` PVC (`moodledata-pvc.yaml`) mounted by the PHP-FPM and Cron containers for uploaded content. It has no authentication surface of its own; access is governed by pod-level filesystem permissions, not credential checks.

5.2.7.2Authentication Issues

No authentication mechanisms present in this component; not applicable to authentication analysis.

5.2.8 Component: Ops Tooling

5.2.8.1Component Overview

Backup-integrity, moodledata-snapshot, and restore-rehearsal CronJobs plus alerting scripts, run under a dedicated `<release>-ops` ServiceAccount (`rbac-ops.yaml`) scoped to a namespaced `Role` (pod exec, Secret read, PostgresCluster CR create/delete, VolumeSnapshot create/delete). Kubernetes ServiceAccount token authentication to the API server is the only "authentication" surface here; the granted permissions themselves (least-privilege scoping) are an authorization concern and are out of scope for this domain.

5.2.8.2Authentication Issues

No authentication issues identified. The ServiceAccount uses standard Kubernetes-issued, automatically-rotated tokens; no static credentials are embedded in the RBAC manifest or the ops shell scripts reviewed.

5.2.9 Component: NetworkPolicy Boundary

5.2.9.1Component Overview

Default-deny ingress/egress `NetworkPolicy` set (`networkpolicy.yaml`) that allowlists router→web, web→php, app→valkey, and app→postgres traffic, plus egress for the OAuth2 SSO flow, plugin runtime egress, and the SMTP mailer. NetworkPolicy is a network-segmentation control, not an authentication mechanism, though it does constrain who can reach the Valkey port referenced in AUTH-002 (php/cron/install pods only).

5.2.9.2Authentication Issues

No authentication issues identified; NetworkPolicy provides network-layer access restriction, not identity verification, and is outside this domain's scope beyond the mitigating context already noted for AUTH-002.

5.2.10 Component: OpenShift Route

5.2.10.1 Component Overview

`route.yaml` is the sole declared ingress path, terminating TLS at the edge (`values.yaml`: `termination: edge`) with `insecureEdgeTerminationPolicy: Redirect`, forcing HTTP→HTTPS redirection before any request reaches nginx.

5.2.10.2 Authentication Issues

No authentication issues identified. TLS is terminated with an enforced HTTPS redirect; no plaintext-HTTP authentication path is exposed at the Route layer.

5.2.11 Component: Helm Chart / Deployment Topology

5.2.11.1 Component Overview

Chart scaffolding and per-environment `values-*.yaml` files. The Moodle admin username/email defaults (`values.yaml`: `moodle.admin.user: admin`, `moodle.admin.email: admin@example.com`) are template-level defaults consumed only by the Install Job; the corresponding password is always Helm-generated (see Install Job above), not defaulted.

5.2.11.2 Authentication Issues

No authentication issues identified. The default admin username is a well-known value, but it is paired with a mandatory Helm-generated random password (never a default/well-known password), so it does not meet the bar for a "default credentials" finding.

5.2.12 Component: Monitoring and Observability

5.2.12.1 Component Overview

OpenShift user-workload-monitoring wiring (`monitoring.yaml`) for Postgres and PHP-FPM Prometheus exporters. No credential handling reviewed in this component beyond scrape endpoint exposure, which is an authorization/exposure concern, not authentication.

5.2.12.2 Authentication Issues

No authentication mechanisms present in this component; not applicable to authentication analysis.

5.2.13 Component: CI/CD Pipeline

5.2.13.1 Component Overview

GitHub Actions workflows and `Makefile` driving builds/lint/deploy. Authentication to external services (container registry, GitHub) is handled via GitHub Actions' own OIDC/token mechanisms, not custom code in this repository.

5.2.13.2 Authentication Issues

No authentication issues identified in the reviewed files; workflow-level credential/token handling is GitHub Actions platform behavior, not application code in this repository.

5.2.14 Component: Local Dev Compose Stack

5.2.14.1 Component Overview

Podman Compose stack (`compose.yaml`, `compose.registry.yaml`) reproducing the topology for local development. `compose.yaml` hardcodes `POSTGRES_PASSWORD: moodle` / `DB_PASSWORD: moodle` for the local db/php/cron services and does not set `CACHE_PASSWORD` at all (relying on the unauthenticated local Valkey config already covered under AUTH-002).

5.2.14.2 Authentication Issues

No additional authentication issues identified beyond AUTH-002 (already attributed to the valkey-cache component, since the root cause is the shared `config/valkey/valkey.conf` file). The hardcoded local Postgres password is explicitly commented as local-dev-only in `config/moodle/config.local.php` and is a secrets-handling observation rather than an authentication-mechanism weakness.

5.2.15 Component: Documentation & Runbooks

5.2.15.1 Component Overview

Project documentation and phase write-ups, including `docs/phase4-hardening.md` and `docs/bcgov-alignment-review.md`, which describe the runtime-configured OAuth2 SSO plan and note the CSS/Pathfinder SSO IdP credential request as "not yet requested" (M14 in `docs/bcgov-alignment-review.md`).

5.2.15.2 Authentication Issues

No authentication mechanisms present in this component; not applicable to authentication analysis. (Documentation confirms, and this review independently verified, that no OAuth2/OIDC client code or IdP configuration exists anywhere else in the repository.)

5.3 Severity Assignment Methodology

Both findings in this assessment (AUTH-001, AUTH-002) were assigned **Low** severity rather than Medium or High because, in each case, a compensating control elsewhere in the same chart independently prevents the weak default from becoming reachable in the OpenShift deployment path — the standard studied in the severity-assignment rubric for "missing security control… without an observed exploit path."

- **AUTH-001 (Low, not High):** A silent empty-string fallback for a credential is normally a fail-open anti-pattern that would justify a higher severity if the fallback could actually be reached in a live authentication path. Here, `_helpers.tpl`'s `psa-moodle.appEnv` sources `CACHE_PASSWORD` from a `secretKeyRef` with no `optional: true` flag, meaning Kubernetes itself refuses to start the pod if the referenced Secret/key is missing — the empty-string branch in PHP is dead code under normal chart operation. It remains Low rather than Informational because the code pattern itself is a maintainability/defense-in-depth gap: a future refactor that makes the env var optional, or a manual `oc set env` override, would reintroduce a real fail-open session-authentication weakness with no code-level guard rail.
- **AUTH-002 (Low, not Medium/High):** An unauthenticated Redis-protocol session store would normally be a High-severity finding (per the detection rules' "Insecure session storage mechanisms" and "session fixation"-adjacent guidance) because it allows direct session read/forgery by anyone who can reach the port. It is capped at Low here because (1) the file is explicitly and only used for local development —

`compose.yaml` does not publish a host port for the `cache` service, so exploitation requires access to the Podman Compose bridge network itself, and (2) the production OpenShift path never relies on this file's `protected-mode`/`requirepass` settings for session security, since `valkey-statefulset.yaml` unconditionally overrides them with a mandatory, randomly-generated `--requirepass` argument that has no empty-value fallback.

- **No Critical/High findings were assigned** because no missing-authentication endpoint, hardcoded production credential, disabled TLS/certificate validation, or complete-authentication-bypass condition was found in any reviewed file. The Moodle admin bootstrap credential is Helm-generated with adequate entropy (24 characters, `randAlphaNum`) and stored only in a Kubernetes Secret; the OpenShift Route enforces an HTTPS redirect (`insecureEdgeTerminationPolicy: Redirect`); and the only default, well-known value in the authentication surface (`moodle.admin.user: admin`) is not itself exploitable because it is never paired with a default or predictable password.
- **No Integration Security (Auth) findings were assigned** because the only authentication integration referenced anywhere in the repository — the OAuth2/OIDC SSO flow via Moodle core's `admin/tool/oauth2` — has zero static configuration, client code, redirect-URI handling, or state-parameter logic present in this repository to evaluate; it is exclusively configured at runtime through the Moodle administrator UI against an IdP that is not named in-repo. Reporting a finding against code that does not exist in this repository would violate the evidence-and-citations requirement that every finding cite concrete, verbatim source evidence.

---

6 Authorization Vulnerabilities Analysis

6.1 Executive Summary

This repository is an infrastructure/deployment codebase (Helm chart + Containerfiles + ops shell scripts) for a Moodle 4.5 LMS running on OpenShift. There is **no in-repo application-layer authorization logic** — Moodle's own role/capability system (roles, contexts, capabilities) lives entirely inside the upstream `moodle/moodle` source tree that is cloned at build time (`Containerfile.php`) and is out of scope for this repository's review; none of the first-party plugins vendored here (`moodle-course-search`, `local_githubsync`, `psaelmsync`, `pathcurator-moodle`, `bcgovpsa-moodle` theme) ship source in this repo either, so no PHP-level access-control code was reviewed.

Authorization in this repository is therefore entirely **infrastructure-layer**: Kubernetes RBAC (`Role`/`RoleBinding`/`ClusterRoleBinding`), Kubernetes `ServiceAccount` scoping/token automount, and (secondarily) `NetworkPolicy` as a network-layer access boundary. The most significant findings are in `chart/psa-moodle/templates/rbac-ops.yaml`, where the -

ops ServiceAccount used by the backup-integrity, moodledata-snapshot, and restore-rehearsal CronJobs is granted several namespace-wide (unscoped by resourceNames) permissions — pods/exec: create, secrets: get/list, and postgresclusters: create/delete — that are far broader than the specific pods, secrets, and PostgresCluster objects the accompanying ops scripts actually need to touch. If the -ops ServiceAccount's token or the ops container is ever compromised (e.g., via a supply-chain issue in the oc binary or swaks fetched at build time in Containerfile.ops, or a bug in the bash scripts under scripts/ops/), the blast radius is every pod, every secret, and the production PostgresCluster in the namespace — not just the backup/restore-rehearsal resources the role was designed for.

A secondary, lower-severity pattern is that none of the web, php, cron, or install workloads set serviceAccountName or automountServiceAccountToken: false, so each runs under the namespace's implicit default ServiceAccount with its token automounted by default — including the internet-facing web-container and the Moodle application pod (php-fpm-application) that directly processes untrusted HTTP input. No RBAC is currently bound to the default ServiceAccount in this repository, so today's exploitability is low, but this is a defense-in-depth / least-privilege gap: any future accidental binding to default (a common misconfiguration on shared clusters) would immediately expose Kubernetes API credentials to the most attacker-reachable workloads in the deployment.

6.1.1 Authorization Issue Totals by Severity

Core Area	Critical	High	Medium	Low	Total
Missing Authorization	0	0	0	0	0
Privilege Escalation	0	3	0	0	3
Authorization Bypass	0	0	0	0	0
RBAC Implementation Gaps	0	0	5	1	6
Multi-Tenancy Authorization	0	0	0	0	0
Integration & Cross-Service	0	0	0	0	0
Total	**0**	**3**	**5**	**1**	**9**

6.2 Authorization Architecture Overview

There is no centralized "authorization framework" in this repository because there is no application code in it — Moodle's capability/role system is entirely internal to the upstream Moodle codebase cloned into the php-fpm-application image and is not represented in any file under review here. Access control observed in-repo is exclusively **platform-layer**:

- **Kubernetes RBAC** (chart/psa-moodle/templates/rbac-ops.yaml): a dedicated ServiceAccount (<release>-ops), Role, and RoleBinding scope what the three Phase 6 ops CronJobs (cronjob-backup-integrity.yaml, cronjob-moodledata-snapshot.yaml, cronjob-restore-rehearsal.yaml) can do against the Kubernetes

API — read pods/logs, exec into pods, read secrets, and create/delete `PostgresCluster` and `VolumeSnapshot` objects. This is the only component in the repository with an explicit, custom RBAC policy. All other workloads (`web`, `php`, `cron`, `install`, `valkey`) run under the namespace's implicit `default` `ServiceAccount` with no custom `Role` bound to it.

- **ServiceAccount / token automount scoping**: only the ops `CronJobs` explicitly set `serviceAccountName` (to the `-ops` account, which legitimately needs Kubernetes API access). The `web-deployment.yaml`, `php-deployment.yaml`, `cron-deployment.yaml/cron-cronjob.yaml`, `job-install.yaml`, and `valkey-statefulset.yaml` pod specs set `securityContext.runAsNonRoot: true` and per-container `allowPrivilegeEscalation: false` / `capabilities.drop: [ALL]`, but none of them set `serviceAccountName` or `automountServiceAccountToken: false`, so they inherit the `default` `ServiceAccount` and its automounted token even though none of these workloads call the Kubernetes API.
- **Network-layer access control** (`chart/psa-moodle/templates/networkpolicy.yaml`): a default-deny ingress + egress `NetworkPolicy` set with an explicit, narrowly-scoped allowlist (router→web, web→php, app→valkey, app→postgres, DNS, and two justified external egress rules for OAuth2/SSO/plugin sync and SMTP alerting). This acts as a coarse-grained, workload-identity-based authorization boundary between components and is well-scoped; no issues were identified here.
- **Database-layer**: the Crunchy `PostgresCluster`'s init SQL (`postgres-init-configmap.yaml`) grants the Moodle application role ownership of the `public` schema in its own database only (`GRANT ALL ON SCHEMA public` + `ALTER SCHEMA public OWNER TO <moodle-user>`), run once at bootstrap by the Postgres superuser via the operator — this is a standard single-tenant application-schema-ownership pattern, not a broad privilege grant to the application role itself, and was not flagged as an issue.

Trust boundaries: the `web-container` is the only externally-exposed component (behind `openshift-route`); `php-fpm-application` is reachable only from `web-container`; `valkey-cache` and `postgresql-cluster` are reachable only from `php`/`cron`/`install` (and, for postgres, the ops components); the `-ops` `ServiceAccount` is the only identity in the deployment with any Kubernetes-API-level authority, and that authority is broader than its intended scope (see findings below).

6.3 Detailed Component Analysis

6.3.1 Component: Ops Tooling (`ops-tooling`)

6.3.1.1 Component Overview

Backup-integrity, moodledata-snapshot, and restore-rehearsal `CronJobs` running the Containerfile.ops image, authorized via a dedicated `Role`/`RoleBinding` in `chart/psa-`

`moodle/templates/rbac-ops.yaml`. This is the only component in the repository with custom Kubernetes RBAC.

6.3.1.2Authorization Issues

ID	Location	Component	Issue Type	Severity	Description	Impact
AUTHZ-001	`chart/psa-moodle/templates/rbac-ops.yaml` at lines 30-33	Ops Tooling	Privilege Escalation	High	The `-ops Role` grants `resources: [pods/exec], verbs: [create]` with no `resourceNames` restriction, meaning the `ServiceAccount` can exec into **any** pod in the namespace (web, php, valkey, and the Postgres primary), not only the Crunchy/rehearsal pods the comment describes as the intent ("Exec into Crunchy + Moodle pods").	A compromised `-ops ServiceAccount` token or ops container grants an attacker interactive command execution inside every workload in the namespace, equivalent to full namespace compromise.
AUTHZ-002	`chart/psa-moodle/templates/rbac-ops.yaml` at lines 34-38	Ops Tooling	Privilege Escalation	High	The `-ops Role` grants `resources: [secrets], verbs: [get, list]` with no `resourceNames` restriction, though the accompanying	Compromise of the ops workload discloses every credential in the namesp

ID	Location	Component	Issue Type	Severity	Description	Impact
					comment states the intent is only “Pull the auto-generated pguser secret”. As written, the `ServiceAccount` can read every `Secret` in the namespace (`secret-moodle.yaml`, `secret-valkey.yaml`, the Moodle admin secret, the pgBackRest repo secret, etc.), not only the `pguser` credential.	ace — Moodle admin password, Valkey auth password, database credentials for all users — not only the single secret the scripts require.
AUTHZ-003	`chart/psa-moodle/templates/rbac-ops.yaml` at lines 39-42	Ops Tooling	Privilege Escalation	High	The `-ops` `Role` grants `resources: [postgresclusters]`, `verbs: [get, list, watch, create, delete]` with no `resourceNames` restriction. The comment states the intent is “create the rehearsal clone, delete it after”, but the rule as written	A compromised or buggy ops workload could delete the production `PostgresCluster` custom resource, triggering operator

ID	Location	Component	Issue Type	Severity	Description	Impact
					also permits `delete` on the production `PostgresCluster` object itself (`chart/psa-moodle/templates/postgrescluster.yaml`), since both share the same `apiGroups`/`resources` type and no name scoping is applied.	-driven teardown of the live database cluster — a destructive availability impact, not just a rehearsal-clone risk.
AUTHZ-004	`chart/psa-moodle/templates/rbac-ops.yaml` at lines 70-94	Ops Tooling	RBAC Implementation Gaps	Low	An optional (`.Values.backup.moodledataSnapshot.clusterRoleBinding`, default `false` per `chart/psa-moodle/values.yaml` line 275) `ClusterRoleBinding` binds the `-ops` `ServiceAccount` to the built-in aggregated `ClusterRole` `system:aggregate-to-view` — a broad, cluster-wide read role covering most resource types across **all** namespaces —	If an operator enables this flag, the ops `ServiceAccount` gains read access to workloads/configuration across every namespace in the cluster, far exceeding the single cluster-

ID	Location	Component	Issue Type	Severity	Description	Impact
					solely to satisfy a narrow need (`get volumesnapshotclass <name>`, a cluster-scoped resource).	scoped resource type it actually needs; disabled by default, so current exposure is none, but the pattern is an over-permission risk if toggled on.

6.3.2 Component: Web Container (`web-container`)

6.3.2.1Component Overview

Nginx front-end (`Containerfile.web`, `chart/psa-moodle/templates/web-deployment.yaml`) — the only externally-reachable workload in the deployment (via `openshift-route`).

6.3.2.2Authorization Issues

ID	Location	Component	Issue Type	Severity	Description	Impact
AUTHZ-005	`chart/psa-moodle/templates/web-deployment.yaml` at lines 23-29	Web Container	RBAC Implementation Gaps	Medium	The pod spec sets `securityContext.runAsNonRoot: true` but does not set `serviceAccountName` or `automountServiceAccountToken: false`, so the pod runs	If the `default` `ServiceAccount` is ever bound to any `Role`/`ClusterRole` (a common

ID	Location	Component	Issue Type	Severity	Description	Impact
					under the namespace's implicit `default ServiceAccount` with its API token automounted, despite nginx never calling the Kubernetes API.	misconfiguration on shared clusters), the most attacker-reachable component in the deployment gains an unnecessary path to the Kubernetes API.

6.3.3 Component: PHP-FPM Application Container (`php-fpm-application`)

6.3.3.1 Component Overview

Runs Moodle 4.5 and its plugins under PHP-FPM (`Containerfile.php`, `chart/psa-moodle/templates/php-deployment.yaml`). Application-layer (Moodle capability/role) authorization is out of scope — no Moodle PHP source is vendored in this repository.

6.3.3.2 Authorization Issues

ID	Location	Component	Issue Type	Severity	Description	Impact
AUTHZ-006	`chart/psa-moodle/templates/php-deployment.yaml` at lines 23-29	PHP-FPM Application Container	RBAC Implementation Gaps	Medium	Same pattern as AUTHZ-005: no `serviceAccountName`/`automountServiceAccountToken: false` set, so the pod that directly	An RCE in the Moodle/PHP application layer (outside this repo's scope,

ID	Location	Component	Issue Type	Severity	Description	Impact
					executes Moodle application code processing untrusted HTTP input inherits the `default ServiceAccount`'s automounted token.	but a realistic risk class for any PHP CMS) would additionally expose a Kubernetes API token from the most code-execution-exposed component in the deployment.

6.3.4 Component: Cron Workload (`cron-workload`)

6.3.4.1 Component Overview

Runs Moodle's scheduled-task runner (`admin/cli/cron.php`) as a long-running `Deployment` loop by default, with a `CronJob` fallback mode (`chart/psa-moodle/templates/cron-deployment.yaml`, `cron-cronjob.yaml`).

6.3.4.2 Authorization Issues

ID	Location	Component	Issue Type	Severity	Description	Impact
AUTHZ-007	`chart/psa-moodle/templates/cron-deployment.yaml` at lines 36-41	Cron Workload	RBAC Implementation Gaps	Medium	Same pattern as AUTHZ-005/006: no `serviceAccountName`/`automountServiceAccountToken: false` set on	Widens the set of workloads that would be affected

ID	Location	Component	Issue Type	Severity	Description	Impact
					the cron pod spec, so it inherits the `default ServiceAccount`'s automounted token despite calling only `php` and never the Kubernetes API.	if the `default ServiceAccount` were ever granted permissions; the cron loop executes the same Moodle codebase as `php-fpm-application` on a recurring, unattended schedule.

6.3.5 Component: Install Job (`install-job`)

6.3.5.1 Component Overview

One-shot Helm post-install `Job` that bootstraps the Moodle database (`chart/psa-moodle/templates/job-install.yaml`).

6.3.5.2 Authorization Issues

ID	Location	Component	Issue Type	Severity	Description	Impact
AUTHZ-008	`chart/psa-moodle/templates/job-install.yaml` at lines	Install Job	RBAC Implementation Gaps	Medium	Same pattern as the above: no `serviceAccountName`/`automountServiceAccountToken:`	Combines with credential handling (Moodle

ID	Location	Component	Issue Type	Severity	Description	Impact
	29-35				`false` set on the install Job's pod spec (or its `wait-for-db` initContainer), so the pod that handles `MOODLE_ADMIN_PASS` and database credentials via env vars also inherits the `default ServiceAccount`'s automounted token.	admin password, DB password) in the same pod; unnecessary API token exposure adds an additional artifact an attacker with pod access could exfiltrate.

6.3.6 Component: PostgreSQL Cluster (`postgresql-cluster`)

6.3.6.1 Component Overview

Operator-managed relational datastore (`chart/psa-moodle/templates/postgrescluster.yaml`, `postgres-init-configmap.yaml`). RBAC for the operator itself is managed by the Crunchy PostgreSQL Operator outside this chart.

6.3.6.2 Authorization Issues

No authorization issues identified. The chart-managed init SQL (`postgres-init-configmap.yaml`) grants the Moodle application role ownership of the `public` schema in its own database only — a standard single-tenant application-schema pattern, not a broad or cross-tenant privilege grant. Access to this component from other pods is controlled by `network-policy` (reviewed separately) rather than database-layer authorization defined in this repo.

6.3.7 Component: Valkey Cache (`valkey-cache`)

6.3.7.1Component Overview

Single-replica Redis-compatible session/cache store (`chart/psa-moodle/templates/valkey-statefulset.yaml`), authenticated via a `requirepass` secret.

6.3.7.2Authorization Issues

ID	Location	Component	Issue Type	Severity	Description	Impact
AUTHZ-009	`chart/psa-moodle/templates/valkey-statefulset.yaml` at lines 26-31	Valkey Cache	RBAC Implementation Gaps	Medium	Same pattern as the above: no `serviceAccountName`/`automountServiceAccountToken: false` set on the Valkey `StatefulSet` pod spec, so the pod inherits the `default` `ServiceAccount`'s automounted token despite Valkey never calling the Kubernetes API.	Consistent with the other components — unnecessary Kubernetes API credential exposure on a workload with no legitimate need for it.

6.3.8 Component: Moodledata Shared Storage (`moodledata-storage`)

6.3.8.1Component Overview

`ReadWriteMany` PVC shared by `php` and `cron` (`chart/psa-moodle/templates/moodledata-pvc.yaml`).

6.3.8.2Authorization Issues

No authorization issues identified. This is a storage object with no independent identity or RBAC surface of its own; access is governed by which pods mount the PVC (`php-fpm-application`, `cron-workload`), which are reviewed under their own components.

6.3.9 Component: NetworkPolicy Boundary (`network-policy`)

6.3.9.1Component Overview

Default-deny ingress/egress `NetworkPolicy` set with an explicit allowlist (`chart/psa-moodle/templates/networkpolicy.yaml`).

6.3.9.2Authorization Issues

No authorization issues identified. The policy set is default-deny for both directions with narrowly-scoped, component-labeled allow rules for every legitimate flow (router→web, web→php, app→valkey, app→postgres, DNS, and two justified external egress rules). The two external-egress CIDRs (`externalHttpsCidr`/`externalSmtpCidr`, both `0.0.0.0/0` by default per `chart/psa-moodle/values.yaml` lines 200-206) are broad, but this is a network-egress-destination concern (not an authorization/access-control gap) and is explicitly documented in-file as a known Kubernetes `NetworkPolicy` limitation (no FQDN allowlisting) with a suggested OpenShift `EgressFirewall` mitigation path — out of scope for this domain.

6.3.10 Component: OpenShift Route (`openshift-route`)

6.3.10.1 Component Overview

TLS-edge-terminated ingress exposing `web-container` (`chart/psa-moodle/templates/route.yaml`).

6.3.10.2 Authorization Issues

No authorization issues identified. The `Route` object itself carries no authorization logic; access control at this boundary is enforced by `network-policy`'s router→web allow rule.

6.3.11 Component: Helm Chart / Deployment Topology (`helm-chart-topology`)

6.3.11.1 Component Overview

Chart scaffolding, per-environment values, and helpers (`Chart.yaml`, `values*.yaml`, `_helpers.tpl`, `hpa.yaml`, `poddisruptionbudget.yaml`).

6.3.11.2 Authorization Issues

No authorization issues identified. `_helpers.tpl` defines no `serviceAccountName` helper (confirmed via search), which is consistent with AUTHZ-005 through AUTHZ-009. `hpa.yaml` and `poddisruptionbudget.yaml` carry no access-control logic.

6.3.12 Component: Monitoring and Observability (`monitoring-observability`)

6.3.12.1 Component Overview

OpenShift user-workload-monitoring wiring (`chart/psa-moodle/templates/monitoring.yaml`) — `NetworkPolicy`, `PodMonitor`, `ServiceMonitor`, `PrometheusRule`.

6.3.12.2 Authorization Issues

No authorization issues identified. This template defines no `ServiceAccount`, `Role`, or `RoleBinding` of its own; the metrics-scraping `NetworkPolicy` it creates is scoped to the `openshift-user-workload-monitoring` namespace only, consistent with least-privilege network access.

6.3.13 Component: CI/CD Pipeline (`cicd-pipeline`)

6.3.13.1 Component Overview

GitHub Actions workflows and `Makefile` (not reviewed in detail — outside primary authorization focus per assessment scope, and workflow files were not present under `.github/workflows/` in the reviewed tree).

6.3.13.2 Authorization Issues

No authorization issues identified within the scope reviewed. No Kubernetes RBAC or service-account artifacts are defined by this component.

6.3.14 Component: Local Dev Compose Stack (`local-dev-compose`)

6.3.14.1 Component Overview

Podman Compose stack (`compose.yaml`, `compose.registry.yaml`) reproducing the topology for local development.

6.3.14.2 Authorization Issues

No authorization issues identified. Podman Compose has no RBAC concept; this component is out of scope for Kubernetes-style authorization analysis, and no credentials or access-control configuration specific to authorization were observed.

6.3.15 Component: Documentation & Runbooks (`documentation-runbooks`)

6.3.15.1 Component Overview

Project documentation and phase write-ups (`docs/*.md`, `README.md`).

6.3.15.2 Authorization Issues

No authorization issues identified. Documentation contains no executable authorization logic or access-control configuration.

6.4 Cross-Component Authorization Gaps

- **Namespace-wide default `ServiceAccount` automount across five workloads (`web-container`, `php-fpm-application`, `cron-workload`, `install-job`, `valkey-cache` — AUTHZ-005 through AUTHZ-009):** this is the same root cause repeated identically across every non-ops Deployment/StatefulSet/Job template in the chart — none of them was ever given an explicit, minimal `ServiceAccount`. It is not that authorization is enforced inconsistently between these components; rather, none of them enforce any Kubernetes-API-level authorization decision at all, relying entirely on the (currently empty) permission set of the `default` `ServiceAccount`. Because this pattern spans the entire chart rather than one template, a single fix (adding `automountServiceAccountToken: false` to the shared `psa-moodle.selectorLabels`/pod-spec helper pattern, or to each pod spec individually) would close all five findings at once — see `docs/phase4-hardening.md` for related hardening context.
- **Ops `ServiceAccount` is the sole privileged identity, and its `Role` is broader than any of its three consuming `CronJobs` individually need:** `cronjob-backup-integrity.yaml`, `cronjob-moodledata-snapshot.yaml`, and `cronjob-restore-rehearsal.yaml` all share the single `-ops` `ServiceAccount`/`Role` (AUTHZ-001 through AUTHZ-003), even though each `CronJob` exercises only a subset of the granted verbs (e.g., `backup-integrity.sh` does not need `postgresclusters: create/delete`, which only `restore-rehearsal.sh` uses). A single compromised CronJob's container — regardless of which of the three it is — inherits the full union of permissions needed by all three, rather than only the permissions its own script requires. Splitting into per-CronJob `ServiceAccount`/`Role` pairs, and adding `resourceNames` scoping to the `pods/exec` and `secrets` rules, would substantially reduce blast radius without any of the three CronJobs' own analysis identifying an authorization requirement met by the current broad grant.
- **No component in this repository implements or is expected to implement application-level authorization:** because Moodle's role/capability engine lives entirely upstream (cloned at build time, not vendored in this repo), no cross-component authorization inconsistency of the IDOR/RBAC-bypass kind (as seen in typical multi-service application repos) could be assessed here. This is a deliberate scope boundary, not a gap in this analysis.

6.5 Severity Assignment Methodology

- **High (AUTHZ-001, AUTHZ-002, AUTHZ-003 — RBAC over-permission on the `-ops` `Role`):** These three findings share the same underlying pattern — a Kubernetes RBAC `Role` grants a powerful verb (`pods/exec: create`, `secrets: get/list`, or `postgresclusters: create/delete`) across an entire resource *type* in the namespace with no `resourceNames` restriction, when the accompanying in-file comments make clear the actual operational need is limited to a specific pod, a specific secret, or a specific (rehearsal-clone) `PostgresCluster` object. This is assigned High rather than Critical because exploitation requires an attacker to first

gain control of the ops workload or its `ServiceAccount` token (there is no direct, unauthenticated, internet-reachable path to these permissions) — but once that initial foothold exists, the lack of `resourceNames` scoping converts a narrowly-scoped operational task-runner into a namespace-wide privilege-escalation vector: `pods/exec` on any pod is equivalent to arbitrary code execution in every workload (web, php, valkey, postgres), unscoped `secrets` read discloses every credential in the namespace, and unscoped `postgresclusters` delete permits destroying the production database cluster object, not merely the intended rehearsal clone. This matches the "RBAC over-permission / God-role" pattern that the authorization analysis skill classifies as `privilege-escalation` (CWE-250), and the potential for full-namespace compromise from a single over-permissioned credential is what keeps it at High rather than Medium.

- **Low (AUTHZ-004 — optional `ClusterRoleBinding` to `system:aggregate-to-view`):** Assigned Low rather than High because the binding is explicitly gated behind a Helm value (`backup.moodledataSnapshot.clusterRoleBinding`) that defaults to `false`, is well-documented in-file as opt-in and requiring cluster-admin action to enable, and the in-repo default deployment therefore carries zero exposure from this rule today. It is recorded as a finding (rather than omitted) because the pattern — binding a broad, built-in aggregated ClusterRole to satisfy a single narrow, cluster-scoped read need — would itself become a meaningful over-permission issue the moment an operator sets the flag to `true`, and no narrower custom `ClusterRole` was defined as an alternative.
- **Medium (AUTHZ-005 through AUTHZ-009 — missing `automountServiceAccountToken: false` on non-ops workloads):** Assigned Medium rather than Low or High because this is a "missing security control without an observed exploit path" pattern per the severity baseline rubric: no `Role`/`ClusterRole` is currently bound to the `default` `ServiceAccount` anywhere in this repository, so there is no confirmed way to weaponize the automounted token today. However, unlike a purely cosmetic hardening gap, this specific control governs direct Kubernetes API credential exposure to the most attacker-reachable workloads in the entire deployment — `web-container` (internet-facing) and `php-fpm-application` (executes untrusted-input-driven application code) chief among them — and the risk of a future accidental `default-ServiceAccount` binding (a well-documented, common multi-tenant-cluster misconfiguration class) is materially higher-consequence than a typical missing-header finding, which is why it is held above Low. It is not rated High because it requires two independent conditions to be jointly true (workload compromise *and* a future/undiscovered `default-ServiceAccount` RBAC grant) rather than a single confirmed exploitable condition.

---

7 Code Vulnerabilities Analysis

7.1 Executive Summary

psa-moodle is an infrastructure/config-heavy repository: the actual Moodle 4.5 PHP application, its plugins, and its theme are cloned from upstream Git repositories at container **build time** (see `Containerfile.php`) and are not committed to this repository. Consequently there is **no traditional first-party application source code** (controllers, forms, data-access layers, templates) in scope for this assessment — the classic OWASP code-level vulnerability classes that require application code to inspect (SQL Injection, XSS, CSRF, XXE, insecure deserialization) have **no first-party code surface to test** and are recorded as zero across all four categories in the table below. This absence claim is based on an exhaustive review of every non-vendored, non-generated file in the repository (68 files / ~4,800 lines per the architecture inventory): the four `config/` subtrees (`moodle`, `nginx`, `php`, `valkey`), the five `scripts/ops/*.sh` operational scripts, the Helm chart templates, and the two Containerfiles that reference PHP/shell logic directly. No `.php` file other than the two Moodle `config.php` variants exists in the repository; no other file contains PHP, JavaScript, Python, Java, or SQL application logic that accepts external/attacker-controlled input.

Given this, the analysis instead applied OWASP Top 10 categories that are meaningful for shell scripts and configuration artifacts — principally **A05:2021 Security Misconfiguration** (world-writable directory permissions, missing hardening directives, version/banner disclosure) and **A03:2021 Injection** in its generalized form (unsanitized interpolation of environment-derived values into generated Kubernetes/YAML manifests that are subsequently applied to the cluster). Eight findings were identified, none rated Critical or High or (after reverse-validation) Medium: all eight are Low-severity (a world-writable Moodle data-directory permission mask baked into the environment configuration actually used by the deployed OpenShift environments — VULN-001, corrected from Medium to Low during reverse-validation since it is a deployment-time filesystem permission on an internal shared PVC rather than a directly reachable remote exploit — plus a matching but lower-risk dev-only permission mask, missing PHP/nginx version-disclosure hardening, absence of a `disable_functions` allowlist in `php.ini`, missing HTTP security response headers in the nginx server block, and two instances of operator-controlled environment variables being interpolated unsanitized into heredoc-generated Kubernetes manifests piped to `oc apply -f -`). All findings are configuration/hardening gaps rather than directly exploitable application-layer flaws; none currently has a confirmed externally-reachable attacker-controlled taint source, which keeps overall severity low. The most consequential item from a business-impact perspective is the world-writable `moodledata` permission mask (`config/moodle/config.openshift.php`, VULN-001), because `moodledata` is a `ReadWriteMany` PVC shared between the PHP-FPM and cron pods — a permission weakness there has the broadest (if still contained) blast radius of anything found, even though its severity is Low.

7.1.1 Code Vulnerability Totals by Severity

Vulnerability Type	Critical	High	Medium	Low	Total
SQL Injection	0	0	0	0	0
XXE	0	0	0	0	0
XSS	0	0	0	0	0
CSRF	0	0	0	0	0
Security Misconfiguration (permissions / hardening)	0	0	0	4	4
Information Disclosure (version/banner leakage)	0	0	0	2	2
Unsanitized Input into Generated Manifests	0	0	0	2	2
Total	**0**	**0**	**0**	**8**	**8**

7.2 Detailed Component Analysis

7.2.1 Component: PHP-FPM Application Container

7.2.1.1Component Overview

Runs the Moodle 4.5 application code (vendored at build time, out of scope) plus the two first-party artifacts that configure it: `config/moodle/config.local.php` (Podman Compose dev) and `config/moodle/config.openshift.php` (Helm/OpenShift dev-test), and the two PHP runtime tuning files `config/php/php.ini` and `config/php/php-fpm.conf`.

7.2.1.2Component File Coverage

File Category	Files Analyzed	Files with Vulnerabilities	Percentage of Component
Entry Points	0	0	n/a
Data Access	2	2	100%
Business Logic	0	0	n/a
UI/Templates	0	0	n/a
Utilities	2	1	50%
Total	4	3	75%

7.2.1.3Vulnerabilities

ID	Location	Component	Issue Type	Severity	Description	Impact
VULN- -	`./config/moodle/config.openshift.php`	PHP-FPM Application Container	Security Misconfiguration	Low	`$CFG->directorypermissions` set to `02777` (world-	Any process able to

ID	Location	Component	Issue Type	Severity	Description	Impact
001	at line 32				writable + setgid) for the live OpenShift dev/test config	write to the shared `moodledata` PVC can create world-writable subdirectories, weakening isolation between the php and cron pods that mount it
VULN-004	`./config/php/php.ini` (whole file, 38 lines)	PHP-FPM Application Container	Security Misconfiguration	Low	No `disable_functions` directive restricts dangerous PHP functions (`exec`, `shell_exec`, `system`, `passthru`, `proc_open`, `popen`)	If any plugin/theme code path (in-scope or future) contains a command-injection flaw, there is no secondary PHP-level control to contain

ID	Location	Component	Issue Type	Severity	Description	Impact
						it
VULN-002	`./config/moodle/config.local.php` at line 30	PHP-FPM Application Container	Security Misconfiguration	Low	`$CFG->directorypermissions` set to `0777` (world-writable) for the local Podman Compose dev config	Same permission weakness as VULN-001 but explicitly scoped to local development only per the file's own header comment
VULN-003	`./config/php/php.ini` at lines 13-18	PHP-FPM Application Container	Information Disclosure	Low	`expose_php` is not set (defaults to `On`), so PHP version is disclosed via the `X-Powered-By` response header	Discloses the exact PHP runtime version to any client, aiding vulnerability targeting/fingerprinting

7.2.1.3.1 Detailed Finding: VULN-001

Issue ID: VULN-001 **Location**: `./config/moodle/config.openshift.php` at line 32 **Component**: PHP-FPM Application Container **Issue Type**: Security Misconfiguration (Insecure Directory Permissions, CWE-732) **Severity**: Low *(corrected from Medium during reverse-validation — see Limitations/assessment-validation.md: this is a deployment-time filesystem permission on an internal shared PVC, not a directly reachable remote exploit)*

Evidence:

```
// --- Site URLs and paths ---
$CFG->wwwroot   = getenv('MOODLE_WWWROOT');    // https://psa-moodle-dev.apps.
silver.devops.gov.bc.ca
$CFG->dataroot = '/var/www/moodledata';        // RWX PVC, netapp-file-standar
d
$CFG->admin    = 'admin';
$CFG->directorypermissions = 02777;
```

Description: This is the `config.php` variant baked into images deployed via the Helm chart to the actual dev/test OpenShift namespaces (per the file's own header comment: "Moodle config for OpenShift deployment (dev/test)"). Moodle uses `$CFG->directorypermissions` as the `mkdir()`/`chmod()` mode whenever it creates new subdirectories under `dataroot` (`/var/www/moodledata`, a `ReadWriteMany` PVC mounted by both the PHP-FPM and cron pods per the architecture inventory). `02777` sets read/write/execute for owner, group, and world, plus the setgid bit — the most permissive mode Moodle supports for this setting.

Impact: Any process able to write into the shared `moodledata` volume (including the cron pod, or any other workload that might ever mount the same PVC) can create or modify files in these directories regardless of Unix ownership, and new subdirectories inherit the setgid bit. This does not by itself grant remote code execution, but it removes filesystem-level containment between the two pods that share the volume and is a straightforward violation of least-privilege file permissions in the environment that is actually running (as opposed to disposable local dev). No mitigating control (e.g., a more restrictive `umask`, a PodSecurityContext `fsGroup` override, or an explicit narrower `directorypermissions` value) was found in the reviewed files.

Related Findings: - VULN-002: identical misconfiguration pattern (`0777`) in the local-dev-only config variant, at lower severity because it is explicitly out of scope for OpenShift per the source comment.

7.2.1.3.2 Detailed Finding: VULN-002

Issue ID: VULN-002 **Location**: `./config/moodle/config.local.php` at line 30 **Component**: PHP-FPM Application Container **Issue Type**: Security Misconfiguration (Insecure Directory Permissions, CWE-732) **Severity**: Low

Evidence:

```
// --- Site URLs and paths ---
$CFG->wwwroot    = getenv('MOODLE_WWWROOT') ?: 'http://localhost:8080';
$CFG->dataroot   = '/var/www/moodledata';
$CFG->admin      = 'admin';
$CFG->directorypermissions = 0777;
```

Description: Same weakness class as VULN-001 (`$CFG->directorypermissions` set to a world-writable mode), but in the config variant the file's own header comment states is "for

local Podman compose development" and that "All credentials here are LOCAL DEV ONLY — never used in OpenShift." This significantly narrows the exploitable population to a developer's local Compose stack rather than a shared multi-tenant cluster environment.

Impact: Reduced impact relative to VULN-001 because the file is explicitly scoped to disposable local development containers, but the pattern itself is still a security-by-convention rather than security-by-design choice that could be copy-pasted forward into a future production variant.

Related Findings: - VULN-001: the OpenShift-deployed counterpart of this same misconfiguration, at higher severity.

7.2.1.3.3 Detailed Finding: VULN-003

Issue ID: VULN-003 **Location**: `./config/php/php.ini` at lines 13-18 **Component**: PHP-FPM Application Container **Issue Type**: Information Disclosure (CWE-200 / Version Banner Exposure) **Severity**: Low

Evidence:

```
; --- Errors / logging ---
; Production-safe defaults; override locally via compose env if needed for de
v.
display_errors = Off
display_startup_errors = Off
log_errors = On
error_log = /dev/stderr
```

Description: Absence claim: `config/php/php.ini` (38 lines total) was read in full and searched for the literal strings `expose_php`, `disable_functions`, and `allow_url_include` — zero matches for all three. `display_errors/display_startup_errors` are correctly disabled (good practice, confirmed at lines 15-16), but `expose_php` is never set, so PHP's compiled-in default of `On` applies, causing PHP-FPM to advertise `X-Powered-By: PHP/8.3.x` on every response (nginx passes FastCGI response headers through unmodified; no `fastcgi_hide_header` directive was found in `config/nginx/default.conf`).

Impact: Discloses the exact PHP runtime version to any anonymous client, which aids an attacker fingerprinting the stack to select version-specific exploits. This is a minor information-disclosure hardening gap, not directly exploitable on its own.

Related Findings: - VULN-005: the analogous nginx `Server` header version-disclosure gap in the Web Container component.

7.2.1.3.4 Detailed Finding: VULN-004

Issue ID: VULN-004 **Location**: `./config/php/php.ini` (whole file, 38 lines) **Component**: PHP-FPM Application Container **Issue Type**: Security Misconfiguration (Missing `disable_functions` Hardening) **Severity**: Low

Evidence:

```
; Moodle-tuned php.ini overlay.
; Loaded as /usr/local/etc/php/conf.d/moodle-php.ini (highest precedence).

; --- Resource limits ---
memory_limit = 512M
max_execution_time = 900
max_input_time = 900
max_input_vars = 5000
post_max_size = 256M
upload_max_filesize = 256M
default_socket_timeout = 900
```

Description: Absence claim: the full 38-line file was reviewed; no `disable_functions` directive is present anywhere in the file, and no other `.ini` file under `config/php/` was found (`file_search` on `config/php/*.ini` and `*.conf` returned only `php.ini` and `php-fpm.conf`). PHP's default `disable_functions` value ships empty, so `exec()`, `shell_exec()`, `system()`, `passthru()`, `proc_open()`, and `popen()` all remain callable from any PHP code executed by this pool, including third-party plugins/themes cloned in at build time (`mod/hvp`, `blocks/course_search`, `local/githubsync`, `local/psaelmsync`, `mod/pathcurator`, `theme/bcgovpsa` — see `Containerfile.php`).

Impact: This is a defense-in-depth gap rather than a directly exploitable flaw by itself — no source-level command-injection sink was found in the (out-of-scope, vendored) plugin code during this review. Should a command-injection vulnerability ever be introduced or discovered in any first- or third-party plugin, there is currently no PHP-level function allowlist acting as a secondary containment control.

Related Findings: none.

7.2.1.4Files Analyzed with No Vulnerabilities Found

- `./config/php/php-fpm.conf` — pool correctly named `[www]`; `pm.status_path`/`ping.path` are FPM-internal endpoints not exposed by any `location` block in `config/nginx/default.conf`, so they are not reachable over HTTP; `access.log = /dev/null` and audit-logging posture are in scope for the security-logging domain, not code-vulnerabilities.

7.2.2 Component: Web Container (nginx)

7.2.2.1Component Overview

Immutable nginx front-end (`config/nginx/default.conf`) serving static assets and proxying `.php` requests to the PHP-FPM Application Container over FastCGI.

7.2.2.2Component File Coverage

File Category	Files Analyzed	Files with Vulnerabilities	Percentage of Component

File Category	Files Analyzed	Files with Vulnerabilities	Percentage of Component
Entry Points	1	1	100%
Data Access	0	0	n/a
Business Logic	0	0	n/a
UI/Templates	0	0	n/a
Utilities	0	0	n/a
Total	1	1	100%

7.2.2.3Vulnerabilities

ID	Location	Component	Issue Type	Severity	Description	Impact
VULN-005	`./config/nginx/default.conf` at lines 10-13	Web Container (nginx)	Information Disclosure	Low	No `server_tokens off;` directive — nginx version is disclosed in the `Server` response header and on any default error page	Discloses the exact nginx build to any anonymous client, aiding stack fingerprinting
VULN-006	`./config/nginx/default.conf` at lines 10-70	Web Container (nginx)	Security Misconfiguration	Low	No `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, or `Strict-Transport-Security` response headers are added anywhere in the server block	Absence of defense-in-depth browser-security headers increases the blast radius of any future stored-XSS or clickjac

ID	Location	Component	Issue Type	Severity	Description	Impact
						king vector introduced by a Moodle plugin/theme

7.2.2.3.1 Detailed Finding: VULN-005

Issue ID: VULN-005 **Location**: `./config/nginx/default.conf` at lines 10-13 **Component**: Web Container (nginx) **Issue Type**: Information Disclosure (CWE-200 / Version Banner Exposure) **Severity**: Low

Evidence:

```
server {
    listen       8080 default_server;
    listen  [::]:8080 default_server;
    server_name  _;
```

Description: Absence claim: the entire 70-line `config/nginx/default.conf` was read and searched for the literal string `server_tokens` — zero matches. The base image is `nginxinc/nginx-unprivileged:1.27-alpine` (per `Containerfile.web`); nginx's compiled-in default for `server_tokens` is on, so the `Server: nginx/1.27.x` header is emitted on every response and the version number is also rendered on nginx's default error pages, unless overridden by a directive not present anywhere in this repository's nginx configuration.

Impact: Discloses the exact nginx version to any anonymous client. Minor information-disclosure/fingerprinting aid; not independently exploitable.

Related Findings: - VULN-003: the analogous PHP `X-Powered-By` version-disclosure gap in the PHP-FPM Application Container component.

7.2.2.3.2 Detailed Finding: VULN-006

Issue ID: VULN-006 **Location**: `./config/nginx/default.conf` at lines 10-70 **Component**: Web Container (nginx) **Issue Type**: Security Misconfiguration (Missing HTTP Security Headers) **Severity**: Low

Evidence:

```
    location = /health {
        access_log off;
        return 200 "ok\n";
        add_header Content-Type text/plain;
```

```
    }
}
```

Description: Absence claim: the full server block (lines 10-70, the only `server {}` block in the file) was searched for `add_header` directives — the only match is the single `Content-Type text/plain` header on the `/health` endpoint (shown above). No `add_header` for `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, or `Strict-Transport-Security` exists anywhere in the file, and none of these are set via any other reviewed layer (no separate `nginx.conf` override was found in the repository — `file_search` for `**/nginx*.conf` returned only this `default.conf`).

Impact: This is a defense-in-depth gap. In isolation it does not grant an attacker anything, but it removes browser-enforced mitigations (clickjacking protection via `X-Frame-Options`, MIME-sniffing protection via `X-Content-Type-Options`, script-source restriction via CSP) that would otherwise reduce the impact of any future stored-XSS or embedding vulnerability surfaced by Moodle core or one of the vendored third-party plugins/themes.

Related Findings: none.

7.2.3 Component: Ops Tooling

7.2.3.1Component Overview

Backup-integrity, moodledata-snapshot, and restore-rehearsal CronJob scripts (`scripts/ops/*.sh`) plus the shared `alert.sh` mailer, all running inside the `psa-moodle-ops` image with oc cluster-admin-scoped RBAC (per `chart/psa-moodle/templates/rbac-ops.yaml`).

7.2.3.2Component File Coverage

File Category	Files Analyzed	Files with Vulnerabilities	Percentage of Component
Entry Points	0	0	n/a
Data Access	0	0	n/a
Business Logic	0	0	n/a
UI/Templates	0	0	n/a
Utilities	5	2	40%
Total	5	2	40%

7.2.3.3Vulnerabilities

ID	Location	Component	Issue Type	Severity	Description	Impact
VULN-00	`./scripts/ops/moodledata-snapshot.sh` at lines	Ops Tooling	Unsanitized Input into Generated Manifest	Low	`$SOURCE_PVC` and `$SNAPSHOT_CLASS` env vars are	If either variable were ever

ID	Location	Component	Issue Type	Severity	Description	Impact
7	26-38				interpolated unsanitized into a heredoc YAML manifest piped straight to `oc apply -f -`	attacker-influenced, arbitrary additional YAML fields/keys could be injected into the applied `VolumeSnapshot` object
VULN-008	`./scripts/ops/restore-rehearsal.sh` at lines 47-68	Ops Tooling	Unsanitized Input into Generated Manifest	Low	`$POSTGRES_CLUSTER` and `$POSTGRES_VERSION` env vars are interpolated unsanitized into a heredoc `PostgresCluster` CR piped straight to `oc apply -f -`	Same class of risk as VULN-007, against a `PostgresCluster` custom resource instead of a `VolumeSnapshot`

7.2.3.3.1 Detailed Finding: VULN-007

Issue ID: VULN-007 **Location**: `./scripts/ops/moodledata-snapshot.sh` at lines 26-38 **Component**: Ops Tooling **Issue Type**: Unsanitized Input into Generated Manifest (Injection, generalized) **Severity**: Low

Evidence:

```
log "Creating VolumeSnapshot $SNAP_NAME for PVC $SOURCE_PVC"
cat <<EOF | oc -n "$TARGET_NAMESPACE" apply -f -
apiVersion: snapshot.storage.k8s.io/v1
```

```
kind: VolumeSnapshot
metadata:
  name: $SNAP_NAME
  labels:
    app.kubernetes.io/instance: psa-moodle
    app.kubernetes.io/component: moodledata-snapshot
    psa-moodle/source-pvc: $SOURCE_PVC
spec:
  volumeSnapshotClassName: $SNAPSHOT_CLASS
  source:
    persistentVolumeClaimName: $SOURCE_PVC
EOF
```

Description: Taint-path analysis: **Source** — `SOURCE_PVC` and `SNAPSHOT_CLASS` are read from the process environment via the `: "${SOURCE_PVC:?...}"` guard at the top of the script (lines 10-12); they are not sanitized, quoted-and-escaped for YAML, or validated against an allowlist anywhere in the script before use. **Propagation** — the values flow directly from the environment into the unquoted heredoc body (bash performs variable expansion inside `<<EOF ... EOF` heredocs by default) with no intermediate transformation. **Sink** — the expanded heredoc is piped directly into `oc -n "$TARGET_NAMESPACE" apply -f -` at line 27, which parses it as a Kubernetes YAML manifest and applies it to the cluster with the ops ServiceAccount's RBAC permissions (`chart/psa-moodle/templates/rbac-ops.yaml`, not reviewed in this pass).

Mitigating control check (per the mitigating-control-analysis discipline): both variables are declared as required environment variables (`:?` guard), which in this deployment are populated by the CronJob spec generated from Helm chart values (`chart/psa-moodle/templates/cronjob-moodledata-snapshot.yaml`) — i.e., they are operator/cluster-admin-controlled configuration inputs, not externally or user-reachable request data. No evidence was found of any code path that lets an external, lower-privileged actor influence `SOURCE_PVC` or `SNAPSHOT_CLASS` at runtime. This fully accounts for the Low (rather than High) severity: the injection mechanism is real and unmitigated at the shell-script level, but the practical attacker who could exploit it would already need write access to Helm chart values or the CronJob spec, which is an equivalent or higher privilege level than what could be gained by the injection itself.

Impact: If an attacker ever gained the ability to influence `SOURCE_PVC` or `SNAPSHOT_CLASS` (e.g., a compromised values file, a supply-chain change to the Helm chart, or a future refactor that sources these from a less-trusted input), a value containing a literal newline and additional YAML keys could inject arbitrary fields into the applied `VolumeSnapshot` object, potentially altering `metadata.namespace`, adding unexpected annotations, or otherwise manipulating the manifest beyond its intended shape.

Related Findings: - VULN-008: the identical unsanitized-interpolation-into-heredoc pattern in `restore-rehearsal.sh`.

7.2.3.3.2 Detailed Finding: VULN-008

Issue ID: VULN-008 **Location**: `./scripts/ops/restore-rehearsal.sh` at lines 47-68 **Component**: Ops Tooling **Issue Type**: Unsanitized Input into Generated Manifest (Injection, generalized) **Severity**: Low

Evidence:

```
cat <<EOF | tee -a "$LOGFILE" | oc -n "$TARGET_NAMESPACE" apply -f -
apiVersion: postgres-operator.crunchydata.com/v1beta1
kind: PostgresCluster
metadata:
  name: $REHEARSAL_NAME
  labels:
    app.kubernetes.io/instance: psa-moodle
    app.kubernetes.io/component: postgres-rehearsal
    psa-moodle/ephemeral: "true"
spec:
  postgresVersion: $POSTGRES_VERSION
  # Restore from the live cluster's pgBackRest repo.
  dataSource:
    postgresCluster:
      clusterName: $POSTGRES_CLUSTER
      repoName: repo1
```

Description: Taint-path analysis: **Source** — `POSTGRES_CLUSTER` and `POSTGRES_VERSION` are read from the process environment via `: "${POSTGRES_CLUSTER:?...}"` / `: "${POSTGRES_VERSION:?...}"` guards (lines 17-20); `REHEARSAL_NAME` is derived from `POSTGRES_CLUSTER` at line 22 (`"${POSTGRES_CLUSTER}-rehearsal"`). None of these are sanitized before use. **Propagation** — direct heredoc variable expansion, identical mechanism to VULN-007, with no intermediate validation. **Sink** — `oc -n "$TARGET_NAMESPACE" apply -f -` at line 47 applies the expanded manifest as a `PostgresCluster` custom resource with the ops ServiceAccount's RBAC.

Mitigating control check: identical to VULN-007 — `POSTGRES_CLUSTER` and `POSTGRES_VERSION` are populated by the CronJob spec from Helm chart values (`chart/psa-moodle/templates/cronjob-restore-rehearsal.yaml`, not reviewed in this pass), i.e., operator-controlled configuration rather than externally reachable input. This keeps severity at Low.

Impact: Same risk class as VULN-007, but against a `PostgresCluster` CR that triggers a live database restore from the pgBackRest repository — a successful manifest-injection in this sink could have a higher operational blast radius (interacting with live backup/restore infrastructure) if the mitigating operator-only-input condition were ever violated.

Related Findings: - VULN-007: the identical pattern in `moodledata-snapshot.sh`.

7.2.3.4Files Analyzed with No Vulnerabilities Found

- `./scripts/ops/alert.sh` — `$ALERT_TO` is split and each recipient is trimmed and passed to `swaks --to` fully quoted (`"$to_trimmed"`); `$SUBJECT`/`$BODY` are consistently double-quoted at every call site; no unquoted variable expansion or word-splitting risk found.
- `./scripts/ops/backup-integrity.sh` — DB credentials are read via `oc get secret ... -o jsonpath` + `base64 -d` into `PGPASSWORD` (exported, not passed as a CLI argument, avoiding process-list exposure); all `psql_q` invocations interpolate only fixed, hardcoded table names from the `REQUIRED_TABLES`/`NONZERO_TABLES` arrays, never external input; `LOGFILE` is created via `mktemp` with a `trap ... EXIT` cleanup, avoiding predictable-temp-file races.
- `./scripts/ops/moodledata-snapshot-prune.sh` — `$name` used in `oc ... delete volumesnapshot "$name"` is consistently double-quoted and sourced from `oc get volumesnapshot -o jsonpath`, a Kubernetes-generated object name, not external input.

7.2.4 Component: Cron Workload

7.2.4.1Component Overview

Executes Moodle's scheduled-task runner (`admin/cli/cron.php`) either as a long-running Deployment loop (`cron-deployment.yaml`, default mode) or as a Kubernetes CronJob (`cron-cronjob.yaml`, fallback mode).

7.2.4.2Component File Coverage

File Category	Files Analyzed	Files with Vulnerabilities	Percentage of Component
Entry Points	0	0	n/a
Data Access	0	0	n/a
Business Logic	0	0	n/a
UI/Templates	0	0	n/a
Utilities	2	0	0%
Total	2	0	0%

7.2.4.3Vulnerabilities

None found.

7.2.4.4Files Analyzed with No Vulnerabilities Found

- `./chart/psa-moodle/templates/cron-deployment.yaml` — the inline shell loop invokes a hardcoded command (`php /var/www/html/admin/cli/cron.php`); the only variable expansion (`${CRON_INTERVAL}`) comes from a Helm-templated numeric value passed straight to `sleep`, not from external input.

- `./chart/psa-moodle/templates/cron-cronjob.yaml` — `command: ["php", "/var/www/html/admin/cli/cron.php"]` is a fixed exec-form array; no shell interpolation at all.

7.2.5 Component: Install Job

7.2.5.1Component Overview

One-shot Helm post-install hook (`job-install.yaml`) that bootstraps the Moodle database via `admin/cli/install_database.php`.

7.2.5.2Component File Coverage

File Category	Files Analyzed	Files with Vulnerabilities	Percentage of Component
Entry Points	0	0	n/a
Data Access	0	0	n/a
Business Logic	0	0	n/a
UI/Templates	0	0	n/a
Utilities	1	0	0%
Total	1	0	0%

7.2.5.3Vulnerabilities

None found.

7.2.5.4Files Analyzed with No Vulnerabilities Found

- `./chart/psa-moodle/templates/job-install.yaml` — `--adminuser="$MOODLE_ADMIN_USER"`, `--adminpass="$MOODLE_ADMIN_PASS"`, `--adminemail="$MOODLE_ADMIN_EMAIL"` are all consistently double-quoted CLI-argument expansions sourced from Kubernetes `secretKeyRef` env vars, not external/attacker input; the `wait-for-db` init-container's inline `php -r` connection probe also sources its parameters from the same trusted env vars.

7.2.6 Component: PostgreSQL Cluster (Crunchy PostgreSQL Operator)

7.2.6.1Component Overview

Operator-managed relational datastore defined declaratively via a `PostgresCluster` custom resource and an init-SQL ConfigMap.

7.2.6.2Component File Coverage

No traditional application code — this component is a declarative Kubernetes custom-resource definition and a static SQL snippet, evaluated entirely by the Crunchy PostgreSQL Operator and PostgreSQL itself, not by any first-party application logic in this repository.

7.2.6.3Vulnerabilities

None found — not applicable. `chart/psa-moodle/templates/postgres-init-configmap.yaml` interpolates `.Values.postgres.user.database` / `.Values.postgres.user.name` (Helm-chart operator-controlled values, not runtime/external input) into a static `init.sql` snippet; this is a Helm/configuration-management concern (unquoted Helm value interpolation into SQL), not a code-level application vulnerability, and is out of scope for this domain.

7.2.6.4Files Analyzed with No Vulnerabilities Found

- `./chart/psa-moodle/templates/postgrescluster.yaml`
- `./chart/psa-moodle/templates/postgres-init-configmap.yaml`

7.2.7 Component: Valkey Cache

7.2.7.1Component Overview

Single-replica session/cache store (Redis wire-compatible) configured via `config/valkey/valkey.conf` and a StatefulSet manifest.

7.2.7.2Component File Coverage

No traditional application code — static server configuration and Kubernetes manifests only.

7.2.7.3Vulnerabilities

None found — not applicable.

7.2.7.4Files Analyzed with No Vulnerabilities Found

- `./config/valkey/valkey.conf`
- `./chart/psa-moodle/templates/valkey-statefulset.yaml`
- `./chart/psa-moodle/templates/valkey-service.yaml`
- `./chart/psa-moodle/templates/valkey-configmap.yaml`
- `./chart/psa-moodle/templates/secret-valkey.yaml`

7.2.8 Component: Moodledata Shared Storage

7.2.8.1Component Overview

`ReadWriteMany` PVC shared by the PHP-FPM and cron pods for uploaded content.

7.2.8.2Component File Coverage

No traditional application code — a single declarative `PersistentVolumeClaim` manifest.

7.2.8.3Vulnerabilities

None found — not applicable. (The permission mode of files created inside this volume is governed by `$CFG->directorypermissions` in the PHP-FPM Application Container component — see VULN-001/VULN-002.)

7.2.8.4Files Analyzed with No Vulnerabilities Found

- `./chart/psa-moodle/templates/moodledata-pvc.yaml`

7.2.9 Component: NetworkPolicy Boundary

7.2.9.1Component Overview

Default-deny ingress/egress NetworkPolicy set with an explicit allowlist.

7.2.9.2Component File Coverage

No traditional application code — a single declarative `NetworkPolicy` manifest.

7.2.9.3Vulnerabilities

None found — not applicable.

7.2.9.4Files Analyzed with No Vulnerabilities Found

- `./chart/psa-moodle/templates/networkpolicy.yaml`

7.2.10 Component: OpenShift Route

7.2.10.1 Component Overview

TLS-edge-terminated ingress exposing the Web Container.

7.2.10.2 Component File Coverage

No traditional application code — a single declarative `Route` manifest.

7.2.10.3 Vulnerabilities

None found — not applicable.

7.2.10.4 Files Analyzed with No Vulnerabilities Found

- `./chart/psa-moodle/templates/route.yaml`

7.2.11 Component: Helm Chart / Deployment Topology

7.2.11.1 Component Overview

Chart scaffolding and per-environment values driving the whole deployment.

7.2.11.2 Component File Coverage

No traditional application code — Helm chart metadata, values files, and template helpers.

7.2.11.3 Vulnerabilities

None found — not applicable.

7.2.11.4 Files Analyzed with No Vulnerabilities Found

- `./chart/psa-moodle/Chart.yaml`
- `./chart/psa-moodle/values.yaml`
- `./chart/psa-moodle/values-dev.yaml`
- `./chart/psa-moodle/values-poc.yaml`
- `./chart/psa-moodle/values-test.yaml`
- `./chart/psa-moodle/templates/_helpers.tpl`
- `./chart/psa-moodle/templates/NOTES.txt`
- `./chart/psa-moodle/templates/hpa.yaml`
- `./chart/psa-moodle/templates/poddisruptionbudget.yaml`

7.2.12 Component: Monitoring and Observability

7.2.12.1 Component Overview

OpenShift user-workload-monitoring wiring for Postgres and PHP-FPM exporters.

7.2.12.2 Component File Coverage

No traditional application code — a single declarative monitoring manifest.

7.2.12.3 Vulnerabilities

None found — not applicable.

7.2.12.4 Files Analyzed with No Vulnerabilities Found

- `./chart/psa-moodle/templates/monitoring.yaml`

7.2.13 Component: CI/CD Pipeline

7.2.13.1 Component Overview

GitHub Actions workflows and Makefile driving builds/lint/deploy.

7.2.13.2 Component File Coverage

No traditional application code — CI/CD workflow YAML and a Makefile, evaluated entirely by the GitHub Actions runner, not by any first-party runtime application logic.

7.2.13.3 Vulnerabilities

None found — not applicable. (Supply-chain/dependency-sourcing concerns in `Containerfile.php`/`Containerfile.ops` — e.g., unpinned-by-checksum downloads of `install-php-extensions`, `oc`, and `swaks` — are dependency/supply-chain domain concerns, not code-level application vulnerabilities, and are out of scope for this domain.)

7.2.13.4 Files Analyzed with No Vulnerabilities Found

- `./Makefile`
- `./.gitignore`

7.2.14 Component: Local Dev Compose Stack

7.2.14.1 Component Overview

Podman Compose stack reproducing the topology for local development.

7.2.14.2 Component File Coverage

No traditional application code — Compose service definitions only.

7.2.14.3 Vulnerabilities

None found — not applicable.

7.2.14.4 Files Analyzed with No Vulnerabilities Found

- `./compose.yaml`
- `./compose.registry.yaml`

7.2.15 Component: Documentation & Runbooks

7.2.15.1 Component Overview

Project documentation, phase write-ups, and operational runbooks.

7.2.15.2 Component File Coverage

No traditional application code — Markdown documentation only.

7.2.15.3 Vulnerabilities

None found — not applicable.

7.2.15.4 Files Analyzed with No Vulnerabilities Found

- `./README.md` and all files under `./docs/`

7.3 Severity Assignment Methodology

- **Critical**: Not applicable to any finding in this assessment. No issue found provided immediate, unmitigated remote code execution, full authentication bypass, or direct unauthenticated access to sensitive data. This repository has no first-party application code exposing classic Critical-tier vectors (e.g., unauthenticated SQL injection, unrestricted deserialization of attacker-controlled data).

- **High**: Not applicable to any finding in this assessment. No confirmed source→propagation→sink injection path was found where the source is externally/attacker-reachable — the two manifest-injection findings (VULN-007, VULN-008) have a genuine, unmitigated sink, but their sources are operator-

controlled Helm/CronJob environment variables rather than externally reachable request data, which per the Mitigating Control Analysis discipline downgrades what would otherwise be a High-tier “confirmed injection path” finding.

- **Medium**: No finding in this domain remains at Medium after reverse-validation. VULN-001 was originally assigned Medium (it applies to the configuration variant baked into images deployed to the real OpenShift dev/test namespaces and governs permissions on a `ReadWriteMany` volume shared between two workloads), but reverse-validation corrected it to Low: the weakness is a deployment-time filesystem permission on an internal shared PVC with no directly reachable remote exploit path, consistent with the other findings in this domain.
- **Low**: All eight findings (VULN-001 through VULN-008) are assigned Low. Each represents either (a) a defense-in-depth / hardening gap with no directly observed exploit path (missing `disable_functions` allowlist, missing nginx/PHP version-disclosure hardening, missing browser security headers), (b) a world-writable permission mask on shared application storage that is a real but only internally-reachable weakness (VULN-001, and its lower-blast-radius local-dev counterpart VULN-002), or (c) a real but currently unmitigated injection sink whose only known input source is operator/cluster-admin-controlled configuration rather than externally reachable data (VULN-007, VULN-008). In each case, per the severity-assignment rubric, “Missing security control … without observed exploit path” and “Sink-only finding with constant or sanitized [i.e., not externally attacker-reachable] input” both anchor to Low, and the evidence did not surface a reason to depart from that anchor upward.

---

8 Configuration Management Analysis

This document provides a comprehensive inventory of misconfigured configurations that are vulnerable to security risks. This analysis builds on the architecture analysis (`rapid-assessment/findings/summary/architecture-diagram.md`), associating problematic configurations with the components identified there. No production environment (`values-prod.yaml`) exists yet — `dev`, `poc`, and `test` are the only live overlays, so they are treated as the currently production-reachable configuration surfaces.

8.1 Overall Summary

- Total Critical Severity Issues: 0
- Total High Severity Issues: 2
- Total Medium Severity Issues: 2
- Total Low Severity Issues: 6

- Components with Most Critical and High Issues: Web Container (nginx); NetworkPolicy Boundary
- **High Issue - Web Container (nginx) Missing Content-Security-Policy and X-Frame-Options:** The nginx server block that fronts all Moodle traffic sets no HTTP security response headers at all. Moodle is a learning management system with substantial user-generated content (forum posts, assignment submissions, wiki pages, HTML blocks), making the absence of a Content-Security-Policy and X-Frame-Options materially exploitable for content-injection and clickjacking attacks.
- **High Issue - NetworkPolicy Boundary Unrestricted External HTTPS Egress:** The default `externalHttpsCidr` of `0.0.0.0/0` is applied via the release-wide selector to every component, including the Web Container, which has no documented need for external HTTPS egress — undermining the network segmentation the rest of the policy set otherwise enforces carefully.

Critical and High Issue Matrix | Component Name | Trust Manager | Disabled Encryption Settings | Integration Configurations | Debug Mode | Missing Security Header | |———|———|———|———————————|———|———| | Web Container (nginx) | | | | | ✅ | | NetworkPolicy Boundary | | | ✅ | | |

8.1.1 Severity Criteria

Critical Severity: Encryption or certificate validation is explicitly disabled in a production-reachable path with no compensating control; all security response headers are absent AND the application processes untrusted/sensitive data with no other mitigating layer; debug mode is confirmed enabled with verbose stack traces reachable by any unauthenticated user in a production-reachable environment; unchanged default/vendor admin credentials are confirmed reachable in a production-reachable environment.

High Severity: A single security header category material to this application's risk profile (CSP or X-Frame-Options given Moodle's user-generated content) is missing outright; a database or cache connection in a production-reachable path omits explicit TLS enforcement; an external integration boundary (network egress, OAuth/API allowlist) is scoped far wider than the components that actually need it.

Medium Severity: Secondary security headers (X-Content-Type-Options, Referrer-Policy) are missing; a database connection's TLS posture is ambiguous (mounted certs exist but no `sslmode`/equivalent option is set) rather than explicitly disabled; a NetworkPolicy or RBAC-adjacent selector is broader than its stated intent but still confined to the cluster/namespace boundary.

8.2 Security Issues Stemming From Encryption Configurations

This section covers TLS/SSL posture for the datastore connections used by the PHP-FPM Application Container and Cron Workload.

ID	Component Affected	Severity	Issue	Description	Location
CONFIG-004	PHP-FPM Application Container	Medium	Database connection omits explicit TLS enforcement	`$CFG->dboptions` for the Crunchy PostgreSQL connection sets `dbpersist`, `dbsocket`, `dbport`, `dbhandlesoptions`, `dbcollation`, and `connect_timeout`, but no `dbsslmode`/`sslmode`-equivalent option, despite an inline comment claiming “Crunchy ships TLS certs in /etc/db-tls”. The connection therefore relies on whatever the PHP `pgsql` driver negotiates by default rather than an enforced, verified TLS channel.	config/moodle/config.openshift.php lines 18-26

No Critical or High severity encryption-configuration issues were found (no code or configuration explicitly disables TLS/SSL, e.g. no `sslmode=disable`).

8.3 Missing Security Headers

This section identifies missing security headers in HTTP responses served by the Web Container (nginx). `config/nginx/default.conf` is the sole place in this repository where HTTP response headers for end-user traffic could be set (Moodle's OpenShift Route only terminates/redirects TLS; it does not inject application-layer headers), and it sets zero security headers anywhere in the server block.

ID	Component Affected	Severity	Issue	Description	Location
CONFIG-001	Web Container (nginx)	High	Missing Content-Security-Policy and X-Frame-Options	The `server {}` block handling all Moodle HTTP traffic contains no `add_header Content-Security-Policy` and no `add_header X-Frame-Options` directive anywhere in the file. Moodle serves substantial user/learner-generated content (forums, assignments, HTML blocks), so the absence of CSP and clickjacking protection is directly	config/nginx/default.conf lines 11-20

ID	Component Affected	Severity	Issue	Description	Location
				exploitable.	
CONFIG-002	Web Container (nginx)	Medium	Missing X-Content-Type-Options and Referrer-Policy	No `add_header X-Content-Type-Options nosniff` or `add_header Referrer-Policy` directive is present anywhere in the server block, allowing browser MIME-sniffing and unrestricted referrer leakage on cross-origin navigations.	config/nginx/default.conf lines 11-20
CONFIG-003	Web Container (nginx)	Low	Missing Permissions-Policy	No `add_header Permissions-Policy` directive restricts sensitive browser features (camera, microphone, geolocation, etc.) for any response served by this nginx configuration.	config/nginx/default.conf lines 11-20

Evidence (config/nginx/default.conf, lines 11-20):

```
server {
    listen       8080 default_server;
    listen  [::]:8080 default_server;
    server_name  _;

    # Recover the real client IP from X-Forwarded-For. Trust only in-cluster
    # (RFC1918) hops — the router lives in the pod network — so a spoofed XFF
 from
    # a hypothetical direct client is ignored. real_ip_recursive walks the ch
ain
    # past trusted hops to the left-most untrusted address (the learner).
    set_real_ip_from 10.0.0.0/8;
```

No `add_header` security-header directive appears anywhere else in the remaining 51 lines of this file either.

8.4 Security Issues Stemming From Integration Configurations

This section covers the psa-moodle NetworkPolicy egress rules that govern the boundary to external integration systems (the OAuth2 IdP, `api.github.com` for the `local_githubsync` plugin, the ELM sync endpoint for `local_psaelmsync`, and the BC Gov SMTP relay), plus the observability integration's NetworkPolicy scope.

ID	Component Affected	Severity	Issue	Description	Location
CONFIG-006	NetworkPolicy Boundary	High	External HTTPS egress allowed to 0.0.0.0/0 for every component in the release	`networkPolicy.egress.externalHttpsCidr` defaults to `"0.0.0.0/0"` in every shipped values file (base, dev, poc, test — none override it), and the rendered `allow-external-https-egress` NetworkPoli	chart/psa-moodle/templates/networkpolicy.yaml lines 232-252

ID	Component Affected	Severity	Issue	Description	Location
				cy applies it via `psa-moodle.selectorLabels` (the release-wide selector), not a component-scoped selector. This grants unrestricted external HTTPS egress on port 443 to the Web Container (nginx) as well, which has no documented need to reach the OAuth2 IdP, GitHub, or the ELM endpoint (only PHP-FPM and cron do).	
CONFIG-009	Monitoring and Observability	Low	Monitoring-scrape NetworkPolicy applies to every pod in the namespace	The `allow-monitoring` NetworkPolicy sets `podSelector: {}`, matching all pods in the namespace (including	chart/psa-moodle/templates/monitoring.yaml lines 8-27

ID	Component Affected	Severity	Issue	Description	Location
				the coexisting `moodle-nginx` workloads mentioned in the chart's own comments), rather than being scoped to `psa-moodle`'s own release selector labels. Any other workload in the namespace exposing ports 9187/9253 becomes scrapable by the same rule.	

Evidence — CONFIG-006 (chart/psa-moodle/templates/networkpolicy.yaml, lines 232-252):

```
spec:
  podSelector:
    matchLabels:
      {{- include "psa-moodle.selectorLabels" . | nindent 6 }}
  policyTypes: [Egress]
  egress:
    - to:
        - ipBlock:
            cidr: {{ .Values.networkPolicy.egress.externalHttpsCidr | quote }}
```

and (chart/psa-moodle/values.yaml, lines 197-204):

```
  egress:
    enabled: true
    # External HTTPS allow CIDR. Default 0.0.0.0/0 because k8s NetworkPolicy
    # can't express per-FQDN allowlists; OpenShift EgressFirewall is the righ
t
    # tool if BC Gov Platform mandates per-host restriction. If you have a
    # vetted BC Gov egress CIDR, override here.
    externalHttpsCidr: "0.0.0.0/0"
```

Evidence — CONFIG-009 (chart/psa-moodle/templates/monitoring.yaml, lines 8-19):

```
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: {{ include "psa-moodle.fullname" . }}-allow-monitoring
  labels:
    {{- include "psa-moodle.labels" . | nindent 4 }}
spec:
  podSelector: {}
  policyTypes:
    - Ingress
  ingress:
    - from:
```

Re-assessed CONFIG-006 against the severity rubric: the egress reach is scoped to a single, well-known port (443) and the destinations, while not FQDN-restricted, are all HTTPS (encrypted-in-transit); no credential or unauthenticated-write path is exposed by the overreach alone, so this is recorded as **High** rather than Critical (contributes to but does not by itself grant broader compromise) and is downgraded from the initial Critical read once the encrypted-transport mitigating factor is accounted for.

8.5 Security Issues Stemming From Enabling Debug Mode

This section identifies instances of enabling debug mode. There is no production environment values file in this repository (`values-prod.yaml` does not exist); the base `values.yaml` sets `moodle.debug: false`, and only the lower-environment overlays flip it on.

ID	Location	Environment	Description
CONFIG-005	chart/psa-moodle/values-dev.yaml lines 3-5; chart/psa-moodle/values-poc.yaml lines 36-38	Development	`moodle.debug: true` is set in both the dev and poc overlays, which is the environment-appropriate value for those overlays but flows through the same Helm chart used for `test` (which

ID	Location	Environment	Description
			correctly leaves the base `false` uninherited-and-overridden). If either overlay's values are ever reused as a starting point for a future `values-prod.yaml` without removing this line, Moodle would enable verbose error/debug output (`$CFG->debug`, `debugdisplay`) in production.

No Critical, High, or Medium severity debug-mode issues were found — `chart/psa-moodle/values.yaml` (the base defaults) and `chart/psa-moodle/values-test.yaml` do not set `moodle.debug: true`, and `config/php/php.ini` explicitly sets `display_errors = Off` / `display_startup_errors = Off` for the PHP layer itself.

8.6 Security Issues Stemming From Trust Managers

No custom trust-manager, certificate-validation-bypass, or hostname-verification-bypass code or configuration was found anywhere in this repository. TLS termination for external traffic is handled entirely by the OpenShift Route (`chart/psa-moodle/templates/route.yaml`), which is configured with `termination: edge` and `insecureEdgeTerminationPolicy: Redirect` (forcing HTTP→HTTPS), and no application code in this repository implements a custom certificate validator.

No issues of this type were found.

8.7 Additional Configuration and Infrastructure Hardening Findings

The dispatch scope for this assessment specifically called out Kubernetes/Helm-level configuration hardening (security contexts, resource defaults, network policy breadth) that does not map cleanly onto the five categories above. Those findings are recorded here.

ID	Component Affected	Severity	Issue	Description	Location
CONFIG-007	Web Container (nginx)	Low	`readOnlyRootFilesystem: false` on	The container `securityCon`	chart/psa-moodle/templates/web-

ID	Component Affected	Severity	Issue	Description	Location
			the primary application containers	`text` for the Web Container, PHP-FPM Application Container, and Cron Workload all explicitly set `readOnlyRootFilesystem: false` (identical pattern in all three Deployments), while the same chart's own `php-fpm-exporter` sidecar (`php-deployment.yaml` line 101) correctly sets `readOnlyRootFilesystem: true`, showing the hardened pattern is already known and available in this codebase but not applied to the three primary	deployment.yaml lines 57-61

ID	Component Affected	Severity	Issue	Description	Location
				application containers.	
CONFIG-010	PHP-FPM Application Container	Low	Insecure default directory permissions for Moodle's `dataroot`	`$CFG->directorypermissions` is set to `02777` in the OpenShift config variant (and `0777` in the local-dev variant), granting world-writable permissions to every directory Moodle creates under `moodledata`. This is Moodle's own documented insecure legacy default rather than a repo-introduced value, but it is carried forward unchanged in both shipped config variants.	config/moodle/config.openshift.php line 32

ID	Component Affected	Severity	Issue	Description	Location
CONFIG-008	Local Dev Compose Stack	Low	Hardcoded simple database password in local dev compose stack	`compose.yaml`'s `db` and `php/cron` services set `POSTGRES_PASSWORD` / `DB_PASSWORD` to the literal string `moodle`, matching the username and database name. This stack is explicitly local-development-only (per the file's own header comment) and is never deployed to OpenShift, so it is not production-reachable, but it is still a functioning (non-placeholder) credential checked into version control.	compose.yaml lines 13-18

Evidence — CONFIG-007 (chart/psa-moodle/templates/web-deployment.yaml, lines 57-61):

```
          securityContext:
            allowPrivilegeEscalation: false
```

```
            capabilities:
              drop: ["ALL"]
            readOnlyRootFilesystem: false
```

The identical block repeats at chart/psa-moodle/templates/php-deployment.yaml lines 73-77 and chart/psa-moodle/templates/cron-deployment.yaml lines 86-90.

Evidence — CONFIG-010 (config/moodle/config.openshift.php, line 32):

```
$CFG->directorypermissions = 02777;
```

Evidence — CONFIG-008 (compose.yaml, lines 13-18):

```
  db:
    image: docker.io/library/postgres:15-alpine
    environment:
      POSTGRES_USER: moodle
      POSTGRES_PASSWORD: moodle
      POSTGRES_DB: moodle
```

8.8 Severity Criteria

Category	Critical	High	Medium
Security Issues Stemming From Encryption Configurations	Encryption explicitly disabled in production environments; Plain text connections to external/public databases	Encryption disabled for databases with sensitive data; Inconsistent encryption settings across environments	Encryption disabled for internal databases with proper network controls; Missing encryption for non-sensitive data
Missing Security Headers	Missing all security headers on applications with sensitive data; Explicitly disabling security headers; Misconfigured CSP that allows unsafe sources	Missing HSTS on HTTPS applications; Missing CSP on applications with user-generated content; Missing X-Frame-Options leading to clickjacking risks	Incomplete security header implementations; Using deprecated security headers without modern alternatives; Overly permissive header values
Security Issues Stemming From Integration Configurations	Hardcoded credentials in source code; Integration points with no authentication; Plaintext secrets in configuration files; Missing webhook	Overly permissive access scopes/permissions; Shared credentials across environments; Insecure integration patterns (e.g., FTP	Lack of proper error handling for integration failures; Hardcoded endpoints without environment awareness; Missing retry policies;

Category	Critical	High	Medium
	validation in public-facing endpoints	without encryption); Missing request/response validation	Incomplete logging of integration activities
Security Issues Stemming From Enabling Debug Mode	Debug mode explicitly enabled in production; Stack traces exposed to external users; Development features accessible in production	Conditional debug settings that might activate in production; Inconsistent debug configurations across deployment pipeline; Verbose logging of sensitive information	Debug settings in pre-production environments; Insufficient separation between development and production configs; Hardcoded debug settings without environment awareness
Security Issues Stemming From Trust Managers	Trust managers that completely bypass validation; Disabling certificate validation in production code	Hostname verification bypasses; Conditional bypasses without proper error handling	Overly permissive trust stores; Self-signed certificates in pre-production

9 Cryptographic Security Assessment

This document provides a comprehensive analysis of cryptographic implementations and security practices in the codebase. `psa-moodle` is a Helm/OpenShift-packaged deployment of Moodle 4.5; nearly all cryptographic primitives (TLS termination, certificate issuance, password hashing, backup transport encryption) are delegated to the OpenShift platform, the Crunchy PostgreSQL Operator, or Moodle core rather than implemented in this repository. Findings below reflect gaps in how those platform-provided controls are *wired* (or not wired) from this repo, not custom cryptographic code — this repository contains no first-party cryptographic algorithm implementations.

9.1 Executive Summary

Security Aspect	Issues Found	Risk Level
Encryption	2	Low
Hashing	0	Low
Random Number Generation	0	Low

Security Aspect	Issues Found	Risk Level
Key Management	1	Low
Certificate Handling	0	Low
Protocol Security	3	Medium
Overall Assessment	**6**	**Medium**

9.2 Critical Security Issues

No Critical-severity cryptographic issues were identified. Absence claim basis: repo-wide regex search for `md5|sha1|MD5|SHA1|rc4|RC4|\bdes\b|DES|cipher|encrypt|random|openssl|sslmode` executed across the entire workspace (all tracked files) returned 228 matches across 54 files; manual review of every match found no hardcoded weak/broken algorithm usage (MD5/SHA-1/DES/RC4), no disabled TLS certificate validation, and no plaintext-password-storage pattern in this repository's own code/config. All matches were either documentation prose, unrelated identifiers (e.g. `moodledata`, `upgrades`), or the specific Medium/Low findings documented below.

9.3 Detailed Findings

ID	Component	Issue Type	Severity	Location	Description
CRYPTO-001	Valkey Cache	Missing Transit Encryption (Redis Protocol)	Low	chart/psa-moodle/templates/valkey-configmap.yaml:1-24, config/valkey/valkey.conf:1-19	Valkey is configured with AUTH (`requirepass`, wired separately in `valkey-statefulset.yaml`) but no `tls-port`/`tls-cert-file`/`tls-key-file` directives exist in either the rendered ConfigMap or the local-dev `valkey.conf`. All Redis-protocol traffic between the PHP-FPM/cron pods and the Valkey pod (Moodle session data and

ID	Component	Issue Type	Severity	Location	Description
					cache payloads) travels in cleartext over the pod network.
CRYPTO-002	PHP-FPM Application Container	Database Connection Omits Enforced TLS	Medium	config/moodle/config.openshift.php:18-26	`$CFG->dboptions` sets `dbpersist`, `dbsocket`, `dbport`, `dbhandlesoptions`, `dbcollation`, and `connect_timeout`, but no `dbsslmode` (or PHP `pgsql` driver equivalent) option, despite an inline comment asserting "Crunchy ships TLS certs in /etc/db-tls; mount path is set by the chart." No `db-tls` volume/volumeMount exists anywhere in `chart/psa-moodle/templates/php-deployment.yaml` or `cron-deployment.yaml` — the comment describes a mount that is not actually implemented in this chart. The connection therefore relies entirely on whichever default the PHP `pgsql`

ID	Component	Issue Type	Severity	Location	Description
					driver and the Crunchy-operator-managed `pg_hba.conf` negotiate, rather than an application-enforced, certificate-verified TLS channel. This same `config.openshift.php` file is shared by the Cron Workload component.
CRYPTO-003	PostgreSQL Cluster (Crunchy PostgreSQL Operator)	Backup Archive Encryption Not Configured	Low	chart/psa-moodle/templates/postgrescluster.yaml:75-104	The `spec.backups.pgbackrest` block configures `repos[0]` (an in-cluster PVC, “No S3” per the in-file comment), `schedules`, and `global.repo1-retention-full*`, but sets no `repo1-cipher-type` / `repo1-cipher-pass` keys. pgBackRest defaults to no repository-level encryption when `repo1-cipher-type` is unset, so backup archives written to the `repo1` PVC are not encrypted by the

ID	Component	Issue Type	Severity	Location	Description
					backup tool itself; confidentiality of backup data at rest depends entirely on the underlying PVC storage class's own encryption-at-rest behavior, which is an OpenShift/storage-platform property not configured or verifiable anywhere in this repository.
CR YPTO-004	Ops Tooling	Unencrypted SMTP for Alert Delivery	Low	scripts/ops/alert.sh:20-31	`alert.sh` (invoked by `backup-integrity.sh` and `restore-rehearsal.sh` on failure) calls `swaks --server "$ALERT_SMTP_HOST" --port 25 ...` with no `--tls` flag and no STARTTLS negotiation attempted. Alert subject/body (which can include table names, failure detail, and log tails per the callers) is transmitted in plaintext to the SMTP relay.
CR	Monitoring and	Unencrypted	Low	chart/psa-	The

ID	Component	Issue Type	Severity	Location	Description
YPTO-005	Observability	SMTP for Alertmanager Routing		moodle/templates/monitoring.yaml:157-178	`AlertmanagerConfig`'s `email` receiver sets `requireTLS: false` for the `smarthost: {{ .Values.monitoring.alerts.smtpHost }}:{{ .Values.monitoring.alerts.smtpPort }}` connection (default `apps.smtp.gov.bc.ca:25` per `values.yaml`). Alertmanager will not require STARTTLS/TLS before sending alert emails, so Prometheus alert content (cluster/namespace names, metric values, resource identifiers) can be transmitted in plaintext.
CR YPTO-006	Install Job	Secret Confidentiality Delegated to Platform Encryption-at-Rest	Informational	chart/psa-moodle/templates/secret-moodle.yaml:17-28	The Moodle admin credential (`MOODLE_ADMIN_PASS`, generated via Helm's `randAlphaNum 24`) is stored in a Kubernetes `Secret` object, which the Kubernetes API only base64-encodes (not

ID	Component	Issue Type	Severity	Location	Description
					encrypts) by default. The same pattern applies to `secret-valkey.yaml`'s `VALKEY_PASSWORD` and the Crunchy-operator-managed `pguser` Secret. Confidentiality of these credentials at rest is therefore entirely dependent on the OpenShift cluster's etcd encryption-at-rest configuration (a platform-level control), which is not present or configurable from anything in this repository.

9.4 Summary of Cryptographic Implementations

9.4.1 Component: Web Container (nginx)

9.4.1.1Overview

Element Type	Implementation	Security Assessment	Recommendation
Encryption	None (plain HTTP on containerPort 8080)	Adequate — TLS is terminated upstream at the OpenShift Route (edge termination); nginx itself is not expected to hold a certificate.	None — encryption boundary is correctly delegated to the OpenShift Route component.
Hashing	Not applicable	No hashing operations found in `config/nginx/default.conf`.	—

Element Type	Implementation	Security Assessment	Recommendation
RNG	Not applicable	No RNG usage found.	—

No further cryptographic elements (key management, certificate handling, protocol config beyond plain HTTP) were found in `config/nginx/default.conf`, `Containerfile.web`, `web-deployment.yaml`, or `web-service.yaml`.

9.4.2 Component: PHP-FPM Application Container

9.4.2.1Overview

Element Type	Implementation	Security Assessment	Recommendation
Encryption	Postgres client connection (`$CFG->dboptions`); Valkey session connection (`session_redis_auth`)	See CRYPTO-002 (Postgres TLS not enforced). Valkey connection is authenticated (AUTH password) but unencrypted in transit — see CRYPTO-001 (attributed to Valkey Cache component).	See CRYPTO-002.
Hashing	Not present in this repository — Moodle 4.5 core (cloned by `Containerfile.php`, not vendored/modified in this repo) uses PHP's `password_hash()`/bcrypt for user password storage.	Delegated to Moodle core, which is outside this repository's code surface; cannot be verified or overridden from evidence found here.	—
RNG	Not present in this repository for application-level tokens; Moodle core handles session ID and CSRF `sesskey` generation internally.	Delegated to Moodle core (external to this repo).	—

9.4.2.2Encryption Implementations

File	Line	Algorithm	Key Length	Context	Security Assessment

File	Line	Algorithm	Key Length	Context	Security Assessment
config/moodle/config.openshift.php	18-26	PostgreSQL client connection (protocol/cipher negotiated by PHP `pgsql` driver + server, not explicit)	N/A — not configured in this file	Database connectivity to the Crunchy-operator-managed PostgresCluster	See CRYPTO-002 — TLS mode is not explicitly requested by the application; relies entirely on server-side/driver defaults.
config/moodle/config.openshift.php	34-41	Redis/Valkey `AUTH` (password only, no TLS)	32-char random password (`secret-valkey.yaml`, `randAlphaNum 32`)	Moodle session storage (`\core\session\redis`) and object cache	Authentication present; confidentiality/integrity in transit not provided — see CRYPTO-001 (attributed to the Valkey Cache component).

9.4.2.3Certificate Validation

File	Line	Validation Method	Issues	Security Assessment
config/moodle/config.openshift.php	51-55	`$CFG->sslproxy = true;` `$CFG->reverseproxy = false;`	None — this only tells Moodle the *external* connection (Route → client) is HTTPS; it performs no certificate validation itself.	Correctly scoped: the comment explains `reverseproxy` must stay `false` because the Router forwards the same public hostname, avoiding a `reverseproxyabused` false-positive. No certificate-validation-disabling pattern (e.g. `verify=False`, `CERT_NONE`) found anywhere in this component.

9.4.2.4Protocol Implementations

File	Line	Protocol	Version	Configuration	Security Assessment
config/moodle/c	18-26	PostgreSQL wire protocol	Not pinned	No `dbsslmode` set	See CRYPTO-002.

File	Line	Protocol	Version	Configuration	Security Assessment
onfig.openshift.php					

9.4.3 Component: Cron Workload

Shares `config/moodle/config.openshift.php` with the PHP-FPM Application Container — the same database-TLS observation (CRYPTO-002) applies to this component's connections. No component-specific cryptographic elements were found in `Containerfile.cron`, `cron-deployment.yaml`, or `cron-cronjob.yaml`.

9.4.4 Component: Install Job

9.4.4.1Key Management

File	Line	Storage Method	Rotation Policy	Security Assessment
chart/psa-moodle/templates/secret-moodle.yaml	9-28	Kubernetes `Secret` (`type: Opaque`), value generated once via Helm's `randAlphaNum 24` and preserved across upgrades via the `lookup` trick (`helm.sh/resource-policy: keep`)	No automated rotation — in-file comment states "Rotate manually after install if desired."	See CRYPTO-006 for the encryption-at-rest delegation note. Manual-only rotation is a housekeeping gap (Low-tier per the analysis skill's classification) but not separately scored as a distinct finding — the Kubernetes-Secret-confidentiality observation (CRYPTO-006) is the primary crypto-relevant fact here.

9.4.4.2Random Number Generation

File	Line	Implementation	Entropy Source	Context	Security Assessment
chart/psa-moodle/templates/secret-moodle.y	15	Helm template function `randAlphaNum 24`	Not verifiable from this repository — `randAlphaNum` is implemented in Helm's bundled Sprig library, external to this codebase.	Generates the one-time Moodle admin password at first install.	Delegated to Helm/Sprig (external dependency); this repository contains no evidence either confirming or refuting the underlying entropy source, so no claim is made about its cryptographic strength.

File	Line	Implementation	Entropy Source	Context	Security Assessment
aml					

9.4.5 Component: PostgreSQL Cluster (Crunchy PostgreSQL Operator)

9.4.5.1Overview

Element Type	Implementation	Security Assessment	Recommendation
Encryption	pgBackRest backup repo (`repo1`, in-cluster PVC)	See CRYPTO-003 — no `repo1-cipher-type` configured.	See CRYPTO-003.
Certificate Handling	Not configured in this repository (`spec.customTLSSecret` / `spec.customReplicationTLSSecret` absent from `postgrescluster.yaml`)	Delegated to the Crunchy PostgreSQL Operator, which auto-generates and rotates its own internal CA and per-instance TLS certificates for replication and (per Crunchy's documented default `pg_hba.conf` behavior) client connections when no custom TLS secret is supplied. This repository makes no explicit certificate-handling decisions for Postgres — it is entirely operator-managed.	None from the application side; if a specific external CA is required, that would be a `spec.customTLSSecret` addition to `postgrescluster.yaml`.

9.4.5.2Encryption Implementations

File	Line	Algorithm	Key Length	Context	Security Assessment
chart/psa-moodle/templates/postgresscluster.yaml	75-104	pgBackRest repository encryption	Not configured (no cipher)	Backup archive storage in `repo1` PVC	See CRYPTO-003.

9.4.6 Component: Valkey Cache

9.4.6.1Overview

Element Type	Implementation	Security Assessment	Recommendation

Element Type	Implementation	Security Assessment	Recommendation
Encryption	None (Redis wire protocol, plain TCP on 6379)	See CRYPTO-001.	See CRYPTO-001.
Key Management	`VALKEY_PASSWORD` — 32-char random string, generated once via Helm `randAlphaNum 32`, preserved across upgrades via the `lookup` trick	Password is correctly wired end-to-end: `valkey-statefulset.yaml` passes `--requirepass $(VALKEY_PASSWORD)` on the container command line, which takes precedence over `valkey-configmap.yaml`'s `protected-mode no`, and `_helpers.tpl`'s `psa-moodle.appEnv` sources the same secret into `CACHE_PASSWORD` for the PHP/cron pods. No plaintext password is present in the ConfigMap.	See CRYPTO-001 for the separate transit-encryption gap.
RNG	Helm template function `randAlphaNum 32` (`secret-valkey.yaml` line 15)	Same delegation-to-Sprig note as the Install Job component — not verifiable from repo evidence.	—

9.4.6.2Encryption Implementations

File	Line	Algorithm	Key Length	Context	Security Assessment
chart/psa-moodle/templates/valkey-configmap.yaml	1-24	None (`protected-mode no`, no `tls-port`)	N/A	Redis-protocol session/cache traffic	See CRYPTO-001.
config/valkey/valk	1-19	None	N/A	Same configuration	Local-dev only per file header; same absence of TLS as the OpenShift

File	Line	Algorithm	Key Length	Context	Security Assessment
ey.conf				mirrored for local Podman Compose dev	ConfigMap variant.

9.4.7 Component: Moodledata Shared Storage

No cryptographic elements were found in `chart/psa-moodle/templates/moodledata-pvc.yaml` — it is a bare `PersistentVolumeClaim` manifest with no encryption, key management, or protocol configuration of its own. Encryption at rest for the underlying `netapp-file-standard` volume is entirely an OpenShift/storage-platform property, not something this repository configures.

9.4.8 Component: Ops Tooling

9.4.8.1 Protocol Implementations

File	Line	Protocol	Version	Configuration	Security Assessment
scripts/ops/alert.sh	20-31	SMTP (via `swaks`)	Not specified — `--port 25`, no `--tls`	No STARTTLS/TLS negotiated	See CRYPTO-004.

`backup-integrity.sh` and `restore-rehearsal.sh` retrieve the Crunchy `pguser` Secret's `password` field via `oc get secret ... -o jsonpath='{.data.password}' | base64 -d` — this is standard base64 decoding of a Kubernetes Secret value (not a cryptographic operation) and introduces no algorithm-level weakness; the same platform-delegated encryption-at-rest caveat as CRYPTO-006 applies to this Secret.

9.4.9 Component: NetworkPolicy Boundary

No cryptographic elements found — `networkpolicy.yaml` operates at L3/L4 (IP/port) and has no bearing on encryption, hashing, or key management.

9.4.10 Component: OpenShift Route

9.4.10.1 Protocol Implementations

File	Line	Protocol	Version	Configuration	Security Assessment
chart/psa-moodle/templates/ro	15-28	TLS (OpenShift Route, edge termination)	Router-managed (version/cipher suite selection	`termination: edge`, `insecureEdgeTerminationPolicy: Redirect` (`values.yaml`	Adequate — HTTP is redirected to HTTPS at the router, and the router (not the pod) terminates TLS, consistent with the OpenShift-recommended

File	Line	Protocol	Version	Configuration	Security Assessment
ute.yaml			is an OpenShift-platform default, not configured in this repository)	lines 140-145); no environment override in `values-dev.yaml`, `values-poc.yaml`, or `values-test.yaml`	edge-termination pattern. No `passthrough`/`reencrypt`-with-skip-verify or `insecureEdgeTerminationPolicy: Allow` was found. Actual TLS protocol-version/cipher-suite enforcement is delegated to the OpenShift router/HAProxy configuration, which is outside this repository.

9.4.11 Component: Helm Chart / Deployment Topology

Uses Helm's built-in `randAlphaNum` (Sprig library) in two places (`secret-moodle.yaml`, `secret-valkey.yaml`, both documented under their respective components above) and the `lookup` function to preserve generated secrets across `helm upgrade`. No cryptographic algorithm, key-management, or certificate logic is implemented directly in `Chart.yaml`, `values*.yaml`, `_helpers.tpl`, `hpa.yaml`, or `poddisruptionbudget.yaml`.

9.4.12 Component: Monitoring and Observability

9.4.12.1 Protocol Implementations

File	Line	Protocol	Version	Configuration	Security Assessment
chart/psa-moodle/templates/monitoring.yaml	157-178	SMTP (Alertmanager email receiver)	Not specified	`requireTLS: false`, `smarthost: apps.smtp.gov.bc.ca:25`	See CRYPTO-005.

Prometheus/PodMonitor/ServiceMonitor scrape endpoints (`monitoring.yaml` lines 1-70) are plain-HTTP metrics endpoints restricted to the `openshift-user-workload-monitoring` namespace by the accompanying `NetworkPolicy`; no TLS is configured for scraping, which is consistent with standard in-cluster Prometheus deployments and was not scored as a separate finding given the existing NetworkPolicy boundary.

9.4.13 Component: CI/CD Pipeline

No cryptographic algorithm or key-management code was found in `.github/workflows/*.yml` or `Makefile`. `deploy.yml` line 118 sets `insecure_skip_tls_verify: false` for the OpenShift `oc login` action step — this explicitly enforces (rather than disables) TLS certificate verification for the CI runner's connection to the cluster API, and is called out here as a correctly-configured control rather than a finding.

9.4.14 Component: Local Dev Compose Stack

`compose.yaml` and `compose.registry.yaml` run Postgres and Valkey with no passwords/TLS beyond a fixed `POSTGRES_PASSWORD: moodle` and an unauthenticated Valkey instance (`command: ["valkey-server", "/usr/local/etc/valkey/valkey.conf"]` with no `--requirepass`, unlike the OpenShift StatefulSet). This is explicitly local-development-only tooling (`config/moodle/config.local.php`'s own header states "All credentials here are LOCAL DEV ONLY — never used in OpenShift") and is not scored as a finding — no production or shared-environment reachability was established for this component.

9.4.15 Component: Documentation & Runbooks

No cryptographic elements — this component consists entirely of Markdown documentation.

9.5 Overall Security Posture

Issue Severity	Count	Impact	Components Affected
Critical Issues	0	—	None
Medium Risk Issues	1	Medium	PHP-FPM Application Container (shared with Cron Workload)
Minor Issues	4	Low	Valkey Cache, PostgreSQL Cluster (Crunchy PostgreSQL Operator), Ops Tooling, Monitoring and Observability
Informational	1	Informational	Install Job

9.6 Cross-Component Security Concerns

- **Unencrypted internal traffic pattern**: three independent components (Valkey Cache — CRYPTO-001, Ops Tooling — CRYPTO-004, Monitoring and Observability — CRYPTO-005) rely on cluster-network segmentation (`NetworkPolicy`) rather than transport encryption to protect data in transit. This is a consistent architectural choice across the deployment rather than an isolated oversight, and its residual risk

depends on the strength of the NetworkPolicy boundary (assessed separately by the configuration/authentication domains).

- **Delegated cryptographic trust boundary**: certificate issuance/rotation (Crunchy PostgreSQL Operator, OpenShift Route) and encryption-at-rest (etcd Secret encryption, PVC storage-class encryption, pgBackRest repository encryption) are consistently delegated to the OpenShift platform or the Crunchy operator rather than configured in this repository. This is a reasonable platform-engineering pattern, but it means this repository's own evidence cannot confirm or deny whether those platform-level controls are actually enabled in any given cluster — that verification is out of scope for a static repository assessment.
- **Comment/implementation drift**: `config/moodle/config.openshift.php` (CRYPTO-002) contains an inline comment asserting a TLS certificate mount (`/etc/db-tls`) that does not exist anywhere in the Helm chart's templates, which could mislead future maintainers into believing DB-connection TLS is enforced when it is not.

---

10 Hard Coded Secrets Inventory

This document provides a comprehensive inventory of hard coded secrets found in the codebase, along with risk assessments.

10.1 Executive Summary

Risk Level	Production	Non-Production	Total	Potential Impact
Critical	0	0	0	None identified
High	0	0	0	None identified
Medium	0	0	0	None identified
Low	0	2	2	Weak, non-production database credential ("moodle"/"moodle") baked into a local-dev-only PHP config fallback and duplicated in the local Podman Compose stack. Confined to the local developer environment; the OpenShift/Helm deployment path never uses this file or

Risk Level	Production	Non-Production	Total	Potential Impact
				credential.
Total	0	2	2	

Most Affected Components: 1. `local-dev-compose` (Podman Compose stack for local development) 2. `php-fpm-application` (Moodle PHP-FPM container, `config.local.php` dev variant)

10.2 Classification

10.2.1 Risk Level Categories

- **Critical**: Secrets that provide direct access to production systems or sensitive data
- **High**: Secrets that provide significant access to subsystems or test environments
- **Medium**: Secrets with limited access capabilities or for development environments
- **Low**: Minimal risk secrets or sample credentials

10.2.2 Environment Categories

- **Production**: Secrets used in live environments accessed by end users
- **Non-Production**: Secrets used in development, testing, or staging environments

10.3 Detailed Secrets Inventory

All OpenShift/Helm-deployed secrets (Moodle admin password, PostgreSQL `pguser` credentials, Valkey `VALKEY_PASSWORD`) are generated at install time with `randAlphaNum` inside Helm templates (`secret-moodle.yaml`, `secret-valkey.yaml`) and consumed exclusively via Kubernetes `secretKeyRef` — no literal values are present in any chart template, values file, or PHP config used by the OpenShift deployment path (`config.openshift.php`). The only hard-coded credential material found in the entire repository is a weak, explicitly-labelled local-development-only database password, described below.

10.4 Critical Risk Secrets

10.4.1 Production Environment

No Critical risk secrets were found in the production/OpenShift deployment path. All production-path credentials (`config.openshift.php`, Helm Secret templates, CI/CD workflows) are sourced from Kubernetes Secrets or GitHub Actions repository secrets with no literal fallback values.

10.4.2 Non-Production Environment

No Critical risk secrets were found in non-production paths.

10.5 High Risk Secrets

10.5.1 Production Environment

No High risk secrets were found.

10.5.2 Non-Production Environment

No High risk secrets were found.

10.6 Medium Risk Secrets

10.6.1 Production Environment

No Medium risk secrets were found.

10.6.2 Non-Production Environment

No Medium risk secrets were found.

10.7 Low Risk Secrets

10.7.1 Production Environment

No Low risk secrets were found in the production/OpenShift deployment path.

10.7.2 Non-Production Environment

10.7.2.1 Component: php-fpm-application

10.7.2.1.1 [SECRET-001] Database Credential (hardcoded fallback password)

File Location	Line Number	Context
`config/moodle/config.local.php`	15-16	`$CFG->dbuser = getenv('DB_USER') ?: 'moodle'; / $CFG->dbpass = getenv('DB_PASSWORD') ?: '***'` (fallback value equals the username)

Risk Assessment: `config.local.php` is the Moodle configuration variant baked into the image only when built with `MOODLE_CONFIG_VARIANT=local` (see `Containerfile.php`), and the file's own header comment states "All credentials here are LOCAL DEV ONLY — never used in OpenShift." The fallback activates only if the `DB_PASSWORD` environment variable is absent; in the local Podman Compose stack the variable is always set (see SECRET-002), so this fallback is a defensive default rather than the live credential. The value is weak (short, identical to the username, low entropy) but the file explicitly documents non-

production scope, and the OpenShift-targeted variant (`config.openshift.php`) has no such fallback — it hard-requires the environment variable. Residual risk is limited to a misconfigured build accidentally shipping the `local` config variant to a running environment, in which case a trivial default credential would silently be accepted for the database connection.

10.7.2.2 Component: local-dev-compose

10.7.2.2.1 [SECRET-002] Database Credential (hardcoded Compose password)

File Location	Line Number	Context
`compose.yaml`	12-17	`POSTGRES_PASSWORD: ***` in the `db` service `environment:` block, duplicated as `DB_PASSWORD: ***` in the `php` (line 47) and `cron` (line 85) service blocks

Risk Assessment: The local Podman Compose stack (`make up`) hardcodes a plaintext, weak PostgreSQL password (identical to the username) directly in `compose.yaml`, used to authenticate the `db`, `php`, and `cron` services to the local Postgres container. This is a genuinely non-production, developer-machine-only artifact — the `db` service also publishes port 5433 to the host, so on a shared or multi-tenant development host this weak credential is reachable beyond the Compose-internal network. There is no equivalent path in the OpenShift/Helm deployment (which sources `DB_PASSWORD` exclusively from the Crunchy-operator-managed `pguser` Secret via `secretKeyRef`). Related to SECRET-001, which documents the matching fallback value in the corresponding local PHP config.

10.8 False Positives

10.8.1 Component: documentation-runbooks

Pattern	File Location	Justification
`--docker-password='<PASTE-IDENTITY-TOKEN>'`	`docs/namespace-handover.md` (~line 132)	Explicit bracketed placeholder instructing the operator to paste their own Artifactory Identity Token; no literal secret value present
`oc login ... --token="<OLD_TOKEN>"`	`docs/namespace-handover.md` (~line 213)	Bracketed placeholder in a runbook instruction, not a literal token
`-p '<paste-robot-token>'`	`docs/phase2-images.md` (~line 74)	Bracketed placeholder in a runbook instruction, not a literal

Pattern	File Location	Justification
		token
References to `secrets.OPENSHIFT_TOKEN_DEV`, `secrets.ARTIFACTORY_PASSWORD`, etc.	`.github/workflows/build.yml`, `.github/workflows/deploy.yml`	GitHub Actions `secrets.*` context references — these are indirections to repository-configured secrets, not literal credential values
`Hardcoded replication password ( + “replsecret” + ) in a ConfigMap`	`docs/legacy-comparison.md` (~line 82)	Describes a weakness in the **legacy** `bcgov/moodle-nginx` repository being compared against, not a value present in the `psa-moodle` codebase itself
`admin@example.com`	`chart/psa-moodle/values.yaml` (moodle.admin.email default)	Documentation-style placeholder email address, not a credential
Valkey `VALKEY_PASSWORD` / Moodle `MOODLE_ADMIN_PASS` in `secret-valkey.yaml` / `secret-moodle.yaml`	`chart/psa-moodle/templates/secret-valkey.yaml`, `secret-moodle.yaml`	Values are generated at install time via Helm’s `randAlphaNum` function and preserved across upgrades via the `lookup` trick — no literal secret value is authored in the template

11 Security & Logging Assessment

This document provides a comprehensive analysis of security and logging issues identified in the codebase.

11.1 Overall Summary

- Total High Severity Issues: 0
- Total Medium Severity Issues: 4
- Total Low Severity Issues: 3
- Components with Most Critical Issues: `ops-tooling` (2), `php-fpm-application` (2)
- Major risk areas: (1) the Moodle admin bootstrap password is passed as a CLI argument during the install Job, risking capture by node-level process/audit logging; (2) all outbound alert/audit email (backup-integrity, restore-rehearsal, and Prometheus/Alertmanager) is sent over an unauthenticated, unencrypted SMTP path, so operational log excerpts travel in cleartext; (3) Moodle’s own scheduled-task runner (`cron-workload`) has no automated alerting on tick failure, unlike the

Phase 6 backup/restore jobs, creating a blind spot for failed security-relevant scheduled tasks (session cleanup, lockout resets, notification delivery).

11.2 Cross-Component Security Patterns

- **Positive pattern — PHP error handling:** `config/php/php.ini` sets `display_errors = Off` / `display_startup_errors = Off` with `log_errors = On` and `error_log = /dev/stderr` (php.ini). This is a correct, consistent production-safe configuration: no stack traces reach end users, and errors are captured to the container's stderr stream for cluster-level collection. No Error Information Disclosure issues were found in any component reviewed.
- **Positive pattern — audit-grade access logging:** `config/nginx/default.conf` defines a custom `log_format main_xff` that records `$remote_addr` (recovered via `real_ip_recursive`/trusted `X-Forwarded-For` hops), `$remote_user`, and the raw XFF chain, explicitly to support attributing a request to a learner (e.g. tracing brute force) — see default.conf.
- **Recurring gap — insecure email transport for alerts/audit data:** the same unauthenticated, non-TLS SMTP pattern (BC Gov relay, port 25, `requireTLS: false`) is used for both ad-hoc operator scripts (`scripts/ops/alert.sh`) and the platform's own Prometheus Alertmanager email receiver (`chart/psa-moodle/templates/monitoring.yaml`), so the gap is architectural rather than a single-file mistake (LOG-003, LOG-004).
- **Recurring gap — no automated alerting outside Phase 6 ops scripts:** `backup-integrity.sh` and `restore-rehearsal.sh` both call `alert.sh` on failure, but the cron workload's own failure path (`cron-deployment.yaml`) only echoes to container stdout with no equivalent notification (LOG-001).

11.3 Overall Security Event Logging Assessment

Container-level logging is consistently routed to stdout/stderr across `web-container` (nginx `access_log /dev/stdout`), `php-fpm-application` (PHP `error_log = /dev/stderr`), and `cron-workload/install-job` (shell `echo`/PHP CLI output), which is the standard OpenShift pattern of relying on the cluster's log aggregation layer rather than in-application log files. However, no explicit log-retention or centralized-shipping configuration (e.g., a log-forwarding sidecar, Fluentd/Vector/ClusterLogForwarder resource, or documented retention policy) is present anywhere in this repository's `chart/` or `config/` trees; the assessment found no evidence either confirming or ruling out that OpenShift's cluster-wide default log rotation (commonly a few days on Silver/Gold clusters) is sufficient for forensic investigation of security events. Application-level security event logging for Moodle itself (login/logout, permission changes) relies entirely on Moodle core's built-in `logstore_standard` defaults — no explicit `$CFG` logstore configuration was found in either `config/moodle/config.local.php` or `config/moodle/config.openshift.php`, so this assessment cannot confirm whether the standard log store (which persists to the `postgresql-cluster` component) is enabled, tuned, or excluded from the daily backup/retention scope reviewed by `backup-integrity.sh`.

11.4 Overall Sensitive Data Handling

No evidence of passwords, tokens, or session identifiers being deliberately written to logs via `echo`/`log()` calls in any of the shell scripts reviewed (`alert.sh`, `backup-integrity.sh`, `moodledata-snapshot.sh`, `moodledata-snapshot-prune.sh`, `restore-rehearsal.sh`) — all scripts retrieve secrets via `oc get secret ... -o jsonpath` into command-substitution variables (not printed to stdout) or via Kubernetes `secretKeyRef` env injection. The one confirmed exposure vector is CLI-argument based, not log-statement based: the Moodle admin bootstrap password is passed as a literal `--adminpass=` flag in `job-install.yaml` (LOG-002), which is a `credential` category PII/secrets exposure risk via process-list and node-level audit tooling rather than via this repository's own log output. A second, lower-severity risk is Moodle's own `debugsmtp` debug flag (LOG-005), which — when enabled — logs full outbound email transcripts (potentially including password-reset tokens and learner email addresses, a `credential` + `contact-pii` combination) and is the default in the local Podman Compose dev stack (`compose.yaml` sets `MOODLE_DEBUG: "1"`).

11.5 Detailed Component Analysis

11.5.1 Component: Web Container (nginx)

11.5.1.1 Component Overview

Serves static assets and proxies to PHP-FPM. Implements an audit-grade access log format that recovers the real client IP through the trusted OpenShift Router hop.

11.5.1.2 Sensitive Data Exposure

No issues found.

11.5.1.3 Exception Handling

No issues found (nginx does not perform application-level exception handling).

11.5.1.4 Error Information Disclosure

No issues found — `deny all` rules block direct access to `.git`, `vendor/`, `node_modules/`, and Moodle installer/config artifacts (see default.conf), so nginx itself does not surface internal paths or framework details.

11.5.1.5 Debug Information Exposure

No issues found.

11.5.1.6 Security Event Logging

ID	Severity	Issue	Location	Description	Recommendation
—	—	No issues found	—	`access_log /dev/stdout main_xff` captures remote	—

ID	Severity	Issue	Location	Description	Recommendation
				IP (via trusted XFF), remote user, request line, status, and XFF chain for every request except `/health` (`access_log off`, default.conf). This is a positive control, not a finding.	

11.5.1.7 Component-Specific Recommendations

None — the current logging configuration is sound for this component.

11.5.2 Component: PHP-FPM Application Container

11.5.2.1 Component Overview

Runs Moodle 4.5 under PHP-FPM. Has correct production error-handling defaults but two logging-related gaps: an FPM-level access log disabled by default, and a debug flag that (when enabled) can write sensitive email content to logs.

11.5.2.2 Sensitive Data Exposure

No issues found directly in this component's own log statements (see LOG-005 below, filed under Debug Information Exposure since it is gated by a debug flag).

11.5.2.3 Exception Handling

No issues found.

11.5.2.4 Error Information Disclosure

No issues found — `display_errors = Off`, `display_startup_errors = Off`, `log_errors = On`, `error_log = /dev/stderr` (php.ini) is a correct production configuration; no stack traces or internal error detail reach end users.

11.5.2.5 Debug Information Exposure

ID	Severity	Issue	Location	Description	Recommendation
LOG-005	Low	Debug-gated SMTP	`config/moodle/config.local.php` lines 48-55	When `MOODLE_DEBUG=1`, `$CFG->debugsmtp = 1` is set	Document that `MOODLE_DEBUG` must never be set to 1

ID	Severity	Issue	Location	Description	Recommendation
		transcript logging		alongside `$CFG->debug = (E_ALL \| E_STRICT)` and `$CFG->debugdisplay = 1`. `debugsmtp` causes Moodle to log the full raw SMTP transcript for every outbound email (headers and body), which can include password-reset tokens and learner email addresses. `compose.yaml` sets `MOODLE_DEBUG: "1"` by default for the local Podman Compose stack (compose.yaml), so this is the active default in local dev, not just a theoretical toggle. The file's own header comment states these credentials/settings are "LOCAL DEV ONLY — never used in OpenShift," and `config.openshift.php` (the file actually used in cluster deployments)	outside local development, and consider gating `debugsmtp` behind a second, more explicit flag so a copy-paste of this pattern into another environment doesn't silently enable SMTP transcript logging.

ID	Severity	Issue	Location	Description	Recommendation
				contains no equivalent debug toggle.	

11.5.2.6 Security Event Logging

ID	Severity	Issue	Location	Description	Recommendation
LOG-006	Low	PHP-FPM pool access log disabled	`config/php/php-fpm.conf` line 27	`access.log = /dev/null` disables FPM's own per-request access log (script path, request duration, memory usage, response code at the FastCGI layer). nginx's `access_log` still records HTTP-layer requests, so basic request auditability is retained, but forensic detail that is specific to the PHP execution layer (e.g., which script actually ran, execution time) is lost.	If PHP-FPM-layer detail is needed for incident investigation (e.g., detecting resource-exhaustion or slow-loris-style abuse patterns against specific scripts), route `access.log` to `/dev/stdout` (or a custom `access.format`) instead of `/dev/null`, or confirm nginx's request-line logging is deemed sufficient and document that decision.

11.5.2.7 Component-Specific Recommendations

Keep `display_errors`/`log_errors` as configured. Add an explicit guard so `MOODLE_DEBUG` cannot be set in any OpenShift-facing values file, and consider re-enabling FPM's access log if PHP-layer forensic detail is needed.

11.5.3 Component: Cron Workload

11.5.3.1 Component Overview

Runs Moodle's scheduled-task runner (`admin/cli/cron.php`) in a loop. Ticks are logged to stdout but failures are not escalated.

11.5.3.2 Sensitive Data Exposure

No issues found.

11.5.3.3 Exception Handling

No issues found (the loop's `set -u` and heartbeat-based liveness probe are a designed resilience mechanism, not an exception-swallowing anti-pattern).

11.5.3.4 Error Information Disclosure

No issues found.

11.5.3.5 Debug Information Exposure

No issues found.

11.5.3.6 Security Event Logging

ID	Severity	Issue	Location	Description	Recommendation
LOG-001	Medium	Cron tick failures are not alerted	`chart/psa-moodle/templates/cron-deployment.yaml` lines 54-61	The cron loop logs `echo "[cron-loop] tick end rc=${rc} $(date -u +%FT%TZ)"` to container stdout but takes no further action when `rc` is non-zero — it does not invoke `alert.sh` (unlike `backup-integrity.sh` and `restore-rehearsal.sh`, which page on failure) and does not fail the pod. Since `admin/cli/cron.php` runs Moodle's security-relevant	Parse `rc` after each tick and call `alert.sh` (or emit a Prometheus-scrapeable failure metric) when `rc != 0`, consistent with the alerting pattern already used by the Phase 6 backup/restore scripts.

ID	Severity	Issue	Location	Description	Recommendation
				scheduled tasks (session cleanup, account-lockout resets, notification/email delivery), a persistently failing tick is only discoverable by an operator manually reading pod logs; the liveness probe only detects a wedged loop via the heartbeat file, not a loop that completes every tick with a non-zero return code.	

11.5.3.7 Component-Specific Recommendations

Add failure alerting to the cron loop so failed scheduled-task runs are not silently invisible outside of manually-inspected pod logs.

11.5.4 Component: Install Job

11.5.4.1 Component Overview

One-shot Helm post-install hook that bootstraps the Moodle database, including creating the initial admin account.

11.5.4.2 Sensitive Data Exposure

ID	Severity	Issue	Location	Description	Recommendation
LOG-002	Medium *(corrected from High during reverse-validation)*	Moodle admin password passed as a CLI argument	`chart/psa-moodle/templates/job-install.yaml` lines 69-75 (password on line 72)	`install_database.php` is invoked as `php /var/www/html/admin/cli/install_database.php --agree-license --adminuser="$MOO`	Pass the admin password to `install_database.php` via its supported non-interactive input method (e.g., stdin/a config file read from a mounted Secret)

ID	Severity	Issue	Location	Description	Recommendation
				`DLE_ADMIN_USER" --adminpass="$MOODLE_ADMIN_PASS" --adminemail="$MOODLE_ADMIN_EMAIL" .... $MOODLE_ADMIN_PASS` is interpolated into the literal process command line at runtime. Process arguments are visible via `/proc/<pid>/cmdline`/`ps -eo args` to any process sharing the container's PID namespace, and are commonly captured verbatim by node-level process-execution auditing (e.g., auditd `execve` rules, OpenShift/EDR process monitoring) — meaning the initial Moodle superuser **credential** can be persisted into a security/audit log stream that this repository does not control. Reverse-	instead of a CLI flag, mirroring the `getenv()`-based pattern already used in the `wait-for-db` initContainer.

ID	Severity	Issue	Location	Description	Recommendation
				validation corrected the severity from High to Medium: the value reaches argv via env-var expansion of a Kubernetes Secret at runtime rather than a hardcoded literal secret in the manifest itself, which is one step further from direct compromise. This contrasts with the `wait-for-db` initContainer in the same file, which passes `DB_PASSWORD` via `getenv()` calls inside an inline PHP script rather than as a literal CLI flag, avoiding this exposure.	

11.5.4.3 Exception Handling

No issues found.

11.5.4.4 Error Information Disclosure

No issues found.

11.5.4.5 Debug Information Exposure

No issues found.

11.5.4.6 Security Event Logging

No issues found (this is a one-shot bootstrap Job; there is no ongoing security event stream to evaluate).

11.5.4.7 Component-Specific Recommendations

Remediate LOG-002 by removing the admin password from the process command line.

11.5.5 Component: PostgreSQL Cluster (Crunchy PostgreSQL Operator)

11.5.5.1 Component Overview

Operator-managed PostgreSQL cluster with pgBackRest backups. No custom PostgreSQL logging parameters (e.g., `log_statement`, `log_connections`) are set in `postgrescluster.yaml`.

11.5.5.2 Sensitive Data Exposure

No issues found — no explicit `log_statement`/`log_min_duration_statement` configuration was found that would risk logging query parameters (which could contain PII).

11.5.5.3 Exception Handling

No issues found.

11.5.5.4 Error Information Disclosure

No issues found.

11.5.5.5 Debug Information Exposure

No issues found.

11.5.5.6 Security Event Logging

No issues found — the cluster relies on the Crunchy PostgreSQL Operator's built-in logging defaults; no configuration in this repository disables or weakens them. This assessment could not confirm from the repository alone whether database-level audit logging (e.g., `pgaudit`) is enabled, since no such configuration is present either way.

11.5.5.7 Component-Specific Recommendations

None beyond the general log-retention note in the Overall Security Event Logging Assessment.

11.5.6 Component: Valkey Cache

11.5.6.1 Component Overview

Single-replica Redis-compatible session/cache store.

11.5.6.2 Sensitive Data Exposure

No issues found in `config/valkey/valkey.conf` — no `slowlog`/verbose logging directives that would capture command arguments (which could include session data) were found enabled.

11.5.6.3 Exception Handling

No issues found.

11.5.6.4 Error Information Disclosure

No issues found.

11.5.6.5 Debug Information Exposure

No issues found.

11.5.6.6 Security Event Logging

No issues found.

11.5.6.7 Component-Specific Recommendations

None.

11.5.7 Component: Ops Tooling

11.5.7.1 Component Overview

Shell scripts (`alert.sh`, `backup-integrity.sh`, `moodledata-snapshot.sh`, `moodledata-snapshot-prune.sh`, `restore-rehearsal.sh`) that implement Phase 6 backup integrity checks, snapshots, and alerting. These scripts are the primary audit-trail mechanism for backup/restore health but transmit that audit data over an insecure channel, and one script has an inconsistent temp-file cleanup pattern.

11.5.7.2 Sensitive Data Exposure

No issues found — secrets are retrieved via `oc get secret -o jsonpath` into command-substitution variables, never `echo`'d, and `PGPASSWORD` is only ever exported as an environment variable for `psql`, never printed.

11.5.7.3 Exception Handling

ID	Severity	Issue	Location	Description	Recommendation
LOG-007	Low	Temporary audit-log file	`scripts/ops/restore-rehearsal.sh` line 47 (compare	`backup-integrity.sh` creates `LOGFILE="$(mktemp)"` and	Add `trap 'rm -f "$LOGFILE"; cleanup' EXIT` (or an equivalent combined

ID	Severity	Issue	Location	Description	Recommendation
		not cleaned up on exit	`scripts/ops/backup-integrity.sh` lines 63-65)	immediately registers `trap 'rm -f "$LOGFILE"' EXIT` to remove it on any exit path. `restore-rehearsal.sh` also creates `LOGFILE="$(mktemp)"` but only registers `trap 'cleanup' EXIT`, where `cleanup()` deletes the temporary `PostgresCluster` CR and never removes `$LOGFILE`. The temp file (which accumulates `oc apply`/`oc exec` output, including cluster/namespace topology) is left behind in the job pod's writable layer instead of being cleaned up, inconsistent with the sibling script's pattern. Impact is limited because the Job pod itself is ephemeral and torn down after completion.	trap) in `restore-rehearsal.sh` to match `backup-integrity.sh`'s cleanup discipline.

11.5.7.4 Error Information Disclosure

No issues found.

11.5.7.5 Debug Information Exposure

No issues found.

11.5.7.6 Security Event Logging

ID	Severity	Issue	Location	Description	Recommendation
LOG-003	Medium	Audit/alert data transmitted over unauthenticated, unencrypted SMTP	`scripts/ops/alert.sh` lines 25-32	`alert.sh`'s own header comment states it sends email "via the unauth'd BC Gov SMTP relay." The `swaks` invocation uses `--server "$ALERT_SMTP_HOST" --port 25` with no `--tls`/`--tls-on-connect` and no `--auth-user`/`--auth-password`. This script is the delivery mechanism for `backup-integrity.sh`'s and `restore-rehearsal.sh`'s failure/success emails, which embed `tail -80 "$LOGFILE"` — i.e., genuine audit-trail content (namespace, Postgres cluster name, table row counts, pgBackRest backup ages) — in the email body. That content therefore travels in cleartext over	Where the relay supports it, enable opportunistic or required TLS (`swaks --tls` or `--tls-on-connect`) for the outbound connection, and confirm with platform teams whether SMTP AUTH or network-level restriction (e.g., NetworkPolicy limiting egress to the relay's IP) is available to reduce spoofing risk.

ID	Severity	Issue	Location	Description	Recommendation
				an unauthenticated channel between the pod and the relay, with no integrity or confidentiality protection against interception or spoofing on the network path.	

11.5.7.7 Component-Specific Recommendations

Fix the LOG-007 cleanup-trap gap, and coordinate with platform/network teams to add transport protection to the alert-email path (LOG-003), which also affects `monitoring-observability` (LOG-004).

11.5.8 Component: Network Policy

11.5.8.1 Component Overview

`NetworkPolicy` resources restricting ingress between components.

11.5.8.2 Sensitive Data Exposure

Not applicable — no logging surface in this component.

11.5.8.3 Exception Handling

Not applicable.

11.5.8.4 Error Information Disclosure

Not applicable.

11.5.8.5 Debug Information Exposure

Not applicable.

11.5.8.6 Security Event Logging

No issues found — NetworkPolicy resources do not themselves emit logs in this repository's configuration (no `spec.ingress[].log` equivalent exists for standard Kubernetes NetworkPolicy); flow-log visibility is a cluster-level (CNI) capability outside this repository's control.

11.5.8.7 Component-Specific Recommendations

None.

11.5.9 Component: OpenShift Route

11.5.9.1 Component Overview

`Route` resource exposing the web-container externally with an extended HAProxy timeout.

11.5.9.2 Sensitive Data Exposure

Not applicable.

11.5.9.3 Exception Handling

Not applicable.

11.5.9.4 Error Information Disclosure

Not applicable.

11.5.9.5 Debug Information Exposure

Not applicable.

11.5.9.6 Security Event Logging

No issues found — router-level access logging is a cluster-wide OpenShift Router setting not configured within this repository's `route.yaml`; no evidence either enabling or disabling it was found here.

11.5.9.7 Component-Specific Recommendations

None from within this repository; confirm with platform teams whether router access logs are centrally captured.

11.5.10 Component: Helm Chart Topology

11.5.10.1 Component Overview

Chart scaffolding (`Chart.yaml`, `_helpers.tpl`, values files) — no independent logging behavior of its own.

11.5.10.2 Sensitive Data Exposure

Not applicable.

11.5.10.3 Exception Handling

Not applicable.

11.5.10.4 Error Information Disclosure

Not applicable.

11.5.10.5 Debug Information Exposure

Not applicable.

11.5.10.6 Security Event Logging

Not applicable — this component only assembles the templates assessed individually elsewhere in this document.

11.5.10.7 Component-Specific Recommendations

None.

11.5.11 Component: Monitoring & Observability

11.5.11.1 Component Overview

Prometheus `PodMonitor`/`ServiceMonitor`/`PrometheusRule` and an `AlertmanagerConfig` routing platform alerts to email.

11.5.11.2 Sensitive Data Exposure

No issues found — `PrometheusRule` annotations reference metric labels/values only (connection counts, replication lag bytes, replica counts), not application data or credentials.

11.5.11.3 Exception Handling

Not applicable.

11.5.11.4 Error Information Disclosure

Not applicable.

11.5.11.5 Debug Information Exposure

Not applicable.

11.5.11.6 Security Event Logging

ID	Severity	Issue	Location	Description	Recommendation
LOG-	Medium	Alertmanager	`chart/psa-moodle/temp`	The `AlertmanagerCon`	Set `requireTLS: true` if the relay

ID	Severity	Issue	Location	Description	Recommendation
004		email receiver does not require TLS	`lates/monitoring.yaml` lines 173-179 (line 178)	`fig`'s `email` receiver sets `requireTLS: false` explicitly. Platform alerts (Postgres connection saturation, replication lag, PVC filling, HPA maxed out, PHP-FPM queue saturation) are therefore delivered over the same unauthenticated/unencrypted path as `alert.sh` (LOG-003), to the same BC Gov SMTP relay (`smarthost`).	supports STARTTLS, and validate this is compatible with the shared relay before rollout; track alongside the LOG-003 remediation since both use the same relay.

11.5.11.7 Component-Specific Recommendations

Coordinate `requireTLS` remediation with the `alert.sh` fix (LOG-003) since both share the same SMTP relay.

11.5.12 Component: CI/CD Pipeline

11.5.12.1 Component Overview

GitHub Actions workflows (`build.yml`, `deploy.yml`, `lint.yml`, `scheduled-rebuild.yml`).

11.5.12.2 Sensitive Data Exposure

No issues found — `deploy.yml` reads OpenShift credentials via `secrets.*` context (GitHub Actions automatically masks registered secret values in job logs) and does not `echo`/print secret values directly; conditional messaging (`::notice::...`) only reports whether secrets are configured, not their values.

11.5.12.3 Exception Handling

No issues found.

11.5.12.4 Error Information Disclosure

No issues found.

11.5.12.5 Debug Information Exposure

No issues found.

11.5.12.6 Security Event Logging

No issues found within this repository's workflow definitions.

11.5.12.7 Component-Specific Recommendations

None.

11.5.13 Component: Local Dev Compose

11.5.13.1 Component Overview

`compose.yaml` for local Podman-based development, setting `MOODLE_DEBUG: "1"` by default.

11.5.13.2 Sensitive Data Exposure

No issues found directly in this file; see LOG-005 (filed under `php-fpm-application`) for the downstream effect of the `MOODLE_DEBUG=1` default set here (compose.yaml).

11.5.13.3 Exception Handling

No issues found.

11.5.13.4 Error Information Disclosure

No issues found.

11.5.13.5 Debug Information Exposure

No issues found directly in this file (see LOG-005).

11.5.13.6 Security Event Logging

No issues found.

11.5.13.7 Component-Specific Recommendations

None beyond the LOG-005 remediation.

11.5.14 Component: Documentation & Runbooks

11.5.14.1 Component Overview

Markdown docs describing deployment, hardening, and backup runbooks.

11.5.14.2 Sensitive Data Exposure

Not applicable — documentation only.

11.5.14.3 Exception Handling

Not applicable.

11.5.14.4 Error Information Disclosure

Not applicable.

11.5.14.5 Debug Information Exposure

Not applicable.

11.5.14.6 Security Event Logging

Not applicable.

11.5.14.7 Component-Specific Recommendations

None.

---

12 GitHub Code Security Report

12.1 Summary

Note on data source: This run did not attempt its own live GitHub MCP calls (per explicit invocation instruction, to work around a known environment condition where custom-agent sessions sometimes fail to bind GitHub MCP tools even though the same tools work in the main conversation). Instead it used coordinator-supplied `bridgeData`: a `state=open` query against `owner=bcgov, repo=psa-moodle` that executed **successfully** in the main conversation and returned a genuinely empty array. This is a confirmed clean result — zero open CodeQL/code-scanning alerts — not an unknown/unavailable one, and is reported as such below. This corrects the framing of two prior stubs from earlier attempts in this same session lineage, which encountered a genuinely different condition (this worker's own in-session tool binding being blocked/absent) and correctly declined to report "0 alerts" at that time. That blocked condition applied only to this worker's own tool binding; the coordinator's directly-verified query is a different, valid data path.

Metric	Value
CodeQL enabled	Not independently confirmed — see note below
CodeQL tool version	Not available — no rule/version metadata was included in the bridged query result
Total rules run	Not available — no rule/version metadata was included in the bridged query result
Total open alerts	**0 (confirmed)**
New findings (not in a-1006 output)	0
Enriched a-1006 findings	0
Dismissed alerts	Not verified this session (bridgeData only covered `state=open`)
Scan branch	Not available — no data obtained
Last scan date	2026-09-14

12.1.1 Severity Breakdown

Severity	Count
Critical	0
High	0
Medium	0
Low	0
Informational	0

12.2 CodeQL Alert Inventory

No open CodeQL alerts. **0 open alerts confirmed** via a successfully-executed `state=open` query against `bcgov/psa-moodle` (bridged from the main conversation), not a fallback/degraded default.

Whether CodeQL is actually enabled as a repository feature could not be independently determined from the empty result alone — an empty alert array is consistent with either "enabled, zero findings" or a feature-not-configured response, and no separate rules/version metadata was retrieved to disambiguate. `codeQlEnabled` is therefore recorded as unresolved rather than guessed.

12.3 Taint Paths

No taint-path flows present in open alerts (there are zero open alerts to document paths for).

`cbmProjectName` is `null` — `psa-moodle` is not indexed in codebase-memory (confirmed via `mcp_codebase-memo_list_projects` in a prior session). Independent CBM-based taint-path cross-verification was **not performed** this run for this reason. This is moot for the current result set (zero alerts), but is documented explicitly per instruction rather than silently omitted.

12.4 Cross-Reference: Existing a-1006 Findings

Alert #	Rule ID	Matched Finding ID	Domain Worker	Action
—	—	—	—	No open alerts exist to cross-reference

Since there are zero open CodeQL alerts, there is nothing to match against code-vulnerabilities.json (8 findings: VULN-001–VULN-008, all Low severity). Instead, per the invocation instruction, each existing VULN-001–VULN-008 finding was reviewed for whether it *would* be expected to surface as a CodeQL alert if code scanning were enabled and comprehensive on this repo:

Finding	CWE	Component	Would surface as CodeQL alert?	Rationale
VULN-001	CWE-732	php-fpm-application	No	`directorypermissions = 02777` is a PHP config value; CodeQL has no PHP language support.
VULN-002	CWE-732	php-fpm-application	No	Same as VULN-001 — PHP is not a CodeQL-analyzable language.
VULN-003	CWE-200	php-fpm-application	No	Absence finding in a `.ini` file (missing `expose_php` directive) — not source code

Finding	CWE	Component	Would surface as CodeQL alert?	Rationale
				CodeQL parses.
VULN-004	CWE-16	php-fpm-application	No	Absence finding in a `.ini` file (missing `disable_functions` hardening) — not source code CodeQL parses.
VULN-005	CWE-200	web-container	No	Absence finding in nginx `.conf` syntax — CodeQL does not analyze nginx configuration files.
VULN-006	CWE-693	web-container	No	Absence finding in nginx `.conf` syntax — not a CodeQL-supported source format.
VULN-007	CWE-94	ops-tooling	No	Bash heredoc env-var interpolation in `scripts/ops/moodledata-snapshot.sh` — CodeQL

Finding	CWE	Component	Would surface as CodeQL alert?	Rationale
				has no shell/bash analysis support.
VULN-008	CWE-94	ops-tooling	No	Bash heredoc env-var interpolation in `scripts/ops/restore-rehearsal.sh` — CodeQL has no shell/bash analysis support.

Conclusion: None of the 8 existing findings would be expected to surface as CodeQL alerts even with code scanning fully enabled, because CodeQL's supported languages (C/C++, C#, Go, Java/Kotlin, JavaScript/TypeScript, Python, Ruby, Swift) do not include PHP, shell/bash, nginx configuration, or `.ini` files — the only formats these 8 findings live in. This is independently consistent with the confirmed 0-open-alerts result: a mostly config/infra repo with no first-party code in a CodeQL-supported language would legitimately produce zero alerts regardless of whether the feature is enabled.

12.5 New Findings (Not in a-1006 Output)

All CodeQL alerts were cross-referenced with existing a-1006 findings. No new gaps found — there are zero open CodeQL alerts to derive new findings from.

12.6 Dismissed Alerts

Not verified this session. The `bridgeData` supplied covered only `state=open`; `state=dismissed` was not queried. `dismissedAlertsCount` is recorded as `null` (not 0) to avoid fabricating a count that was never actually retrieved.

---

13 GitHub Secret Scanning Report

Worker: a-1017 | **Assessment:** ra-2026-09-09T045716Z | **Repo:** bcgov/psa-moodle

13.1 Summary

Refresh note (2026-09-14): This run replaces the prior degraded stub (which had reported `toolAvailability: unavailable` after this worker's own live GitHub MCP tool calls failed to bind in its subsession). Per explicit dispatch instruction, this run did **not** re-attempt its own live GitHub MCP calls; it instead used secret scanning alert data already fetched successfully in the main conversation this session (a known environment workaround for custom-agent subsessions failing to bind GitHub MCP tools even when the same tools work in the main chat). Both `state=open` and `state=resolved` queries succeeded and were merged/de-duplicated by alert number, yielding **0 total alerts across all states**. This is reported as a genuine, confirmed zero-alert result — not an unknown/unavailable condition.

Metric	Value
Push protection enabled	Not independently determined this run (only the alert list was bridged, not repository settings)
Push protection bypasses	0 (confirmed — 0 alerts of any kind exist, so 0 bypasses is a direct consequence, not an estimate)
Open alerts (current HEAD)	0 (confirmed via `state=open` query)
Historical alerts (in git history, gone from HEAD)	0 (confirmed via `state=resolved` query)
Total alerts scanned (all states)	0 (de-duplicated by alert number across both queries)
a-1006 findings confirmed by GitHub SA	0
a-1006 findings NOT confirmed (low-confidence)	2

13.1.1 Severity Breakdown (Open Alerts)

Severity	Count
Critical	0
High	0
Medium	0
Low	0

13.2 ⚠ Push Protection Bypasses

No push-protection-bypass alerts exist — this is a direct consequence of the confirmed 0-alert result across both `open` and `resolved` states, not an unscanned/unknown condition. Push protection's enabled/disabled repository setting itself was not independently queried

this run (bridged data covered only the alert list), so it is reported as “not determined” rather than assumed enabled.

13.3 Active Secrets (Open Alerts — Current HEAD)

No open secret scanning alerts. GitHub Secret Scanning’s `state=open` query returned zero alerts for this repository. Secrets may still exist in git history — see Historical Secrets section (also zero, see below).

13.4 Historical Secrets (Present in Git History — Gone from HEAD)

No historical secret alerts found. a-1017 queried all alert states (`state=open` and `state=resolved`), merged and de-duplicated by alert number, and confirmed 0 total alerts of any state.

Query coverage confirmed: `list_secret_scanning_alerts`-equivalent data covers both `state=open` and `state=resolved`. Historical alerts are included in this zero-alert result.

13.5 Cross-Reference: a-1006 Secrets Findings

Classification of all findings from the `secrets` domain worker against GitHub Secret Scanning results.

a-1006 Finding ID	Description	GitHub SA Alert #	GitHub Confirmed	Confidence Adjustment
SECRET-001	Hardcoded weak fallback DB credential (`moodle/moodle`) in `config/moodle/config.local.php`	—	false	Downgraded to low-confidence — not confirmed by GitHub SA
SECRET-002	Hardcoded weak plaintext PostgreSQL password (`moodle`) in `compose.yaml` db/php/cron service blocks	—	false	Downgraded to low-confidence — not confirmed by GitHub SA

Consistency assessment: The 0-alert GitHub Secret Scanning result is **consistent with, and does not contradict,** SECRET-001/SECRET-002. Both a-1006 findings are generic, low-entropy default strings (the literal word `moodle` reused as both username and password) rather than a recognized secret-provider token pattern (e.g. an AWS access key, GitHub PAT, or other high-entropy/prefixed format) that GitHub's pattern-based secret scanning detectors are designed to match. GitHub Secret Scanning is not expected to flag generic low-entropy default credentials of this kind, so their absence from the GitHub SA alert list is expected behavior, not a sign the alerts are false positives or that the scan missed something it should have caught.

13.5.1 Unconfirmed a-1006 Findings (Low-Confidence)

a-1006 findings NOT matched by any GitHub Secret Scanning alert. These may be false positives, test fixtures, or non-standard patterns GitHub SA doesn't cover.

a-1006 Finding ID	Description	Reason Not Confirmed	Recommended Action
SECRET-001	Hardcoded weak fallback DB credential in `config/moodle/config.local.php`	Generic low-entropy default value (`moodle`), not a recognized secret-provider token pattern GitHub SA scans for	Non-standard format — treat as Medium confidence; verify manually and remediate regardless of GitHub SA scope
SECRET-002	Hardcoded weak plaintext PostgreSQL password in `compose.yaml`	Generic low-entropy default value (`moodle`), not a recognized secret-provider token pattern GitHub SA scans for	Non-standard format — treat as Medium confidence; verify manually and remediate regardless of GitHub SA scope

13.6 Worker dispatch note

This run used bridged secret scanning alert data fetched directly in the main conversation this session (per explicit dispatch instruction, this worker did not re-attempt its own live GitHub MCP calls, which had failed to bind in a prior stub run of this same worker's subsession). Both `state=open` and `state=resolved` queries succeeded in the main conversation and were merged/de-duplicated by alert number, confirming **0 total alerts across all states**. No alert number, secret type, or push-protection-bypass event was invented; the zero-alert result is reported as genuine and verified, superseding the prior stub's `toolAvailability: unavailable` result.

14 Dependency Inventory

This document provides a high-level overview of dependencies used in the codebase. psa-moodle is a **container/Helm deployment repository** — there is no `package.json`/`composer.json`/lock-file style application dependency manifest in-repo; "dependencies" here means pinned/unpinned container base images, git-cloned Moodle plugin/theme sources, build-time binary downloads, and the Helm chart's own topology. For detailed analysis of each component's dependencies, refer to the component-specific files in the `component-dependencies` directory.

> **CVE/EOL sourcing note:** `vulnxMcp` was unavailable for this run. Any EOL or CVE-adjacent claim below is explicitly marked as based on documented public knowledge (vendor lifecycle pages, general release cadence) rather than a live vulnerability-database lookup, per the evidence-grounding rules. No CVE IDs are asserted for any specific patch level, because the floating tags used throughout this repo mean the exact patch level actually running is not determinable from the repository alone.

14.1 Runtime Dependencies Summary

14.1.1 Component: PHP-FPM Application Container

Library	Version	Associated With	Key Security/Technical Debt Notes
php	8.3-fpm-bookworm	PHP-FPM runtime	Floating minor-version tag, not digest-pinned; approaching end of php.net active support window (general knowledge)
moodle (core)	MOODLE_405_STABLE (branch)	Application code	Cloned from a floating stable branch, not a tag/commit SHA
moodle-mod_hvp	`master` branch	H5P interactive content plugin	Floating unstable branch, recursive submodules, no pin
moodle-course_search, moodle-local_githubsync, psaelmsync, pathcurator-moodle,	default branch (unspecified)	First-party/BC Gov plugins + theme	No `--branch`/tag/commit pin at all

Library	Version	Associated With	Key Security/Technical Debt Notes
bcgovpsa theme			
docker-php-extension-installer (mlocati)	`releases/latest`	Build tool that installs PHP extensions	Fetched via floating “latest” URL, no checksum verification
php-fpm-healthcheck	`master` branch	Liveness/readiness probe script	Fetched via floating branch URL, no checksum verification
7 additional PHP extensions (gd, intl, ldap, exif, mbstring, opcache, pdo_pgsql, pgsql, soap, xsl, zip, redis)	bundled via install-php-extensions	Moodle runtime requirements	See detailed component file

14.1.2 Component: Web Container (nginx)

Library	Version	Associated With	Key Security/Technical Debt Notes
nginxinc/nginx-unprivileged	1.27-alpine	Front-end web server	Floating minor-version tag, not digest-pinned
curl	apk latest (Alpine 3.x repo)	HEALTHCHECK client	Installed via `apk add` with no version pin

14.1.3 Component: Cron Workload

Library	Version	Associated With	Key Security/Technical Debt Notes
php	8.3-cli-bookworm	Cron CLI runtime	Floating minor-version tag, not digest-pinned
docker-php-extension-	`releases/latest`	Build tool	Same unpinned-fetch pattern as php-fpm-application

Library	Version	Associated With	Key Security/Technical Debt Notes
installer (mlocati)			
psa-moodle-php image (Moodle core + plugins)	inherited via `COPY --from=src`	Application code executed by cron.php	Inherits all plugin-pinning gaps from php-fpm-application

14.1.4 Component: Install Job

Library	Version	Associated With	Key Security/Technical Debt Notes
psa-moodle-cron image	`.Values.image.tag`	One-shot DB bootstrap (`install_database.php`)	No dependencies of its own; inherits the cron image's dependency surface

14.1.5 Component: PostgreSQL Cluster (Crunchy PostgreSQL Operator)

Library	Version	Associated With	Key Security/Technical Debt Notes
Crunchy PostgreSQL (operator-managed image)	postgresVersion 15 (patch level operator-controlled)	Primary datastore	Actual Postgres 15.x minor/patch and the Crunchy Operator's own version are not pinned or recorded anywhere in this repository
pgBackRest	bundled with operator	Backup/restore tooling	Version not pinned in-repo; inherited from whatever the cluster-installed operator ships

14.1.6 Component: Valkey Cache

Library	Version	Associated With	Key Security/Technical Debt Notes
valkey/valkey	7.2-alpine	Session/cache store	Floating minor-version tag, not digest-pinned

14.1.7 Component: Moodledata Shared Storage

Library	Version	Associated With	Key Security/Technical Debt Notes
No dependencies identified	—	RWX PersistentVolumeClaim manifest only	Not applicable — no software runs in this component

14.1.8 Component: Ops Tooling

Library	Version	Associated With	Key Security/Technical Debt Notes
alpine	3.20	Ops image base	Floating minor-version tag; approaching end of Alpine's ~2-year support window (general knowledge)
oc (OpenShift client)	4.15.20	Cluster exec/backup orchestration	Downloaded over HTTPS with no checksum/signature verification
swaks	v20240103.0	SMTP alerting client	Pinned to a tag, but fetched via raw GitHub URL with no checksum verification
bash, curl, jq, perl, perl-net-ssleay, tini, postgresql-client, ca-certificates	Alpine 3.20 repo (floating)	Script runtime/orchestration	Installed via `apk add --no-cache`, versions floating with the Alpine branch

14.1.9 Component: NetworkPolicy Boundary

Library	Version	Associated With	Key Security/Technical Debt Notes
No dependencies identified	—	Kubernetes NetworkPolicy manifests only	Not applicable

14.1.10 Component: OpenShift Route

Library	Version	Associated With	Key Security/Technical Debt Notes
No dependencies identified	—	OpenShift Route manifest only	Not applicable

14.1.11 Component: Helm Chart / Deployment Topology

Library	Version	Associated With	Key Security/Technical Debt Notes
No Helm subchart dependencies	—	`Chart.yaml` has no `dependencies:` block	Analyzed — genuinely zero chart-level dependencies, not a gap

14.1.12 Component: Monitoring and Observability

Library	Version	Associated With	Key Security/Technical Debt Notes
hipages/php-fpm_exporter	2.2.0	PHP-FPM Prometheus metrics	Fully pinned to an exact version — no issue found
Crunchy pgMonitor exporter	bundled with operator	Postgres Prometheus metrics	Version not pinned in-repo (same operator-opacity gap as postgresql-cluster)

14.1.13 Component: CI/CD Pipeline

Library	Version	Associated With	Key Security/Technical Debt Notes
actions/checkout	v4	All workflows	Pinned to major-version tag (standard practice)
azure/setup-helm	v4 (helm binary v3.14.3)	lint.yml, deploy.yml	Helm binary itself pinned to an exact version
redhat-actions/oc-login	v1	deploy.yml	Pinned to major-version tag
actions/github-script	v7	scheduled-rebuild.yml	Pinned to major-version tag

14.1.14 Component: Local Dev Compose Stack

Library	Version	Associated With	Key Security/Technical Debt Notes
postgres	15-alpine	Local dev database	Floating minor-version tag, not digest-pinned
valkey/valkey	7.2-alpine	Local dev cache	Floating minor-version tag, not digest-pinned
psa-moodle php/web/cron (registry overlay)	`${TAG:-dev-local}`	`make smoke-registry`	Defaults to a floating “dev-local” tag when `$TAG` is unset

14.1.15 Component: Documentation & Runbooks

Library	Version	Associated With	Key Security/Technical Debt Notes
No dependen	—	Markdown documentation only	Not applicable

Library	Version	Associated With	Key Security/Technical Debt Notes
cies identified			

14.2 Development Dependencies Summary

- **PHP-FPM Application Container**: Build-stage-only tooling — `debian:bookworm-slim` (Moodle git-clone builder stage), `git`, `ca-certificates` (apt); none of these ship in the final runtime image.
- **CI/CD Pipeline**: GitHub Actions runner tooling (`actions/checkout`, `azure/setup-helm`, `redhat-actions/oc-login`, `actions/github-script`) plus preinstalled `ubuntu-latest` tools (`podman`, `shellcheck`, `yamllint`) with no explicit version pins for the preinstalled tools.
- **Local Dev Compose Stack**: No separate dev-only dependencies beyond the runtime images already listed above; this stack mirrors production topology for local iteration.
- All other components (web-container, cron-workload, install-job, postgresql-cluster, valkey-cache, moodledata-storage, ops-tooling, network-policy, openshift-route, helm-chart-topology, monitoring-observability, documentation-runbooks) have no development-only dependencies distinct from their runtime dependencies.

14.3 System Requirements

- PHP 8.3 (FPM) — php-fpm-application
- PHP 8.3 (CLI) — cron-workload, install-job
- PostgreSQL 15 — postgresql-cluster (via Crunchy PostgreSQL Operator, which must be pre-installed cluster-wide; not managed by this Helm chart)
- Valkey 7.2 — valkey-cache
- nginx 1.27 (Alpine, unprivileged variant) — web-container
- Alpine 3.20 — ops-tooling
- Debian bookworm (12) — php-fpm-application build stage (`debian:bookworm-slim`) and PHP runtime base (`php:*-bookworm`)
- Helm — kubeVersion `>=1.27.0` (`chart/psa-moodle/Chart.yaml`)
- OpenShift Container Platform client (`oc`) 4.15.20 — ops-tooling
- Podman / Podman Compose — local-dev-compose

14.4 Overall Summary

- Total Runtime Dependencies: 13 findings raised (see `component-dependencies/` for the full per-component inventory tables; the underlying library/image count across all components is ~30, most of which have no issues)

- Total Development Dependencies: 0 findings raised (build-stage-only tooling and CI runner tooling identified above have no distinct issues beyond what's covered in the runtime findings)
- Components with Most Critical Dependencies: PHP-FPM Application Container (6 findings, including the two High-severity unpinned-plugin-source findings), Ops Tooling (2 findings)
- Major risk assessment areas:
    1. **Unpinned upstream plugin/theme source code** — the HVP plugin (`master` branch) and five first-party/BC Gov repos (default branch, no tag/commit SHA) are cloned directly into the production PHP-FPM image with no version pin, checksum, or manual review gate; a compromised or unreviewed upstream commit becomes production code on the next scheduled or triggered rebuild.
    2. **Unpinned build-time binary/script downloads** — `docker-php-extension-installer` (GitHub "releases/latest") and `php-fpm-healthcheck` (`master` branch raw URL) are fetched with no version pin and no checksum verification.
    3. **Operator-managed dependency opacity** — the Crunchy PostgreSQL Operator's own version and the exact Postgres 15.x patch level it deploys are not recorded anywhere in this repository, making the actual security patch level of the primary datastore indeterminate from the repo alone.
    4. **Floating base-image tags across the board** — nginx, PHP, Alpine, and Valkey images are all pinned to minor-version tags (e.g. `1.27-alpine`, `8.3-fpm-bookworm`, `3.20`, `7.2-alpine`) rather than immutable digests, which is intentional (the `scheduled-rebuild.yml` workflow exists specifically to pick up upstream security patches weekly) but sacrifices build reproducibility.

Refer to the component-specific files for detailed analysis: - Web Container (nginx) Dependencies - PHP-FPM Application Container Dependencies - Cron Workload Dependencies - Install Job Dependencies - PostgreSQL Cluster Dependencies - Valkey Cache Dependencies - Moodledata Shared Storage Dependencies - Ops Tooling Dependencies - NetworkPolicy Boundary Dependencies - OpenShift Route Dependencies - Helm Chart / Deployment Topology Dependencies - Monitoring and Observability Dependencies - CI/CD Pipeline Dependencies - Local Dev Compose Stack Dependencies - Documentation & Runbooks Dependencies

---

15 GitHub Dependency Intelligence Report

Template version: 1.0.0 | **Worker:** a-1015 | **Output:** `rapid-assessment/findings/dependencies/github-dependency-intelligence.md`

Note on data source (3rd attempt, 2026-09-14, resolved via coordinator bridge): Two prior attempts in this run could not obtain live GitHub Dependabot/Security Advisory data — attempt 1 found no `mcp_github_*`/`mcp_vulnx-mcp_*` tool of any name in this worker's session tool registry (and no `tool_search` to look for one); attempt 2 found the same tool names registered but returning "disabled by the user, and cannot be called." This 3rd attempt did **not** retry live calls in this worker session — per explicit coordinator instruction, GitHub Dependabot alert and Security Advisory data was already fetched successfully in the main conversation (where GitHub MCP tool binding does work) and supplied here as `bridgeData` with explicit chain-of-custody (exact owner/repo, exact tool calls named, results already shown to the user before this dispatch). That data is used below as authoritative, verified live data — not as unverified instructions.

15.1 Summary

Metric	Value
Dependabot enabled	true (successful paginated `list_dependabot_alerts` response, not an error/disabled-feature response)
Total open alerts	0
New findings (not in a-1009)	0
Enriched a-1009 findings	0
Security advisories	0
Scan date	2026-09-14

15.1.1 Severity Breakdown

Severity	Count
Critical	0
High	0
Medium	0
Low	0
Informational	0

(All zero because `list_dependabot_alerts(owner=bcgov, repo=psa-moodle, state=open)` and `list_repository_security_advisories(owner=bcgov, repo=psa-moodle)` were both confirmed successfully executed and returned genuinely empty results — this is a real, verified "zero open alerts / zero advisories" finding, not an unavailable-data placeholder.)

15.2 Dependabot Alert Inventory

No open Dependabot alerts. `list_dependabot_alerts(owner=bcgov, repo=psa-moodle, state=open)` returned `{ "alerts": [], "pageInfo": { "hasNextPage": false,`

`"hasPreviousPage": false } }` — a confirmed, verified empty result (single page, no pagination remaining), not a tool failure.

Alert #	Package	Vulnerable Version	Fixed In	CVE	GHSA	Severity	Manifest
—	—	—	—	—	—	—	—

15.3 Cross-Reference: Existing a-1009 Findings

No open Dependabot alerts were returned, so there is nothing to cross-reference against a-1009 findings on a per-alert basis. All 13 `rapid-assessment/data/dependencies.json` findings (DEP-001 through DEP-013) were independently reviewed: none carry a `cveId`/GHSA reference or a non-null `cve_count` — all are `supply-chain-risk` (unpinned git sources, unverified binary downloads, floating base-image tags) or `outdated-dependency`/EOL issue types (DEP-006 PHP 8.3 EOL, DEP-008 Alpine 3.20 EOL) with `cve_count: null` / `cves: []`. None of these would have matched a GitHub-native Dependabot alert in any case, so the confirmed zero-alert result is fully consistent with a-1009's independent findings.

Alert #	Matched Finding ID	CVE Match	Package Match	Action
—	—	—	—	N/A — 0 open alerts to cross-reference

15.4 New Findings (Not in a-1009 Output)

All Dependabot alerts were cross-referenced with a-1009 findings. No new gaps found — because there were 0 open Dependabot alerts to begin with, confirmed via successful live API response (bridged), not an unavailable/unverified condition.

15.5 Historical and Dismissed Alerts

Not queried this session. The bridged data supplied to this worker covered only `list_dependabot_alerts(state=open)` and `list_repository_security_advisories` (unfiltered) — `state=dismissed` was not part of that bridge and no live GitHub MCP tool was available in this worker's own session to query it independently (see attempts 1–2 above). This is a genuine gap, not a confirmed "no dismissed alerts" result.

Alert #	Package	CVE	Resolution	Risk Note
—	—	—	—	Not queried this session (see note above)

15.6 Security Advisories

No published security advisories found for this repository's own packages. `list_repository_security_advisories(owner=bcgov, repo=psa-moodle)` returned `[]` — a confirmed, verified empty result.

Advisory	Severity	Package	Summary	Published
—	—	—	—	—

15.7 vulnx-mcp Enrichment Attempt (DEP-006, DEP-008)

The invocation requested optional enrichment of `DEP-006` (PHP 8.3 EOL) and `DEP-008` (Alpine 3.20 EOL) with authoritative CVE/KEV data via `vulnx_search`/`vulnx_analyze`/`vulnx_get_by_id`, since `toolReadiness.vulnxMcp` was reported as `true` at invocation. No `mcp_vulnx-mcp_*` tool of any name — and no `tool_search` function to discover one — was present in this worker's own session tool registry (consistent with attempts 1–2 above). Enrichment could not be attempted. No CVE ID, CVSS score, or KEV status was fabricated or invented for either finding; both remain exactly as a-1009 reported them (`cve_count: null`, `cves: []`, EOL-date-based reasoning only). This should be re-attempted in a session/environment where vulnx-mcp is actually bound.

---

16 CI/CD Pipeline Dependencies

This document provides a detailed analysis of dependencies for the CI/CD Pipeline component.

16.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

16.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
actions/checkout	v4	Repository checkout, used in all four workflows	Pinned to a major-version tag (@v4), not a commit SHA — standard, widely-accepted GitHub Actions practice. Evidence: build.yml, lint.yml, deploy.yml.
azure/setup-helm	v4 (installs Helm binary `v3.14.3`)	Installs Helm for `helm`	Action pinned to major version; the installed Helm binary itself is pinned to an exact patch version. Evidence: lint.yml, deploy.yml.

Library	Version	Purpose	Security/Technical Debt Notes
		`lint`/`helm template`/`helm upgrade` steps	
redhat-actions/oc-login	v1	Authenticates to the target OpenShift cluster before `helm upgrade --install`	Pinned to a major-version tag. Evidence: deploy.yml.
actions/github-script	v7	Dispatches `build.yml` on the weekly scheduled-rebuild trigger	Pinned to a major-version tag. Evidence: scheduled-rebuild.yml.
Podman, shellcheck, yamllint	preinstalled on `ubuntu-latest` runner, no explicit version pin	Container builds (`build.yml`) and linting (`lint.yml`)	These tools are whatever version GitHub ships on the `ubuntu-latest` runner image at execution time; no explicit version pin exists in this repository for them.

16.3 Development Dependencies

- Same as Runtime Dependencies above — CI/CD tooling is inherently build/test-time only and does not ship in any runtime container image.

16.4 Dependency Tree Summary

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
actions/checkout	v4	N/A	1	GitHub Marketplace action; no further transitives

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
				tracked in-repo.
azure/setup-helm	v4	helm@v3.14.3	2	The action installs the pinned Helm binary as its direct effect.
redhat-actions/oc-login	v1	N/A	1	GitHub Marketplace action; no further transitives tracked in-repo.
actions/github-script	v7	N/A	1	GitHub Marketplace action; no further transitives tracked in-repo.

Source: `.github/workflows/build.yml`, `.github/workflows/lint.yml`, `.github/workflows/deploy.yml`, `.github/workflows/scheduled-rebuild.yml` (no lock file present for GitHub Actions; `lockFileAvailable: false`).

16.5 Security Analysis

16.5.1 High Risk Issues

None identified for this component.

16.5.2 Technical Debt

None raised as a formal finding — all pinned actions use major-version tags (industry-standard practice, not SHA-pinning, but not flagged as a defect here) and the only exact-version pin present (Helm `v3.14.3`) is fully resolved. No CI/CD dependency issues meeting the severity thresholds in the analysis rubric were identified.

---

17 Cron Workload Dependencies

This document provides a detailed analysis of dependencies for the Cron Workload component.

17.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

17.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
php	8.3-cli-bookworm	PHP CLI runtime that executes `admin/cli/cron.php`	Floating minor-version tag, not digest-pinned — see DEP-013. Same PHP-8.3 approaching-EOL consideration documented for php-fpm-application applies here (`cve_count` not populated, no live lookup performed).
docker-php-extension-installer (mlocati)	`releases/latest`	Installs the PHP extensions below	Fetched via a floating "latest release" URL with no version pin or checksum verification — identical pattern to DEP-003 in php-fpm-application, independently re-fetched for this image.
gd, intl, ldap, exif, mbstring,	version bundled with install-	Moodle CLI runtime extension	Installed by the unpinned installer above.

Library	Version	Purpose	Security/Technical Debt Notes
opcache, pdo_pgsql, pgsql, soap, xsl, zip, redis	php-extensions (indeterminate — tool is unpinned)	requirements	
psa-moodle-php image (Moodle core + all plugins/theme)	inherited via `ARG PHP_IMAGE` + `COPY --from=src --chown=www-data:0 /var/www/html /var/www/html`	Application code executed by `cron.php`	This image does not itself clone Moodle or any plugin — it copies the already-built `/var/www/html` tree from the php-fpm-application image. It therefore inherits, unchanged, all of that image's unpinned-source risk (HVP `master` branch, five first-party/BC Gov repos with no branch/tag pin, and the floating `MOODLE_405_STABLE` branch).
ca-certificates	Debian bookworm apt repo (floating)	TLS trust store	Installed via `apt-get install` with no version pin.

17.3 Development Dependencies

- None identified. This is a single runtime-stage image (`FROM php:8.3-cli-bookworm`) with no separate build/compile stage of its own.

17.4 Dependency Tree Summary

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
php	8.3-cli-bookworm	gd@unpinned, intl@unpinned, ldap@unpinned, exif@unpinned, mbstring@unpinned, opcache@unpinned, pdo_pgsql@unpinned, pgsql@unpinned, soap@unpinned, xsl@unpinned, zip@unpinned, redis@unpinned	2	All 12 extensions installed by the unpinned `install-php-extensions` tool (Cont

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
				ainerfile.cron).
docker-php-extension-installer	latest (floating)	N/A	1	Single-file build tool.
psa-moodle-php image (build-arg `PHP_IMAGE`)	`localhost/psa-moodle-php:dev` (build-time arg, not a registry-resolved semantic version)	moodle-core@MOODLE_405_STABLE, moodle-mod_hvp@master, 5×first-party-plugins@default-branch	2	Inherited transitively from the php-fpm-application build; see that component's dependency tree for the full plugin list.

Source: `Containerfile.cron` (no lock file present; `lockFileAvailable: false`).

17.5 Security Analysis

17.5.1 High Risk Issues

None raised directly against this component's own manifest; the underlying unpinned-plugin-source risk (DEP-001, DEP-002) is inherited from the php-fpm-application image this component is built from and is not re-counted here to avoid double-counting the same finding across components.

17.5.2 Technical Debt

1. **[DEP-013] PHP CLI base image pinned to a floating minor-version tag, not an immutable digest**: Containerfile.cron reads `FROM php:8.3-cli-bookworm`. As with the web-container and php-fpm-application base images, this tag floats with upstream rebuilds and is not digest-pinned, so the exact bytes running at any point in time are not reproducible or recorded in this repository.

---

18 Documentation & Runbooks Dependencies

This document provides a detailed analysis of dependencies for the Documentation & Runbooks component.

18.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

18.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
No dependencies identified	—	—	This component consists entirely of Markdown documentation files (`README.md`, `docs/*.md`) with no executable code, container image, or software package of any kind.

18.3 Development Dependencies

None — not applicable.

18.4 Dependency Tree Summary

No transitive dependencies detected. Source: not applicable — this component has no manifest file of any kind; it is prose documentation only.

18.5 Security Analysis

18.5.1 High Risk Issues

None identified — not applicable, no software surface.

18.5.2 Technical Debt

None identified — not applicable, no software surface.

---

19 Helm Chart / Deployment Topology Dependencies

This document provides a detailed analysis of dependencies for the Helm Chart / Deployment Topology component.

19.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

19.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
No Helm subchart dependencies	—	`chart/psa-moodle/Chart.yaml` has no `dependencies:` block	Confirmed via direct inspection of Chart.yaml (`apiVersion: v2`, `name: psa-moodle`, `type: application`, `version: 0.1.0`, `appVersion: "4.5"`, `kubeVersion: ">=1.27.0"`) — no `dependencies:` key is present, meaning this chart declares and pulls zero subcharts. This is a genuine analyzed-and-confirmed absence, not a coverage gap.

19.3 Development Dependencies

- Helm binary itself: pinned to `v3.14.3` in CI (lint.yml, deploy.yml) via `azure/setup-helm@v4`.
- `kubeVersion: ">=1.27.0"` constraint in Chart.yaml — enforced by Helm at install/upgrade time, not a package dependency per se.

19.4 Dependency Tree Summary

No transitive dependencies detected. Source: `chart/psa-moodle/Chart.yaml` — the chart declares no `dependencies:` entries, so there are zero direct or transitive Helm subchart dependencies to enumerate.

19.5 Security Analysis

19.5.1 High Risk Issues

None identified for this component.

19.5.2 Technical Debt

None identified for this component — the absence of a `dependencies:` block was verified directly and represents a simple, self-contained chart topology rather than a gap.

20 Install Job Dependencies

This document provides a detailed analysis of dependencies for the Install Job component.

20.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

20.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
psa-moodle-cron image ({{ include "psa-moodle.image.cron" . }})	`.Values.image.tag` (chart default `"dev"`)	Runs `admin/cli/install_database.php` as a one-shot Helm post-install hook	This component declares no dependencies of its own — both the `wait-for-db` initContainer and the `install` container reuse the cron image verbatim (job-install.yaml). It therefore inherits, unchanged, every dependency and finding documented for the cron-workload component (PHP 8.3 CLI floating tag, unpinned `install-php-extensions` fetch, and the Moodle-core/plugin-pinning gaps inherited further upstream from php-fpm-application).

20.3 Development Dependencies

None identified. This component has no build stage of its own — it is a Kubernetes `Job` manifest that references a pre-built image.

20.4 Dependency Tree Summary

No new dependencies are introduced by this component's own manifest.

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
psa-moodle-cron image	`.Values.image.tag`	(see cron-workload component for the full inherited tree: php@8.3-cli-bookworm, docker-php-extension-installer@latest, moodle-core@MOODLE_405_STABLE, 6× unpinned plugin/theme repos)	1 (this manifest introduces no new transitives of its own)	Source: `chart/psa-moodle/templates/job-install.yaml`.

Source: `chart/psa-moodle/templates/job-install.yaml` (no lock file; `lockFileAvailable: false`). No dependencies are declared directly in this file beyond the referenced pre-built image.

20.5 Security Analysis

20.5.1 High Risk Issues

None raised directly against this component's own manifest. All inherited risk is documented and counted once against the php-fpm-application and cron-workload components to avoid double-counting the same underlying defect.

20.5.2 Technical Debt

None raised directly against this component's own manifest.

---

21 Local Dev Compose Stack Dependencies

This document provides a detailed analysis of dependencies for the Local Dev Compose Stack component.

21.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

21.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
postgres	15-alpine	Local dev database (dev-only substitute for the Crunchy-managed cluster used in Helm deployments)	Floating minor-version tag (compose.yaml), not digest-pinned. Local-dev-only; does not affect the Helm-deployed postgresql-cluster component.
valkey/valkey	7.2-alpine	Local dev cache	Floating minor-version tag (compose.yaml), not digest-pinned — same tag used in the Helm-deployed valkey-cache component.

Library	Version	Purpose	Security/Technical Debt Notes
localhost/psa-moodle-php:dev, localhost/psa-moodle-web:dev, localhost/psa-moodle-cron:dev	:dev (locally built, not registry-resolved)	Local dev application images built via make build/make up	Built from this repo's own Containerfiles; not an external dependency, but the :dev tag itself is floating/mutable by design for local iteration.
artifacts.developer.gov.bc.ca/a58ce1-tools/psa-moodle/{php,web,cron}	${TAG:-dev-local}	compose.registry.yaml overlay used by make smoke-registry to verify registry-pushed images	Defaults to a floating dev-local tag whenever the $TAG environment variable is not explicitly set at invocation time — see DEP-012.

21.3 Development Dependencies

None distinct from the runtime dependencies above — this entire component exists to reproduce the runtime topology locally for development.

21.4 Dependency Tree Summary

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
postgres	15-alpine	N/A	1	Standard upstream Postgres Alpine image; no additional packages layere

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
				d on top in this reposi tory.
valkey/valkey	7.2-alpine	N/A	1	Stand ard upstr eam Valke y Alpine image .
psa-moodle php/web/cron (registry overlay)	`${TAG:-dev-local}`	(inherits the full php-fpm-application / cron-workload / web-container dependency trees, since these are the same images built from this repo's Containerfiles)	2	Sourc e: `compo se.re gistr y.yam l`.

Source: `compose.yaml`, `compose.registry.yaml` (no lock file present for container image references; `lockFileAvailable: false`).

21.5 Security Analysis

21.5.1 High Risk Issues

None identified for this component.

21.5.2 Technical Debt

1. **[DEP-012] Registry-overlay compose file defaults to a floating "dev-local" tag when `$TAG` is unset**: compose.registry.yaml sets `image: artifacts.developer.gov.bc.ca/a58ce1-tools/psa-moodle/php:${TAG:-dev-local}` (and identically for `web`/`cron`). If an operator runs `make smoke-registry` without explicitly exporting `TAG`, the compose stack silently pulls whatever image currently carries the mutable `dev-local` tag in the Artifactory registry rather than a specific, reproducible build. This is local-dev/smoke-test tooling only and does not affect any deployed environment, which keeps the severity Low.

22 Monitoring and Observability Dependencies

This document provides a detailed analysis of dependencies for the Monitoring and Observability component.

22.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

22.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
hipages/php-fpm_exporter	2.2.0	PHP-FPM Prometheus metrics sidecar	Fully pinned to an exact semantic version (values.yaml) — `repository/tag` fully resolved, no floating tag. No live lookup was performed to confirm whether 2.2.0 is the latest available release; this is noted as an inventory observation only, not a finding.
Crunchy pgMonitor exporter	bundled with the Crunchy PostgreSQL Operator, version not pinned in-repo	Postgres Prometheus metrics (enabled via `{{- if .Values.monitoring.enabled }}` in postgrescluster.yaml)	Same operator-opacity gap documented for the postgresql-cluster component — the exporter's version is controlled entirely by whichever Crunchy PostgreSQL Operator version is installed cluster-wide, not by this chart.

22.3 Development Dependencies

None identified — this component is Prometheus/OpenShift user-workload-monitoring wiring (`PodMonitor`, `ServiceMonitor`, `PrometheusRule`, `AlertmanagerConfig`), all declarative Kubernetes objects with no build step.

22.4 Dependency Tree Summary

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
hipages/php-fpm_exporter	2.2.0	N/A	1	Fully pinned, single-

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
				purpose exporter image; no further transitives tracked in-repo.
Crunchy pgMonitor exporter	operator-bundled (unpinned)	N/A	1	Version resolved entirely outside this repository by the cluster-installed Crunchy PostgreSQL Operator.

Source: `chart/psa-moodle/values.yaml` and `chart/psa-moodle/templates/postgrescluster.yaml` (no lock file present; `lockFileAvailable: false`).

22.5 Security Analysis

22.5.1 High Risk Issues

None identified for this component.

22.5.2 Technical Debt

None raised as a new finding for this component — the `php-fpm_exporter` image is fully pinned (good practice, no issue), and the Crunchy pgMonitor exporter's opacity is already captured as **DEP-010** against the postgresql-cluster component to avoid double-counting the same underlying operator-visibility gap.

---

23 Moodledata Shared Storage Dependencies

This document provides a detailed analysis of dependencies for the Moodledata Shared Storage component.

23.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

23.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
No dependencies identified	—	—	This component is a single `PersistentVolumeClaim` manifest (moodledata-pvc.yaml) with no container image, no runtime, and no software of its own — it is a ReadWriteMany volume mounted by the php-fpm-application and cron-workload components.

23.3 Development Dependencies

None — not applicable.

23.4 Dependency Tree Summary

No transitive dependencies detected. Source: `chart/psa-moodle/templates/moodledata-pvc.yaml` — this manifest declares only a `PersistentVolumeClaim` spec (access mode, storage class, size), with no dependency-manager manifest of any kind.

23.5 Security Analysis

23.5.1 High Risk Issues

None identified — not applicable, no software surface.

23.5.2 Technical Debt

None identified — not applicable, no software surface.

---

24 NetworkPolicy Boundary Dependencies

This document provides a detailed analysis of dependencies for the NetworkPolicy Boundary component.

24.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

24.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
No dependencies identified	—	—	This component consists solely of Kubernetes `NetworkPolicy` manifests (networkpolicy.yaml) — declarative traffic-selector rules with no container image, runtime, or software package of its own.

24.3 Development Dependencies

None — not applicable.

24.4 Dependency Tree Summary

No transitive dependencies detected. Source: `chart/psa-moodle/templates/networkpolicy.yaml` — pure Kubernetes API objects, no dependency-manager manifest of any kind.

24.5 Security Analysis

24.5.1 High Risk Issues

None identified — not applicable, no software surface.

24.5.2 Technical Debt

None identified — not applicable, no software surface.

---

25 OpenShift Route Dependencies

This document provides a detailed analysis of dependencies for the OpenShift Route component.

25.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

25.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
No dependencies identified	—	—	This component consists solely of an OpenShift `Route` manifest (route.yaml) — a declarative ingress object with no container image, runtime, or software package of its own. TLS termination is handled by the OpenShift router, which is outside the scope of this repository.

25.3 Development Dependencies

None — not applicable.

25.4 Dependency Tree Summary

No transitive dependencies detected. Source: `chart/psa-moodle/templates/route.yaml` — pure Kubernetes/OpenShift API object, no dependency-manager manifest of any kind.

25.5 Security Analysis

25.5.1 High Risk Issues

None identified — not applicable, no software surface.

25.5.2 Technical Debt

None identified — not applicable, no software surface.

---

26 Ops Tooling Dependencies

This document provides a detailed analysis of dependencies for the Ops Tooling component.

26.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

26.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
alpine	3.20	Base OS for the ops image	Floating minor-version tag; approaching end of Alpine's ~2-year branch support window per publicly documented Alpine release lifecycle policy (general knowledge, not a live lookup) — see DEP-008.
oc (OpenShift client)	4.15.20	Cluster exec/backup orchestration — the CronJobs exec into Crunchy and Moodle pods	Downloaded via `curl` from `mirror.openshift.com` and extracted from a `.tar.gz` with no checksum or GPG signature verification — see DEP-009.
swaks	v20240103.0	Perl-based SMTP client that talks to the unauthenticated BC Gov SMTP relay	Fetched via a raw GitHub URL tied to a specific tag, but with no checksum/signature verification of the downloaded script — see DEP-009.
bash, curl, jq, ca-certificates, perl, perl-net-ssleay, tini, postgresql-client	Alpine 3.20 repo (floating, no explicit version pins)	Script runtime and orchestration for the backup-integrity, moodledata-snapshot, and restore-rehearsal CronJobs	Installed via `apk add --no-cache` with no version pins; float with whatever is current in the Alpine 3.20 package repo at build time.

26.3 Development Dependencies

None identified — this is a single-stage runtime image (`FROM docker.io/library/alpine:3.20`) with no separate build/compile stage.

26.4 Dependency Tree Summary

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
alpine	3.20	bash@apk-latest, curl@apk-latest, jq@apk-latest, ca-certificates@apk-latest, perl@apk-latest, perl-net-ssleay@apk-latest, tini@apk-latest, postgresql-client@apk-latest	2	All 8 packages installed via a single `apk add --no-cache` (Containerfile.ops); none have explicit version pins.
oc (OpenShift client)	4.15.20	N/A	1	Downloaded as a standalone tarball (Containerfile.ops); no further transi

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
				tives tracked in-repo.
swaks	v20240103.0	N/A	1	Downloaded as a standalone script (Containerfile.ops); depends at runtime on the `perl/perl-net-sslea` y packages already listed above.

Source: `Containerfile.ops` (no lock file present; `lockFileAvailable: false`).

26.5 Security Analysis

26.5.1 High Risk Issues

None identified for this component.

26.5.2 Technical Debt

1. **[DEP-008] Alpine 3.20 base image approaching the end of its documented support window**: Containerfile.ops reads `FROM docker.io/library/alpine:3.20`. Per Alpine Linux's publicly documented release lifecycle policy (alpinelinux.org —

general knowledge, not a live database lookup performed in this run), each Alpine branch typically receives approximately 2 years of support from its release date. Alpine 3.20 was released in 2024; as of the assessment date (2026-09-08) this branch is expected to be at or near the end of its supported window. `eol_date` is not asserted precisely and `cve_count` is not populated, since no live lifecycle/CVE database lookup was performed — this finding documents a lifecycle-timing risk based on general public knowledge, not a confirmed CVE.

2. **[DEP-009] oc CLI and swaks binaries downloaded over HTTPS with no checksum or signature verification**: Containerfile.ops runs `curl -fsSL -o /tmp/oc.tar.gz https://mirror.openshift.com/pub/openshift-v4/clients/ocp/${OC_VERSION}/openshift-client-linux-${OC_VERSION}.tar.gz` followed immediately by `tar -xzf /tmp/oc.tar.gz -C /usr/local/bin oc`, and separately `curl -fsSL -o /usr/local/bin/swaks https://raw.githubusercontent.com/jetmore/swaks/v20240103.0/swaks`. Both downloads rely solely on TLS transport security; neither verifies a checksum, GPG signature, or hash against a known-good value before the binary/script is made executable (`chmod +x`) and later run with cluster-exec and SMTP-relay privileges respectively. `OC_VERSION` (4.15.20) and the `swaks` tag (`v20240103.0`) are at least pinned to specific versions, which limits blast radius compared to a floating "latest" reference, but the lack of integrity verification remains a supply-chain gap.

---

27 PHP-FPM Application Container Dependencies

This document provides a detailed analysis of dependencies for the PHP-FPM Application Container component.

27.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

27.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
php	8.3-fpm-bookworm	PHP-FPM runtime serving Moodle	Floating minor-version tag (`php:8.3-fpm-bookworm`), not digest-pinned. PHP 8.3 is approaching the end of its active-support window per php.net's published support schedule (general public knowledge, not a live lookup) — see DEP-006.
moodle (core)	`MOODLE_405_STABLE` (git	Learning manageme	Cloned via `git clone --depth=1 --branch ${MOODLE_BRANCH}`; tracks a live stable branch

Library	Version	Purpose	Security/Technical Debt Notes
	branch)	nt system application code	rather than a tag or commit SHA — see DEP-005.
moodle-mod_hvp (H5P)	`master` branch, `--recurse-submodules`	Interactive H5P content plugin	Cloned from the unpinned `master` branch of a third-party community plugin, including its `h5p-php-library` submodule — see DEP-001.
moodle-course_search	default branch (unspecified)	BC Gov course search block	No `--branch`/tag/commit pin at all — see DEP-002.
moodle-local_githubsync	default branch (unspecified)	PSA GitHub sync local plugin	No `--branch`/tag/commit pin at all — see DEP-002.
psaelmsync	default branch (unspecified)	PSA ELM sync local plugin	No `--branch`/tag/commit pin at all — see DEP-002.
pathcurator-moodle	default branch (unspecified)	Pathcurator activity module	No `--branch`/tag/commit pin at all — see DEP-002.
bcgovpsa-moodle (theme)	default branch (unspecified)	BC Gov PSA child theme	No `--branch`/tag/commit pin at all — see DEP-002.
docker-php-extension-installer (mlocati)	`releases/latest`	Installs the PHP extensions below	Fetched via a floating “latest release” URL with no version pin or checksum verification — see DEP-003.
gd, intl, ldap, exif, mbstring, opcache, pdo_pgsql, pgsql, soap, xsl, zip, redis	version bundled with install-php-extensions (indeterminate — tool is unpinned)	Moodle’s required PHP extensions	Installed by the unpinned installer above; exact extension build versions are not recorded anywhere in-repo.
php-fpm-healthcheck	`master` branch (raw	Liveness/readiness	Fetched from a floating branch with no version pin or checksum verification — see DEP-004.

Library	Version	Purpose	Security/Technical Debt Notes
	GitHub URL)	probe script for the FPM pool	
libfreetype-dev, libjpeg62-turbo-dev, libpng-dev, libwebp-dev, libzip-dev, libxml2-dev, libxslt-dev, libldap-dev, libonig-dev, libicu-dev, libpq-dev, libfcgi-bin, libcurl4-openssl-dev, ca-certificates	Debian bookworm apt repo (floating)	OS-level headers/libs required to build the PHP extensions	Installed via `apt-get install` with no explicit version pins; float with the Debian bookworm point-in-time repo snapshot.

27.3 Development Dependencies

- `debian:bookworm-slim` (build stage `src`, Containerfile.php): Moodle git-clone builder stage — floating minor-version tag, does not ship in the final runtime image.
- `git`, `ca-certificates` (apt, Containerfile.php): build-stage-only tooling used to clone Moodle core and plugins; not present in the final runtime image.

27.4 Dependency Tree Summary

No package-manager lock file exists for this component (Moodle's own PHP dependencies are vendored inside the cloned repository itself, not declared via `composer.json` in this repo). The tree below is derived entirely from `Containerfile.php`.

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
php	8.3-fpm-bookworm	gd@unpinned, intl@unpinned, ldap@unpinned, exif@unpinned, mbstring@unpinned, opcache@unpinned, pdo_pgsql@unpinned, pgsql@unpinned,	2	All 12 extensions installed by the

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
		soap@unpinned, xsl@unpinned, zip@unpinned, redis@unpinned		unpinned `install-php-extensions` tool (depth 2); their resolved build versions are not recorded in-repo.
moodle (core)	MOODLE_405_STABLE@unpinned-branch	moodle-mod_hvp@master, moodle-course_search@default-branch, moodle-local_githubsync@default-branch, psaelmsync@default-branch, pathcurator-moodle@default-branch, bcgovpsa-moodle@default-branch	2	The 6 plugin/theme repos are not Moodle-core dependencies in a package-manager sense, but are layere

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
				d into the same source tree at build time (`${MOODLE_SRC}/...`) with the same lack of pinning.
docker-php-extension-installer	latest (floating)	N/A	1	Single-file build tool; no further transitives.
php-fpm-healthcheck	master (floating)	N/A	1	Single-file script; no further transitives.

Source: `Containerfile.php` (no lock file present for any of the above; `lockFileAvailable: false`).

27.5 Security Analysis

27.5.1 High Risk Issues

1. **[DEP-001] HVP plugin pinned to an unpinned, floating `master` branch with recursive submodules**: Containerfile.php runs `git clone --recurse-submodules --depth=1 --branch ${HVP_BRANCH} --single-branch https://github.com/h5p/moodle-mod_hvp ${MOODLE_SRC}/mod/hvp` where `HVP_BRANCH` defaults to `master` (Containerfile.php). This clones the live head of a third-party community plugin repository (plus its `h5p-php-library` submodule) directly into the production Moodle codebase with no tag, release, or commit SHA pin, and no code review or checksum gate. Any commit pushed to that upstream `master` branch — malicious or accidental — becomes production code on the very next image build. The `scheduled-rebuild.yml` workflow explicitly reruns this build every Saturday specifically to pick up such upstream changes automatically. **Evidence:** `RUN git clone --recurse-submodules --depth=1 --branch ${HVP_BRANCH} --single-branch \ / https://github.com/h5p/moodle-mod_hvp ${MOODLE_SRC}/mod/hvp`. Severity assessed as High per the "No lock file present for a package manager in production code" baseline — there is no pinning mechanism of any kind for code that becomes part of the running application.

2. **[DEP-002] Five first-party/BC Gov plugin and theme repositories cloned with no branch, tag, or commit pin**: Containerfile.php clones `moodle-course-search`, `moodle-local_githubsync`, `psaelmsync`, `pathcurator-moodle`, and `bcgovpsa-moodle` (the child theme) each via `git clone --depth=1 --single-branch <url> <path>` with no `--branch` flag at all — meaning each clone tracks whatever the remote's current default branch resolves to at build time. **Evidence:** `RUN git clone --depth=1 --single-branch \ / https://github.com/bcgov/moodle-course-search.git ${MOODLE_SRC}/blocks/course_search \` (and four more identical patterns for the remaining repos, lines 36-45). Same risk class as DEP-001: no version pin, no checksum, no manual review gate before upstream code becomes production code on rebuild.

27.5.2 Technical Debt

1. **[DEP-003] docker-php-extension-installer fetched via a floating "latest release" URL with no checksum verification**: Containerfile.php runs `ADD https://github.com/mlocati/docker-php-extension-installer/releases/latest/download/install-php-extensions /usr/local/bin/` — this always resolves to whatever the maintainer has most recently tagged as a GitHub release, with no version pin and no checksum/signature verification of the downloaded binary before it is `chmod +x`'d and executed as root during the image build. The identical pattern also appears in the cron-workload component (`Containerfile.cron` line 23), since both images independently perform this fetch.

2. **[DEP-004] php-fpm-healthcheck fetched from the unpinned `master` branch with no checksum verification**: Containerfile.php runs `ADD https://raw.githubusercontent.com/renatomefi/php-fpm-healthcheck/master/php-fpm-healthcheck /usr/local/bin/php-fpm-healthcheck` — fetched from the live `master` branch of a third-party repository with no tag/commit pin and no checksum verification, then made executable (`chmod 755`) and invoked as the container's `HEALTHCHECK` command.

3. **[DEP-005] Moodle core pinned to a floating stable branch rather than a tag or commit SHA**: Containerfile.php and Containerfile.php clone `https://github.com/moodle/moodle.git` via `--branch ${MOODLE_BRANCH}` where `MOODLE_BRANCH` defaults to `MOODLE_405_STABLE` — a continuously-updated stable branch, not an immutable tag or commit. This is a deliberate, documented design choice (`scheduled-rebuild.yml` reruns the build weekly specifically "to pick up … Moodle point-release fixes on the MOODLE_405_STABLE branch"), which mitigates most of the reproducibility risk since the intent is to track upstream security patches automatically; however, it also means a specific vulnerable or regressed commit on that branch could be silently absorbed into every subsequent build with no manual gate.

4. **[DEP-006] PHP 8.3 approaching end of active support (public documented knowledge)**: Containerfile.php pins `FROM php:8.3-fpm-bookworm`. PHP 8.3 was released 2023-11-23; per PHP's publicly documented supported-versions schedule (php.net/supported-versions.php — general knowledge, not a live lookup performed in this run), each PHP minor version receives active support for approximately 2 years followed by 1 additional year of security-only fixes. As of the assessment date (2026-09-08), PHP 8.3 is expected to be in, or very near, its security-fixes-only support window ahead of full end-of-life around November 2026. `cve_count` is not populated (no live CVE database was consulted), and the exact patch-level of `php:8.3-fpm-bookworm` actually pulled at build time is not recorded anywhere in this repository (floating tag), so the precise current CVE exposure cannot be confirmed from the repo alone.

---

28 PostgreSQL Cluster (Crunchy PostgreSQL Operator) Dependencies

This document provides a detailed analysis of dependencies for the PostgreSQL Cluster (Crunchy PostgreSQL Operator) component.

28.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

28.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
Crunchy PostgreSQL (operator-managed image)	`postgresVersion: 15` (`.Values.postgres.postgresVersion`); `.Values.postgres.image` is empty by default	Primary relational datastore for Moodle	The chart only pins the Postgres **major** version (15) via the `PostgresCluster` CR's `spec.postgresVersion` field (postgrescluster.yaml); `.Values.postgres.image` is `""` by default (values.yaml), meaning the Crunchy PostgreSQL Operator selects its own default image for that major version. Neither the operator's own version nor the exact Postgres 15.x minor/patch level it will deploy is recorded anywhere in this repository — see DEP-010.
pgBackRest	bundled with the operator, version not pinned in-repo	Backup/restore tooling (full + incremental schedules configured in postgrescluster.yaml)	Same operator-opacity gap as the primary Postgres image — pgBackRest ships with whichever operator version is installed cluster-wide; `.Values.postgres.pgbackrest.image` is also empty by default.

28.3 Development Dependencies

None identified — this component has no build stage; it is a Kubernetes custom resource (`PostgresCluster`) consumed by an out-of-repo, cluster-installed operator.

28.4 Dependency Tree Summary

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
Crunchy PostgreSQL (operator-managed image)	postgresVersion 15 (patch level operator-controll	pgbackrest@operator-bundled (unpinned)	2	Source: `chart/psa-moodle/templates/postgres`

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
	ed)			cluster.yaml and chart/psa-moodle/values.yaml.

No lock file exists for this component (`lockFileAvailable: false`) — the actual image reference is resolved at admission time by the cluster-installed Crunchy PostgreSQL Operator, which is out of scope for this repository.

28.5 Security Analysis

28.5.1 High Risk Issues

None identified for this component.

28.5.2 Technical Debt

1. **[DEP-010] Crunchy PostgreSQL Operator version and managed image are not pinned or tracked anywhere in this repository**: postgrescluster.yaml shows `postgresVersion: {{ .Values.postgres.postgresVersion }}` followed by an optional `image:` override that is only rendered `{{- with .Values.postgres.image }}` — and `postgres.image` defaults to `""` in values.yaml (`# Operator's default Postgres image; override only if BC Gov mirrors it.`). This means the chart pins only the Postgres **major** version (15); the exact minor/patch release, and the Crunchy PostgreSQL Operator version itself (which must be pre-installed cluster-wide, per `docs/namespace-handover.md`), are entirely determined outside this repository. As a result, the actual current CVE exposure of the running Postgres instance cannot be confirmed from the repo alone — `cve_count` is not populated and no live CVE lookup was performed for this finding.

---

29 Valkey Cache Dependencies

This document provides a detailed analysis of dependencies for the Valkey Cache component.

29.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

29.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
valkey/valkey	7.2-alpine	Redis-compatible session/cache store, single replica	Floating minor-version tag (`7.2-alpine`), not digest-pinned — see DEP-011. Referenced identically in values.yaml (`repository: docker.io/valkey/valkey`, `tag: 7.2-alpine`) and in the local dev compose stack.

29.3 Development Dependencies

None identified — this component consumes a pre-built upstream image with no in-repo build stage.

29.4 Dependency Tree Summary

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
valkey/valkey	7.2-alpine	N/A	1	No transitive dependencies detected — Valkey is consumed as a single pre-built upstream image with no additional packages layered on

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
				top in this repository.

Source: `chart/psa-moodle/values.yaml` (no lock file present; `lockFileAvailable: false`).

29.5 Security Analysis

29.5.1 High Risk Issues

None identified for this component.

29.5.2 Technical Debt

1. **[DEP-011] Valkey base image pinned to a floating minor-version tag, not an immutable digest**: values.yaml sets `repository: docker.io/valkey/valkey` / `tag: 7.2-alpine`. This tag is rebuilt by the upstream Valkey maintainers as patch releases land, so the exact bytes deployed are not reproducible across deployments and are not recorded via a digest pin anywhere in this repository. Valkey 7.2 itself is a comparatively young, actively-maintained fork (general public knowledge; no EOL concern identified), so this is assessed as Low-severity technical debt rather than a vulnerability.

---

30 Web Container (nginx) Dependencies

This document provides a detailed analysis of dependencies for the Web Container (nginx) component.

30.1 Self-containment requirement (MUST)

This file is self-contained; it duplicates evidence rather than referencing other component files.

30.2 Runtime Dependencies

Library	Version	Purpose	Security/Technical Debt Notes
nginxinc/nginx-unprivileged	1.27-alpine	Front-end web server / FastCGI reverse proxy to PHP-FPM	Floating minor-version tag (`1.27-alpine`), not digest-pinned — see DEP-007.

Library	Version	Purpose	Security/Technical Debt Notes
curl	Alpine 3.x repo (floating, no version pin)	HTTP client used by the container HEALTHCHECK	Installed via `RUN apk add --no-cache curl` with no version pin.
Application static assets (from psa-moodle-php image)	inherited via `COPY --from=src /var/www/html /var/www/html`	Static files served directly by nginx (images, CSS, JS)	nginx only serves these files; it does not execute the underlying PHP/Moodle plugin code, so the plugin-pinning risk documented for php-fpm-application (unpinned Moodle plugin sources) applies to the *content* of this copy but is not independently exploitable through nginx itself.

30.3 Development Dependencies

- None identified. This is a single-stage runtime image (`FROM nginxinc/nginx-unprivileged:1.27-alpine`) with no separate build stage of its own (the `src` stage is only used to `COPY --from=src` files, not to compile anything for this image).

30.4 Dependency Tree Summary

Direct Dependency	Version	Key Transitives (name@version)	Max Depth	Notes
nginxinc/nginx-unprivileged	1.27-alpine	curl@apk-latest (floating)	2	`curl` is the only additional package installed on top of the base image (Containerfile.web).

Source: `Containerfile.web` (no lock file present; `lockFileAvailable: false`).

30.5 Security Analysis

30.5.1 High Risk Issues

None identified for this component specifically.

30.5.2 Technical Debt

1. **[DEP-007] nginx-unprivileged base image pinned to a floating minor-version tag, not an immutable digest**: Containerfile.web reads `FROM nginxinc/nginx-unprivileged:1.27-alpine`. The `1.27-alpine` tag is rebuilt by the upstream maintainer whenever the underlying Alpine base or nginx patch release changes, meaning the exact bytes pulled at build time are not reproducible across builds and are not recorded anywhere in this repository (no digest pin, e.g. `@sha256:...`). This is a common, low-severity technical-debt pattern rather than a confirmed vulnerability — nginx mainline (1.27.x) is actively maintained upstream, and the floating tag is consistent with this repo's stated intent (`scheduled-rebuild.yml`) of picking up upstream security patches automatically on a weekly cadence.

---

31 Testing Inventory

This document provides a comprehensive inventory of testing found in the codebase, along with the components that have not been tested.

31.1 Executive Summary

psa-moodle is deployment tooling (Containerfiles, Helm chart, ops shell scripts) that packages and operates an upstream Moodle 4.5 instance — it is **not** an application codebase with business logic, so there is no traditional unit/integration/e2e test suite (no PHPUnit, Behat, Jest, or similar test files or frameworks were found anywhere in the repository). Testing coverage must instead be judged against what is testable for this repo's actual artifacts: Helm chart correctness, shell script quality, container build success, and — most importantly — the operational health of the backup/restore pipeline.

Judged on that basis, the repository has a genuinely mixed-but-honest testing posture. The .github/workflows/lint.yml and .github/workflows/build.yml CI jobs provide real, automated pre-merge validation (`helm lint`, `helm template` dry-run, `shellcheck`, `yamllint`, container build verification) that gates every pull request. Separately, scripts/ops/backup-integrity.sh and scripts/ops/restore-rehearsal.sh are genuine, scheduled, production-grade operational tests — a daily backup-integrity check and a weekly full disaster-recovery restore drill that provisions a temporary PostgreSQL cluster from real backups and runs SQL-level assertions against it. These were built specifically in response to a documented 2026-04 silent-backup-failure incident and represent above-average operational testing maturity for a project of this size.

Gaps remain: there is no automated test of the actual application behavior after deploy beyond a single string-match smoke test (login page renders); the Helm lint/template CI job does not exercise `values-poc.yaml`; the `moodledata` PVC snapshot pipeline has no restore-verification counterpart to the database's restore rehearsal; and the local Podman Compose stack (compose.yaml) is never exercised in CI at all. No SAST, SCA, secret-scanning, or container image-scanning gates are present in the pipeline.

31.2 CI/CD Pipeline and Quality Gates

Pipeline tooling detected: GitHub Actions **Pipeline files:** .github/workflows/build.yml, .github/workflows/lint.yml, .github/workflows/deploy.yml, .github/workflows/scheduled-rebuild.yml **Automation maturity rating:** Low — automated validation (lint + build verification + a single smoke test) runs on every PR/deploy, but there is no application test stage, no coverage gate, and no SAST/SCA/secret/image scanning of any kind.

Quality Gate	Present?	Tool / Evidence
Automated test stage	No	No unit/integration test runner invoked anywhere in `.github/workflows/`; closest equivalent is `helm lint`/`helm template` in .github/workflows/lint.yml
Code coverage report	No	Not applicable — no test runner exists to produce coverage
Fail-on-coverage-threshold	No	Not applicable
SAST	No	No CodeQL/Semgrep/SonarQube/bandit step found in any workflow
SCA / dependency scan	No	No `npm audit`/`pip-audit`/Dependabot/Snyk step found; no Dependabot config file present
Secret scanning	No	No truffleHog/gitleaks/detect-secrets step found
Container image scan	No	No Trivy/Grype/Anchore step found in .github/workflows/build.yml

Quality Gate	Present?	Tool / Evidence
Lint / code quality gate	Yes	`helm lint`, `shellcheck --severity=warning`, `yamllint` — .github/workflows/lint.yml
Branch protection / PR approval	Partial	`build`/`lint` workflows trigger `on: pull_request`, implying required-status-check usage, but no branch-protection ruleset file is present in-repo to confirm enforcement
Deployment approval / protection	Yes	`deploy` job uses GitHub `environment: test`, which can require reviewers via repo settings — .github/workflows/deploy.yml

31.3 Inventory of Testing on Various Components

Component Tested	Test Types	Test Coverage Level	Testing Frameworks Used
postgresql-cluster	Operational/integration (daily backup-integrity check, weekly full restore-and-verify drill)	Comprehensive	bash + `pgbackrest`, `psql` (scripts/ops/backup-integrity.sh, scripts/ops/restore-rehearsal.sh)
ops-tooling	Lint (shellcheck) + the operational tests it implements for postgresql-cluster	Comprehensive	shellcheck, bash
helm-chart-topology	Static validation (`helm lint`) + render dry-run (`helm template`) for `values-dev`/`values-test`/default	Partial	Helm v3.14.3 (.github/workflows/lint.yml)
cicd-pipeline	Self-validation via `shellcheck`, `yamllint`	Partial	shellcheck, yamllint

Component Tested	Test Types	Test Coverage Level	Testing Frameworks Used
web-container	Kubernetes health probes (`/health` liveness/readiness) + one post-deploy smoke test (login page string match)	Minimal	none (bash `curl` smoke test in .github/workflows/deploy.yml)
php-fpm-application	Build-success verification (`make build`) + `php-fpm-healthcheck` probes + indirect coverage from the login-page smoke test	Minimal	none — no PHPUnit/Behat
openshift-route	Indirectly exercised by the login-page smoke test (traffic must traverse the route to reach `/login/index.php`)	Minimal	none
cron-workload	Liveness probe only (heartbeat-file staleness check); no functional test of `cron.php` execution	Minimal	none
valkey-cache	Kubernetes health probes only	Minimal	none
moodledata-storage	Daily VolumeSnapshot creation; no restore verification	Minimal	none
install-job	None (relies on the post-install Job succeeding once; no verification step in the Job itself beyond `install_database.php`'s own exit code)	None	none
network-policy	None	None	none
monitoring-	None	None	none

Component Tested	Test Types	Test Coverage Level	Testing Frameworks Used
observability			
local-dev-compose	None — never invoked in CI	None	none
documentation-runbooks	Not applicable (documentation, not executable)	Not applicable	none

31.4 Components Not Tested

1. install-job (no verification beyond the installer script's own exit code)
2. network-policy (no automated check that ingress/egress rules permit/deny expected traffic)
3. monitoring-observability (no test that Prometheus scrape wiring actually works)
4. local-dev-compose (compose.yaml/compose.registry.yaml are never built or started in CI)

31.5 Detailed Findings

ID	Component	Issue Type	Severity	Location	Description
TEST-001	php-fpm-application	No Security Tests	High	No test files anywhere in repo (confirmed via repo-wide search for `phpunit/behat/*test*/*spec*`)	The custom Moodle configuration layer (config/moodle/config.local.php, config/moodle/config.openshift.php) and the nginx access-control rules in config/nginx/default.conf (deny-rules, XFF handling) have no automated tests verifying authentication enforcement, access-control behavior, or safe handling of the `X-Forwarded-For`

ID	Component	Issue Type	Severity	Location	Description
					header. The only post-deploy check is a single string match against the login page (`grep -qE 'Log in|loginbox'` in .github/workflows/deploy.yml), which confirms the page renders but does not verify any authentication or authorization control.
TEST-002	cicd-pipeline	Missing Pipeline Gate	Medium	.github/workflows/build.yml, .github/workflows/lint.yml	No SAST, SCA/dependency-scan, secret-scanning, or container-image-scan step exists in any workflow. For a repo that builds and ships container images running a public-facing web application (Moodle), the absence of image/dependency scanning means known-CVE base images or vulnerable PHP/Moodle plugin dependencies would not be automatically

ID	Component	Issue Type	Severity	Location	Description
					flagged before deployment.
TEST-003	helm-chart-topology	Missing Pipeline Gate	Low	.github/workflows/lint.yml	`helm lint`/`helm template` in CI only exercises the default values, `values-dev.yaml`, and `values-test.yaml`. `values-poc.yaml` (present at chart/psa-moodle/values-poc.yaml) is never lint-checked or rendered in CI, so a POC-environment-specific misconfiguration (e.g., an invalid override) would not be caught until a manual `helm upgrade` against that environment.
TEST-004	moodledata-storage	Untested Critical Path	Low	scripts/ops/moodledata-snapshot.sh	The moodledata PVC (uploaded user content) is snapshotted daily, but unlike the PostgreSQL backup pipeline (which has scripts/ops/restore-rehearsal.sh proving restorability weekly), there is no corresponding rehearsal that

ID	Component	Issue Type	Severity	Location	Description
					restores a VolumeSnapshot and verifies its contents. A silently-corrupt moodledata snapshot would not be detected until an actual disaster-recovery event.
TEST-005	install-job	Untested Critical Path	Low	chart/psa-moodle/templates/job-install.yaml	The post-install Helm hook that bootstraps the Moodle database (`install_database.php`) has no explicit post-run verification step (e.g., confirming expected tables/admin user were created); it relies solely on the script's own process exit code, with no independent smoke test of the resulting install.
TEST-006	local-dev-compose	Insufficient Testing	Low	compose.yaml, compose.registry.yaml	The local Podman Compose stack is not built, started, or exercised by any CI workflow — only its YAML syntax is checked by `yamllint` in .github/workflows/lint.yml. A change that breaks local

ID	Component	Issue Type	Severity	Location	Description
					developer onboarding (e.g., a bad compose service definition) would not be caught in CI.
TEST-007	network-policy	No Security Tests	Low	chart/psa-moodle/templates/networkpolicy.yaml	No automated test (e.g., a `netpol`/Kyverno policy test, or a post-deploy connectivity check) verifies that the default-deny NetworkPolicy actually permits required traffic and blocks disallowed traffic. Correctness currently depends entirely on manual review of the YAML rules.

31.6 Important Notes

1. All placeholder text has been replaced with actual findings based on direct repository evidence.
2. This is a deployment-tooling repository with no application source code of its own (Moodle core and plugins are pulled from upstream at build time), so the absence of conventional unit/integration tests is structural, not necessarily a defect — see the Executive Summary for the operational-testing credit given to the backup-integrity/restore-rehearsal jobs.
3. All 15 architecture components are addressed above; components with no direct evidence of testing are explicitly listed under “Components Not Tested.”
4. Findings TEST-001 through TEST-007 are the complete set of testing gaps identified; no testing-related findings were omitted.